국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[○], 보안[ ]

중앙행정기관명		사업명	사업명	국가간협력기반조성사업	
전문기관명 (해당 시 작성)	한국연구재단		내역사업명	한-뉴질랜드 협력기반조성	
공고번호		총괄연구개발 식별번호 (해당 시 작성)			
		연구개발과제번호			

기술분류	국가과학기술표준분류							
		EE0302	40%	EE0303	30%	EE0304	30%	

총괄연구개발명 (해당 시 작성)	국문	
	영문	
연구개발과제명	국문	사물인터넷 환경을 위한 첨단 보안 기술 연구
	영문	Advanced Security Technologies for the Internet of Things

주관연구개발기관	기관명	고려대학교	사업자등록번호	2098208298
	주소	(02841) 서울특별시 성북구 안암로 145 (안암동5가, 고려대학교 내)	법인등록번호	114471-0002565

연구책임자	성명	김휘강	직위	정교수
	연락처 직장전화	02.3290.3521	휴대전화	********
	연락처 전자우편	cenda@korea.ac.kr	국가연구자번호	10208314

연구개발기간	전체	2018. 02. 19 - 2021. 02. 18 (3년 0개월)

연구개발비 (단위: 천원)	정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
				지방자치단체		상대국 연구개발비					
	현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계	87,000	0	0	0	0	346,530	0	433,530	0	433,530	0
1년차	29,000	0	0	0	0	115,510	0	144,510	0	144,510	0
2년차	29,000	0	0	0	0	115,510	0	144,510	0	144,510	0
3년차	29,000	0	0	0	0	115,510	0	144,510	0	144,510	0

공동연구개발기관 등	기관명	책임자	직위	휴대전화	전자우편	비고	
						역할	기관유형
연구개발기관 외 기관	University of Canterbury	김동성	부교수	-	dongseong.kim@canterbury.ac.nz	*국협*	*대학*

연구개발담당자 실무담당자	성명	김영환	직위	박사
	연락처 직장전화	02.3290.3521	휴대전화	********
	연락처 전자우편	jamesck@korea.ac.kr	국가연구자번호	11833477

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2021 년 3 월 17 일

연구책임자: 김 휘 강 (인)

주관연구개발기관의 장: 조 석 주 (직인)
공동연구개발기관의 장: (직인)
위탁연구개발기관의 장: (직인)

중앙행정기관의 장 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 요 약 문 >

사업명		국가간협력기반조성사업			총괄연구개발 식별번호 (해당 시 작성)			
내역사업명 (해당 시 작성)		한-뉴질랜드 협력기반조성			연구개발과제번호			
기술 분류	국가과학기술 표준분류	EE0302	40%	EE0303	30%	EE0304	30%	
총괄연구개발명 (해당 시 작성)								
연구개발과제명		사물인터넷 환경을 위한 첨단 보안 기술 연구						
전체 연구개발기간		2018. 02. 19 - 2021. 02. 18						
총 연구개발비		총 433,530 천원 (정부지원연구개발비: 8,7000 천원, 상대국 연구개발비: 346,530 천원)						
연구개발단계		기초[ ] 응용[ㅇ] 개발[ ] 기타(위 3가지에 해당되지 않는 경우)[ ]			기술성숙도 (해당 시 기재)	착수시점 기준( ) 종료시점 목표( )		
연구개발과제 유형 (해당 시 작성)								
연구개발과제 특성 (해당 시 작성)								

연구개발 목표 및 내용	최종 목표	본 연구의 목표는 Internet of Things (IoT) 환경을 위한 새로운 첨단 사이버보안 기술을 설계하고 테스트하는 것이다. 이는 양국의 IoT 환경에 적합한 자동화된 보안 평가 모델, self-learning 기반의 침입탐지 및 대응 기술, 보안사고 예측 기술, usable security 기술을 개발하여 보다 안전한 IoT 환경 구축 및 서비스를 제공하는 것을 목표로 한다.
	전체 내용	사이버보안 평가 프레임워크 세부에서는 1차년도에 사이버보안을 위한 최신 그래픽 모델들의 장점과 단점을 분석하고, 크기가 크고 동적으로 변화하는 IoT 환경에 적합한 그래픽 보안 모델과 효율적인 보안 분석 평가 방법을 개발한다. 2차년도에는 기존의 보안·성능·경제 지표(metric)들이 IoT 환경에서 얼마나 효과적인지 분석하고, IoT 장치들의 이종성 및 유동성을 반영한 효율적인 보안·성능·경제 지표들을 개발한다. 3차년도에는 기업 네트워크로부터 네트워크 설정 정보, 취약점 정보를 수집하고 자동으로 그래픽 보안 모델을 생성 및 분석하여 기업 네트워크의 보안 수준을 평가하는 safelite라는 보안 평가 도구를 개발한다. 침입탐지 및 대응 기술 세부에서는 1차년도에 자율주행 자동차를 대상으로 IoT 네트워크에 잠재된 위협을 도출하고, 현존하는 탐지, 완화, 대응 기술을 조사하며, 위협들을 공유하기 위한 인프라스트럭처를 설계하고 개발한다. 2차년도에는 알려진 공격을 탐지하는데 효과적인 시그니처 기반의 침입탐지 시스템과 새로운 공격을 탐지하기 위한 이상징후 기반 침입탐지 시스템을 개발한다. 3차년도에는 기계학습 및 딥러닝 기술을 적용하여 self-learning 침입탐지 기술과 침입방지 시스템을 이용한 대응책을 제시한다. 보안사고 예측 기술 세부에서는 1차년도에 IoT 장치들로부터 ENF 전력 신호를 효율적으로 수집하는 방법을 탐색하고 노이즈 멀티미디어에서 ENF 전력 신호를 탐지 및 추출하는 기술을 연구한다. 2차년도에는 다중 ENF 신호의 고주파 특성을 추출하고 결합하는 기술과 신호 정렬 기술을 연구한다. 3차년도에는 ENF 신호를 이용한 보안사고 예측 시스템을 개발한다. usable security 세부에서는 1차년도에 일반 사용자들에 대한 전반적인 위협 모델들과 그 대응방안을 조사하고, 스마트홈을 위한 보안 어플리케이션을 개발한다. 2차년도에는 IoT 어플리케이션을 위한 사이버보안 위협 탐지 및 경고 시스템을 개발한다. 3차년도에는 사용자의 보안 요구사항을 반영한 보안 규칙을 정의하고, 사용자의 행위와 만족도를 평가하기 위한 지표를 개발한다. 본 연구에서 개발한 스마트홈 및 자율주행 자동차에 적용 가능한 IoT 보안 기술을 뉴질랜드 및 한국의 테스트베드에서 시험하여 본 연구의 개발물의 실현 가능성과 실용성을 검증하도록 한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구개발 목표 및 내용	1차 년도	목표	1차년도에는 그래픽 보안 모델 및 효율적 평가 방법 개발 세부에서는 IoT 장치들의 이종성과 유동성을 모두 고려한 보안 평가 모델 및 효율적 평가 방안을 연구한다. 자율주행 차량의 위협 모델링 및 공격 패턴 공유를 위한 인프라스트럭처 개발 세부에서는 자율주행 차량에서 발생 가능한 공격 패턴을 도출하고 공격 패턴 공유를 위한 인프라 스트럭처를 개발한다. 노이즈 멀티 미디어에서 전기 신호 탐지 및 추출 기술 개발 세부에서는 노이즈가 많은 멀티미디어 데이터로부터 탐지하고 추출하는 기술을 개발한다. 일반 사용자를 위한 IoT 위협 모델 및 보안 어플리케이션 개발 세부에서는 일반 사용자에게 발생 가능한 보안 위협 모델을 도출하고 IoT 환경에 적합한 보안 어플리케이션을 개발한다.
		내용	사이버보안 평가 프레임워크 세부에서는 사이버보안을 위한 자동화된 보안 평가 그래픽 모델을 개발하며, IoT 장치들의 효율적인 보안 평가 방법을 연구한다. 침입탐지 및 대응 기술 세부에서는 자율주행 차량의 위협 모델링을 통해 잠재된 위협을 도출하며, 공격 패턴 공유를 위한 인프라스트럭처를 설계하고 개발한다. 보안사고 예측 기술 세부에서는 효율적인 전기 신호 수집 기술과 노이즈가 많은 환경에서 전기 신호의 탐지 및 추출 기술을 개발한다. usable security 세부에서는 일반 사용자에게 발생할 수 있는 위협 모델을 개발하며, IoT 환경에서의 보안 어플리케이션을 개발한다.
	2차 년도	목표	2차년도에는 IoT 환경에 적합한 보안·성능·경제 지표 개발 세부에서는 IoT 장치들의 이종성과 유동성을 모두 고려한 보안·성능·경제 지표를 개발한다. 차량 내부 네트워크용 침입탐지 시스템 개발 세부에서는 차량 내부 네트워크에서 활용이 가능한 시그니처 및 이상징후 기반의 침입탐지 시스템을 개발한다. 고품질 ENF 신호 추출 기술 개발 세부에서는 많은 신호가 혼재된 IoT 환경에서 고품질의 ENF 신호를 추출하기 위한 기술을 개발한다. 사이버 보안 위협 탐지 및 경고 시스템 개발 세부에서는 사이버 보안 위협을 탐지하고 사용자에게 직관적인 인터페이스를 통해 정보를 제공하는 시스템을 개발한다.
		내용	IoT 환경에 적합한 보안·성능·경제 지표 개발 세부에서는 IoT 환경에 적합한 보안 지표 및 성능·경제 지표를 개발한다. 차량내부 네트워크용 침입탐지 시스템 개발 세부에서는 시그니처 기반의 침입탐지 시스템과 이상징후 기반의 침입탐지 시스템을 개발하고, 고품질 ENF 신호 추출 기살 개발 세부에서는 다중 ENF 신호의 고주파 특성을 추출하며 결합하는 기술을 개발하고 신호 정렬 기술을 이용하여 중첩된 신호를 추출을 한다. 그리고 사이버 보안 위협 탐지 및 경고 시스템 개발 세부에서는 사이버 보안 위협 탐지 시스템 및 사이버 보안 위협 경고 시스템을 개발한다.
	3차 년도	목표	3차년도에는 통합된 보안 평가 도구 개발 및 테스트 세부에서는 IoT 장치들의 이종성과 유동성을 모두 고려한 보안 평가 모델 및 효율적 평가 방안을 연구한다. self-learning & 침입탐지 기술 및 침입방지 기술 개발 세부에서는 최신 기계학습 기법을 이용한 self-learning 침입탐지 기술을 개발하고 침입을 방지하기 위한 기술을 개발한다. ENF 신호를 이용한 보안사고 예측 시스템 개발 세부에서는 ENF 신호와 보안사고의 연관성을 분석하여 보안사고 예측 가능성을 분석하고 ENF 신호를 이용한 예측 시스템을 개발한다. 보안 규칙 도출 및 편의성 평가 지표 개발 세부에서는 IoT 장치의 보안 정책을 손쉽게 관리하도록 하는 기술 및 어플리케이션의 편의성 평가 지표를 개발한다.
		내용	보안 평가 모델 개발 세부에서는 기업 네트워크로부터 네트워크 설정 정보, 취약점 정보를 수집하고 자동으로 그래픽 보안 모델을 생성 및 분석하여 기법 네트워크의 보안 수준을 평가하는 safelite 라는 보안 평가 도구를 개발한다. 침입탐지 및 대응기술 모델 세부에서는 기계학습 및 딥러닝 기술을 적용하여 self-learning 침입방지 기술과 침입방지 시스템을 이용한 대응책을 제시한다. 보안사고 예측 기술 세부에서는 ENF 신호를 이용한 보안 사고 예측 시스템을 개발하며, usable security 기술 세부에서는 사용자의 보안 요구사항을 반영한 보안 규칙을 정의하고 사용자의 행위와 만족도를 평가하기 위한 지표를 개발한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<table>
<tr><td>연구개발성과</td><td>SCI(E) 논문 4편, 비SCIE 9편 게재 / 인력양성 석사 3명, 박사 1명 /
국·내외 과학자 교류 2건 / 한-뉴 공동연구 교류 워크샵 2건 / 기타-수상실적 1건</td></tr>
<tr><td>연구개발성과
활용계획 및
기대 효과</td><td>본 연구 수행결과로서 기대되는 자동화된 보안 위협 평가 프레임워크, 침해사고 탐지 및 반응 기술, 악의적 보안 이벤트 보안 예측 기법 및 편의성 테스트는 IoT 네트워크를 구성하고 있는 홈 캠, CCTV, 스마트홈, 스마트 자동차 등 다양한 시스템과 신규 서비스에서의 정보보호를 위한 기본적인 침해탐지 도구로 활용될 가능성이 있다. IoT는 기존의 임베디드 기기들뿐만 아니라 다양한 기기들에 인터넷이 결합됨에 따라 정보통신 네트워크 및 기기에서 발생 가능한 보안 문제가 작게는 개인 단위에서 크게는 국가적으로 확산 될 수 있다. 따라서 국민에게 제공되는 서비스 정보에 대한 무단 수집 및 도용, 관련 서비스 내용 조작, DDoS 공격으로 인한 네트워크로 연결된 기간 시스템의 마비 등 기존에는 나타나지 않았던 새로운 보안 위협 및 취약성이 점차 확산될 가능성이 크다. 따라서 기술적 측면에서의 보안 대책이 새롭게 수립되어야 하며, 본 연구과제 수행결과인 보안 위험/위협 평가 프레임워크는 IoT 서비스에서의 정보보호를 위한 기반기술로 활용될 수 있으며, 이와 같은 핵심 원천기술 확보를 통하여 특허 기술 선점을 통한 국가 경쟁력 확보가 가능하며, 개발된 기술의 국내업체 이전을 통한 국내업체 경쟁력 강화 및 지적재산권에 대한 간접 수익을 낼 수 있을 것으로 기대된다.</td></tr>
<tr><td>연구개발성과의
비공개여부 및
사유</td><td>-</td></tr>
</table>

<table>
<tr><td rowspan="2">연구개발성과의
등록·기탁 건수</td><td>논문</td><td>특허</td><td>보고서
원문</td><td>연구
시설·
장비</td><td>기술
요약
정보</td><td>소프트
웨어</td><td>표준</td><td colspan="2">생명자원</td><td rowspan="2">화합물</td><td colspan="2">신품종</td></tr>
<tr><td>생명
정보</td><td>생물
자원</td><td>정보</td><td>실물</td></tr>
<tr><td></td><td>4</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td><td>0</td></tr>
</table>

<table>
<tr><td rowspan="2">연구시설·장비
종합정보시스템
등록 현황</td><td>구입
기관</td><td>연구시설·
장비명</td><td>규격
(모델명)</td><td>수량</td><td>구입
연월일</td><td>구입가격
(천원)</td><td>구입처
(전화)</td><td>비고
(설치장소)</td><td>ZEUS
등록번호</td></tr>
<tr><td>-</td><td>-</td><td>-</td><td>-</td><td>-</td><td>-</td><td>-</td><td>-</td><td>-</td></tr>
</table>

<table>
<tr><td>국문핵심어
(5개 이내)</td><td>사물인터넷</td><td>보안 평가
프레임워크</td><td>자동차 보안</td><td>보안사고 예측</td><td>편의성을
고려한 보안</td></tr>
<tr><td>영문핵심어
(5개 이내)</td><td>Internet of
Things</td><td>Security
Assessment</td><td>Automobile
Security</td><td>Security
Incidents
Prediction</td><td>Usable Security</td></tr>
</table>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

〈 목 차 〉

1. 연구개발과제의 개요

2. 연구개발과제의 수행 과정 및 수행내용

3. 연구개발과제의 수행 결과 및 목표 달성 정도

4. 연구개발성과 및 관련 분야에 대한 기여 정도

5. 연구개발성과의 관리 및 활용 계획

별첨자료 (참고 문헌 등)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1. 연구개발과제의 개요

IoT (Internet of Things)는 농업, 스마트홈/도시, 커넥티드/자율주행 차량, 디지털 헬스케어를 포함하여 수많은 응용 분야에서 사용되고 있으며, 2020년 이후 약 200억 개 이상의 IoT 장치가 사용될 것으로 전망된다. IoT 환경에서의 가장 큰 문제점은 네트워크에 연결된 모든 물건이 해킹 위협에 노출될 수 있다는 것으로, 대규모 IoT 장치들을 대상으로 한 보안사고는 이미 발생하고 있다. 그 예로 Mirai 봇넷이 취약한 IoT 장치들을 감염시켜 인터넷 서비스 공급자에게 DDoS (Distributed Denial-of-Service) 공격을 한 사례가 있다. 미국 보안업체 프루트포인트에 따르면 2013년 12월 말부터 2014년 1월 초까지 발송된 악성 스팸메일 75만 건 가운데 25%가 통신 기능이 있는 TV와 냉장고 등 IoT 가전제품에서 발송된 것으로 확인되었다. 이처럼 일상생활에서 사용되는 가전기기들이 해킹당하여 공격에 악용되는 사례는 지속해서 증가할 것이다. 따라서 안전하고 신뢰할 수 있으며 안전한 IoT 환경을 제공하기 위해서는 IoT 장치, 시스템 및 서비스를 보호하는 것이 가장 중요하다.

본 연구는 IoT 환경의 보안을 강화하기 위해 새롭고 진보된 사이버보안 기술들을 설계하고 개발하는 것을 목표로 한다. 제안된 연구는 수학적 보안 모델과 보안·경제 지표(metric)를 이용하여 IoT 환경의 자동화된 보안 평가 프레임워크 및 도구를 개발하고, 외부 위협을 탐지, 대응, 예방하기 위해서 인공지능 기반의 침입탐지·대응 방지 기술을 개발하고 IoT 환경에 적용한다. 보안사고가 발생하기 이전에 징후를 사전에 포착하여 대응할 수 있도록 보안사고 예측 기술을 개발하며, IoT 서비스 사용자들에게 편의성이 높은 보안 기술(usable security)을 개발한다.

1) 자동화된 보안 평가 프레임워크

IoT 환경에 적합한 보안 모델과 측정방법, 측정 지표, 평가 방법을 통합한 새로운 IoT 환경에 적합한 자동화된 보안 평가 프레임워크를 개발한다.

2) 침입탐지 및 대응 기술

시그니처 기반 및 이상징후 기반 침입탐지 시스템과 최신 기계학습, 딥러닝 기술을 이용한 새로운 침입탐지 기술을 개발하고, 위협에 대한 자동화된 대응 방법을 개발하여 제시한다.

3) 보안사고 예측 기술

IoT 장치들의 전기 신호 데이터를 이용해 신호처리 및 고급 통계 추론 기법을 통해 사이버 공격을 조기에 예측하는 기술을 개발한다.

4) Usable Security

IoT 환경을 위해 개발된 보안 기술들의 편의성을 평가하기 위해 편의성 측정 지표들을 개발한다. 침입탐지 및 보안사고 예측의 결과는 자동화된 보안 평가의 데이터로 활용된다. 자동화된 보안 평가의 결과는 최적의 침입 대응 및 예방책을 도출하는데 사용된다. 침입탐지 및 보안사고 예측 시스템은 편의성 평가 프레임워크를 통해 테스트 및 평가를 수행한다.

2. 연구개발과제의 수행 과정 및 수행 내용

1) 1차년도 연구 내용

1차년도에는 사이버보안 평가 프레임워크 세부에서는 사이버보안을 위한 자동화된 보안 평가 그래픽 모델을 개발하였으며, IoT 장치들의 효율적인 보안 평가 방법을 연구하였다. 침입탐지 및

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

대응 기술 세부에서는 자율주행 차량의 위협 모델링을 통해 잠재된 위협을 도출하였으며, 공격 패턴 공유를 위한 인프라스트럭처를 설계하고 개발하였다. 보안사고 예측 기술 세부에서는 효율적인 전기 신호 수집 기술과 노이즈가 많은 환경에서 전기 신호의 탐지 및 추출 기술을 개발하였다. usable security 세부에서는 일반 사용자에게 발생할 수 있는 위협 모델을 개발하였으며, IoT 환경에서의 보안 어플리케이션을 개발하였다.

가) 그래픽 보안 모델 및 효율적 평가 방법 개발

deception 기술과 패치를 이용한 IoT 네트워크 보안 메커니즘 및 평가 지표 개발을 위해 deception 기술과 패치를 제시하고, 최적으로 deception 노드들을 deployment 하는 프레임워크를 개발하였다. 그리고 개발된 기술의 평가를 위해 세가지 매트릭스를 개발하였다.

나) 자율주행 차량의 위협 모델링 및 공격 패턴 공유를 위한 인프라스트럭처 개발

자율주행차량 환경 분석과 취약점 및 위협 분석을 위해 차량 센서모듈, 통신모듈, 전자제어장치 등 취약점 발생 요소를 식별하고 이를 이용한 공격 시나리오를 도출하였다.

다) 노이즈 멀티미디어에서 전기 신호 탐지 및 추출 기술 개발

다중채널의 전자파 상의 ENF 신호 추출 연구를 위해 IoT 센서로부터 나오는 ENF 신호를 추출해 이에 대한 source separation 기술을 적용하였다.

라) 일반 사용자를 위한 IoT 위협 모델 및 보안 어플리케이션 개발

사람의 음성과 재생된 음성의 차이를 구분하기 위해 음성 간 spectral power의 차이를 구별하는 알고리즘을 개발하기 위해 입력된 음성 신호를 퓨리엘 변환을 이용하여 cumulative spectral power density를 구하였으며, 변환된 신호에서 4개(low power frequency, signal power linearity degree, high power frequency feature, linear prediction cepstrum coefficients)의 분류 벡터를 추출하였다. low power frequency는 실제 사람과 녹음된 음성이 5kHz 밑의 주파수에서 차이가 명확하기 때문에 5kHz 이하의 세기에 대하여 <pow> 벡터를 추출하였으며, signal power linearity degree는 <pow> 벡터를 이용하여 linearity 정도를 측정할 수 있는 벡터를 추출하였으며 저성능의 스피커에서는 높은 linearity를 보였다. high power frequency feature는 <pow> 벡터와 일정 threshold에서의 peak 된 개수를 이용하여 높은 주파수에서 나타나는 특징을 구분하기 위한 벡터를 추출하였다. 그리고 linear prediction cepstrum coefficients는 스피커 인식이나 음성 부호화를 위해 사용되는 기술을 이용하여 만든 벡터이다. 추출된 4개의 feature 벡터들을 이용하여 다양한 기계학습 알고리즘을 실행하여 최적의 결과를 도출할 수 있는 알고리즘을 선정하였다.

2) 2차년도 연구 내용

2차년도에는 IoT 환경에 적합한 보안·성능·경제 지표 개발 세부에서는 IoT 환경에 적합한 보안 지표 및 성능·경제 지표를 개발하였으며, 차량내부 네트워크용 침입탐지 시스템 개발 세부에서는 시그니처 기반의 침입탐지 시스템과 이상징후 기반의 침입탐지 시스템을 개발하였고, 고품질 ENF 신호 추출 기살 개발 세부에서는 다중 ENF 신호의 고주파 특성을 추출하였고 결합하는 기술을 개발하였으며 신호 정렬 기술을 이용하여 중첩된 신호를 추출을 하였다. 그리고 사이버 보안 위협 탐지 및 경고 시스템 개발 세부에서는 사이버 보안 위협 탐지 시스템 및 사이버 보안 위협 경고 시스템을 개발하였다.

가) IoT 환경에 적합한 보안·성능·경제 지표 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

IoT 네트워크를 위한 보안 메커니즘의 효과를 검증하기 위한 시뮬레이션 네트워크를 구축하고 보안·성능·경제 지표로 실험을 진행하였다. 세부적으로는 IoT 네트워크에서 적용이 가능한 보안 메커니즘을 선정하고 그 보안 메커니즘이 사용될 대 경제적인 비용 대비 보안 및 성능의 향상을 평가하고 비교 연구를 수행하였다.

나) 차량 내부 네트워크용 침입탐지 시스템 개발

실제 테스트 차량을 제한된 환경에서 운행하며 OBD (On Board Diagnostics) 단자를 통해 자체 개발한 Raspberry Pi 기반의 CAN Interface 장치를 이용하여 4가지 유형(DoS, Fuzzing, RPM Spoofing, Gear Spoofing)의 메시지 주입 공격을 수행하고, CAN Traffic을 수집함으로써 차량 내부 네트워크인 CAN (Controller Area Network) 환경에서의 공격 데이터셋 구축하였다. 수집된 CAN Traffic 분석을 통해 CAN ID 별 메시지 전송 주기 및 특성을 파악하고, 이를 이용한 Rule 기반의 경량화된 침입탐지 시스템 개발함으로써 CAN 메시지의 주기적 특성을 이용한 Inter-Arrival Time 분석 기반의 침입탐지 시스템 개발하였으며, CAN 프로토콜의 주기적 특성으로 인하여 CAN Traffic에서 나타나는 CAN ID 시퀀스의 규칙성을 이용하여 정상 상태의 CAN ID 시퀀스와 공격이 발생한 경우의 CAN ID 시퀀스의 패턴의 차이를 딥러닝 모델에 학습시켜 높은 정확도의 CAN Traffic의 ID 시퀀스 패턴을 이용한 딥러닝 기반의 침입탐지 시스템을 개발하였다.

다) 고품질 ENF 신호 추출 기술 개발

ENF 신호추출에서 기존 FFT를 사용 시에 부채널 특징을 이용하므로 신호가 사라지거나 엉뚱한 위치에 가는 현상들이 존재하므로 이러한 잡음 및 이상 현상을 최소화하기 위해서 Sinusoidal Peak interpolation 기법의 하나인 Quadratically Interpolated FFT (QIFFT)를 이용함으로써 잡음과 다양한 외부현상으로 사라지거나 왜곡된 ENF 신호들을 복원하였다. 또한, QIFFT를 통해 보정된 Spectrum을 얻은 후에 60Hz 부근에 있는 peak들을 뽑아내어 ENF 추출 후 다양한 기계학습을 이용하여 예측 및 이상 신호 탐지에 적용하였다. 특히, AMRA, CKR을 이용하여 h-ahead prediction을 거쳐서 임의의 Confidence interval 내에 예측값이 존재하는지를 비교함으로써 ENF 신호가 시간에 따라 안정적으로 추출되는지 탐지하였다.

라) 사이버 보안 위협 탐지 및 경고 시스템 개발

IoT 기기에서 주로 사용되는 운영체제인 Chibi OS의 사용자 영역의 데이터 흐름을 도식화하고 위협 모델링을 위해 사용자 영역의 위협 정보를 획득하였으며, 모델링 프로세스에 따라 도출된 위협들의 취약성 점수를 측정하였다.(OWASP 위협 평가) 그리고 IoT 기기에 도출된 위협을 효과적으로 탐지하는 딥러닝 및 머신러닝 기반 시스템을 개발하기 위해 연산 된 점수들을 실제 IoT 기기를 사용한 시나리오를 통해 OneClass SVM과 N-gram Markov chain을 활용한 위협 탐지 시스템에 적용하였다. 정의된 위협들을 탐지한 후 탐지된 위협의 사용자 친화적인 경고 메시지 연구하기 위해 종래의 인증 기법의 근본적인 문제점을 해결하기 위해 사용성 측면에서 분석하고 이를 기반으로 사용성을 향상할 수 있는 인증 기법에 대한 요구사항 도출하였으며, 기존 경고 메시지들의 장점들을 활용한 새로운 경고 메시지 및 전달 방식을 도출하고자 경고 시스템은 탐지 위의 탐지 시스템에서 정의된 위협 및 사용자 상황 정보를 토대로 경고를 GUI로 제공하였다.

3) 3차년도 연구 내용

3차년도에는 보안 평가 모델 개발 세부에서는 기업 네트워크로부터 네트워크 설정 정보, 취약점 정보를 수집하고 자동으로 그래픽 보안 모델을 생성 및 분석하여 기법 네트워크의 보안 수준을 평가하는 safelite 라는 보안 평가 도구를 개발하였으며, 침입탐지 및 대응기술 모델 세부에서는

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

기계학습 및 딥러닝 기술을 적용하여 self-learning 침입방지 기술과 침입방지 시스템을 이용한 대응책을 제시하였다. 보안사고 예측 기술 세부에서는 ENF 신호를 이용한 보안 사고 예측 시스템을 개발하였으며, usable security 기술 세부에서는 사용자의 보안 요구사항을 반영한 보안 규칙을 정의하고 사용자의 행위와 만족도를 평가하기 위한 지표를 개발하였다.

가) 보안 평가 모델 개발

IoT 장치들의 이종성과 유동성을 고려한 보안 평가 모델 및 효율적 평가 방안을 연구하기 위해서 자동화된 보안평가 도구를 개발하였으며,
효율적인 평가 방안을 연구하여 자동화된 보안평가 도구 테스트를 실시하였다.

나) 침입탐지 및 대응기술 모델 개발

최신 기계학습 기법을 이용한 self-learning 침입탐지 기술을 개발하고 침입을 방지하기 위한 기술을 개발하였다.

다) 보안사고 예측 기술

ENF 신호와 보안사고의 연관성을 분석하여 보안사고 예측 가능성을 분석하고 ENF 신호를 이용한 예측 시스템을 개발하였다.

라) usable security 기술

사용자 보안 요구사항으로부터 보안규칙을 도출하고 IoT 장치의 보안 정책을 손쉽게 관리하도록 하는 기술 및 보안 어플리케이션의 편의성 평가 지표를 개발하였다.

3. 연구개발과제의 수행 결과 및 목표 달성 정도

1) 정성적 연구수행 결과

가) 1차년도 연구수행 결과

(1) 그래픽 보안 모델 및 효율적 평가 방법 개발

IoT 네트워크를 보호하기 위한 보안 메커니즘으로 deception 기술과 패치를 제시하고, 최적으로 deception 노드들을 deployment하는 프레임워크 및 평가 지표로 Decoy Nodes Fraction (DNF), Node Interaction Probability (NIP), Fraction of Residual Cost (RCF)를 개발하였다. 세부적으로 Decoy Nodes Fraction (DNF)는 Decoy target으로 향하는 공격 경로상에 위치하는 모든 노드 중에서 decoy 노드들의 비율을 의미하며, Node Interaction Probability (NIP)는 공격자가 주어진 공격 경로 상에 있는 노드들과 상호작용하여 decoy target에 도달할 평균 확률을 의미한다. Fraction of Residual Cost (RCF)는 총 비용에서 deployment와 관련된 비용을 제한 후 남은 비용의 양을 의미한다. 그리고 각 시간별로 수집한 IoT 네트워크의 정보를 바탕으로 시간별 그래픽 모델을 생성하고, 그 모델들과 보안 지표들을 사용하여 IoT 노드의 이동성이 보안에 어떤 영향을 미치는지에 대해서 연구하였다. 이동성 모델은 Gauss-Markov, Random Waypoint, Reference group 모델을 이동성 모델로 사용하였으며, risk, impact, cost, return on attack을 보안 지표로 사용하였으며, 보안에 미치는 영향 평가를 위한 지표는 variation과 attack variation을 측정하였다.

(2) 자율주행 차량의 위협 모델링 및 공격 패턴 공유를 위한 인프라스트럭처 개발

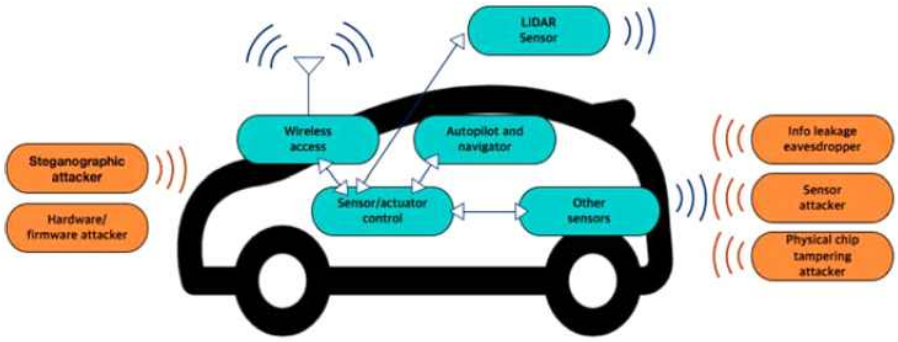
다중 채널 신호의 특징으로 인해 발생하는 노이즈들을 제거하고 하나의 소스로부터 여러 채널을

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

찾아내기 위해서 source separation기술을 적용가능한지에 대한 연구를 진행하였다.

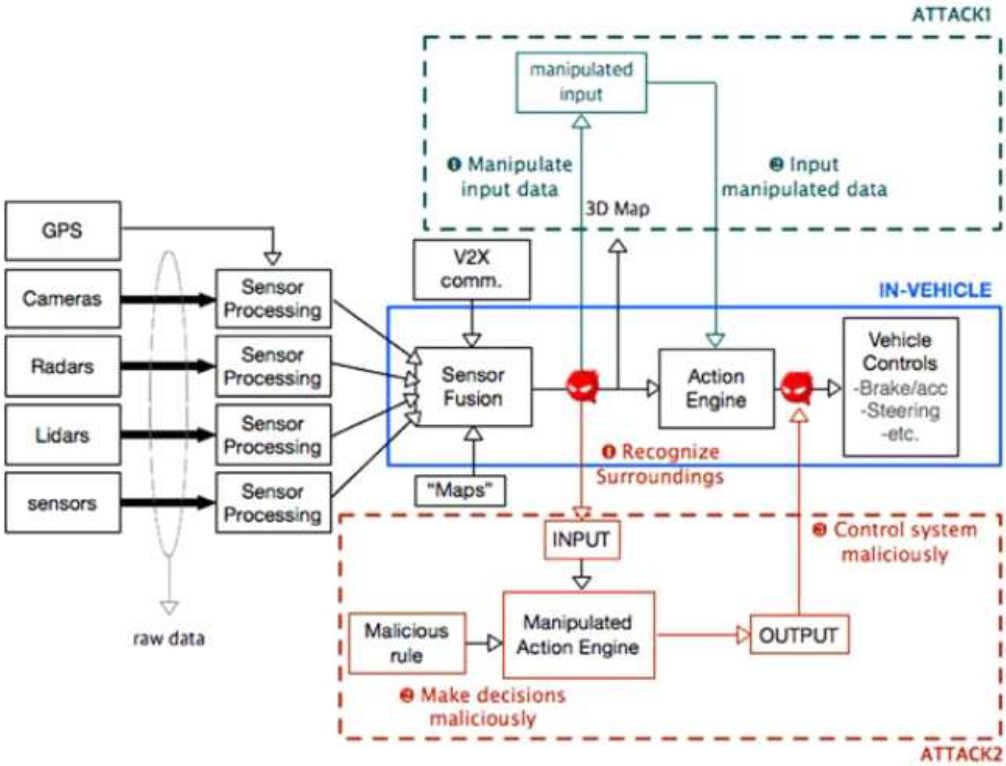
(3) 노이즈 멀티미디어에서 전기 신호 탐지 및 추출 기술 개발

차량에 탑재되는 센서 모듈, 무선통신 모듈, 전자제어장치 등에는 다양한 취약점이 존재할 수 있기 때문에 자율주행 차량에서 발생할 수 있는 잠재적 취약점을 식별하기 위한 연구를 진행하였다.



[그림 1] 자율주행 차량에서 발생할 수 있는 잠재적 취약점

Action Engine의 입력 데이터를 변조를 통해 자율주행 차량의 In-Vehicle 공격을 수행함으로써 Action Engine이 잘못된 결정을 내리도록 만들어 사고를 유도할 수 있기 때문에 자율주행 자동차와 가상 시스템에 대한 공격 시나리오를 도출하였다.

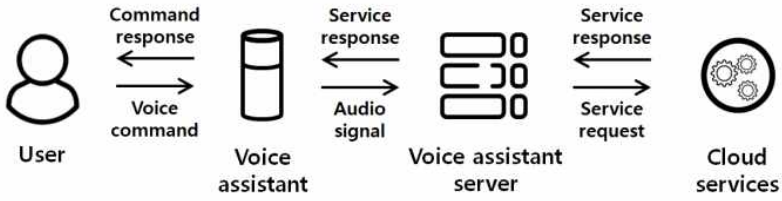


[그림 2] 자율주행 자동차와 가상 시스템에 대한 공격 시나리오

(4) 노이즈 멀티미디어에서 전기 신호 탐지 및 추출 기술 개발

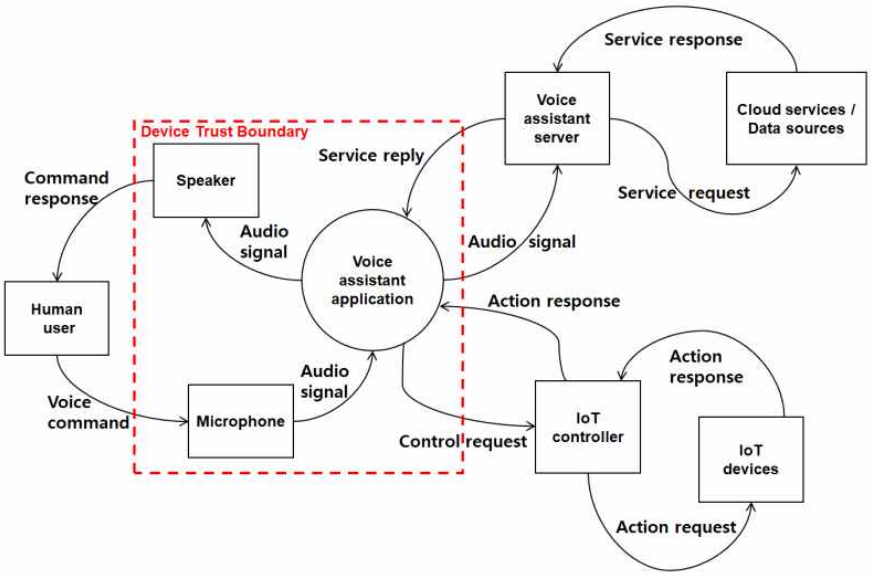
Voice assistant 시스템의 일반적인 아키텍처는 [그림 3] 과 같으며, IoT 위협 모델링을 위해 voice assistant 시스템을 분석하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 3] voice assistance 시스템의 일반적인 아키텍처

보안 위협 모델링을 위해 많이 사용되는 SDL 위협 모델링 도구를 이용하여 아키텍처를 기반으로 voice assistant 시스템의 data flow diagram을 그리고 이를 기반으로 동작 방법을 설명하였다. Data flow에서 발생 가능한 보안 위협들을 STRIDE를 기반으로 분석을 진행하였다.



[그림 4] voice assistance 시스템의 일반적인 아키텍처

Data flow diagram을 기반으로 voice assistant 시스템에서 발생 가능한 위협들을 STRIDE 방법을 이용하여 확인하였으며, DREAD 모델을 이용하여 확인된 위협들에 대한 위험성을 평가하였다 분석결과는 [표 1]과 같다. 그리고 STRIDE를 기반으로 분석한 위협들에 대한 위험성을 평가하기 위해 DREAD 모델을 이용하여 [그림 5]에서와 같은 평가를 진행하였다.

Data flow	Threat	D	R	E	A	D	Average
Voice command	Spoofing on `Microphone`	10	10	10	10	10	**10**
	Tampering with voice command	10	0	0	10	0	**4**
	DoS to `Microphone`	0	10	0	10	0	**4**
Audio signal	Spoofing on `Voice assistant server`	0	0	10	5	0	**3**
Service reply	Tampering with service reply	10	10	10	10	5	**9**
	Information disclosure of service reply	10	10	10	10	0	**8**
	DoS to `Voice assistant app`	0	10	5	10	10	**7**
	Elevation of privilege into `Voice assistant app`	10	10	0	10	0	**6**
Control request	Spoofing on `IoT controller`	10	10	5	10	0	**7**
	Tampering with control request	10	10	5	10	10	**9**
Action response	Spoofing on `IoT controller`	0	10	5	10	10	**7**
	Tampering with action response	0	10	0	10	10	**6**
	Information disclosure of action response	10	10	5	5	0	**6**
	DoS to `Voice assistant app`	0	10	10	10	10	**10**
	Elevation of privilege into `Voice assistant app`	10	0	0	0	0	**2**
Command response	Information disclosure of command response	0	10	10	10	0	**6**

[그림 5] DREAD 분석내용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[표 1] voice assistance 시스템 분석결과

구 분	위 협	세 부 내 용
Voice command to Microphone	spoofing	voice assistant 사용자가 마이크로폰을 통해 'voice command'를 입력할 때 공격자에 의해 spoofing 공격이 발생할 수 있음
	tampering	공격자에 의해 'voice command'가 공격자에 의해 변조될 수 있음
	denial of service	공격자가 악의적인 'voice command'를 재생하여 microphone에 대한 Denial of Service (DoS) 공격이 발생할 수 있음
Audio signal to voice assistant server	spoofing	voice assistant 시스템에서 voice assistant server로 송신되는 'audio signal'에 대한 spoofing 공격이 발생할 수 있음
Service reply to voice assistant app	Tampering	공격자에 의해 'service reply'가 공격자에 의해 변조될 수 있음
	Information Disclosure	voice assistant server에서 응답되는 'service reply'가 공격자의 스니핑 공격으로 인해 정보가 유출될 수 있음
	Denial of Service	공격자가 악의적인 'voice command'를 재생하여 microphone에 대한 Denial of Service (DoS) 공격이 발생할 수 있음
	Elevation of Privilege	악의적인 'service reply'를 생성하여 voice assistant 시스템에 대한 권한상승 공격이 발생할 수 있음
Control request to IoT controller	Spoofing	voice assistant 시스템에서 연결된 IoT 기기들에 대한 'control request'에 대한 spoofing 공격이 발생할 수 있음
	Tampering	공격자에 의해 'control request'가 공격자에 의해 변조될 수 있음
Action response to Voice assistant app	Spoofing	IoT 기기에서 voice assistant 시스템으로 응답하는 'action response'에 대한 spoofing 공격이 발생할 수 있음
	Tampering	공격자에 의해 'action response'가 공격자에 의해 변조될 수 있음
	Information Disclosure	IoT 기기에서 응답되는 'action response'가 공격자의 스니핑 공격으로 인해 정보가 유출될 수 있음
	Denial of Service	공격자가 악의적인 'action response'를 생성하여 voice assistant 시스템에 대한 DoS 공격이 발생할 수 있음
	Elevation of Privilege	악의적인 'action response'를 생성하여 voice assistant 시스템에 대한 권한상승 공격이 발생할 수 있음
Command response to human user	Information Disclosure	voice assistant 시스템으로부터 응답되는 'command response'에 대한 스니핑 공격으로 인해 정보가 유출될 수 있음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(5) 일반 사용자를 위한 IoT 위협 모델 및 보안 어플리케이션 개발

120명의 참가자를 모집하여 한명 당 50개의 문장을 말하게 한 후 그 중 실험에 쓰일 적합한 10,209개의 데이터를 선별하였으며, 수집한 데이터를 다양한 스피커들로 재생하여 다양한 환경에서 녹음하였다. 그 중에서 실험에 적합한 255,173개의 데이터를 선별, 기계학습으로 AdaBoost, SVM RPF, Random forest, SVM linear 그리고 kNN을 사용했으며 검증을 위해 10-fold cross-validation 기술을 사용하였다.

	Training (sec.)	Testing (sec.)	EER (%)
AdaBoost	159.8	0.114	4.3
SVM RBF	4.4	0.002	4.8
Random forest	8.61	0.137	6.1
SVM linear	6.3	0.002	10.3
kNN	0.011	0.018	17.53

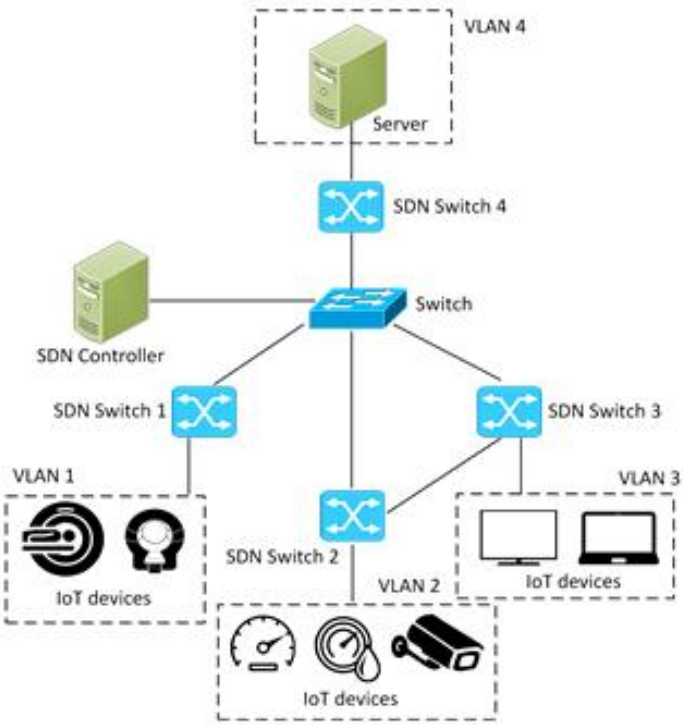
[그림 6] 실제 사용자 음성과 녹음된 음성을 구별

기계학습을 통해 실제 사용자 음성과 녹음된 음성을 구별한 결과는 [그림 6]과 같다. AdaBoost를 사용하였을 때, 가장 높은 정확성을 보였으나 하지만 SVM RBF의 경우 AdaBoost보다 0.5% 높은 EER을 보였지만, 훈련시간과 검증시간에서 AdaBoost보다 상당히 낮은 시간이 걸리는 것을 확인하였다.

나) 2차년도 연구수행 결과

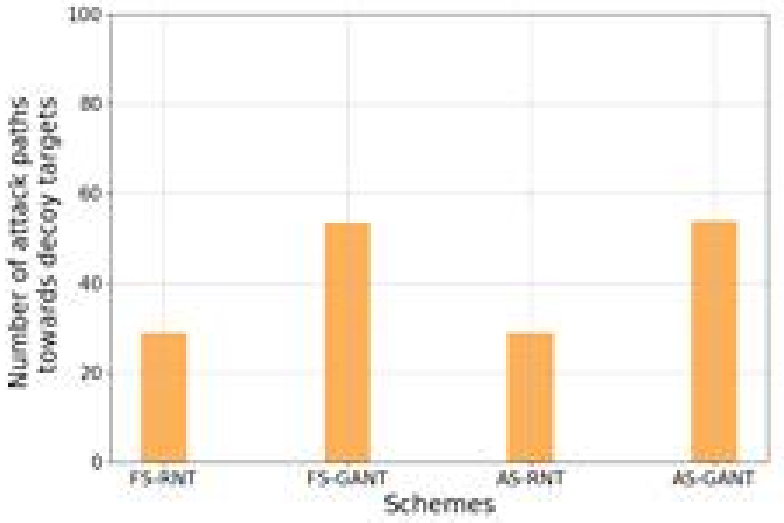
(1) 보안 메커니즘의 효과 검증하기 위한 시뮬레이션 네트워크 구축 및 보안·성능·경제 지표로 실험

IoT 네트워크의 보안 향상을 위한 보안 기술을 개발하였고, 개발된 보안 기술을 보안, 성능 및 경제지표를 이용하여 평가하였다.

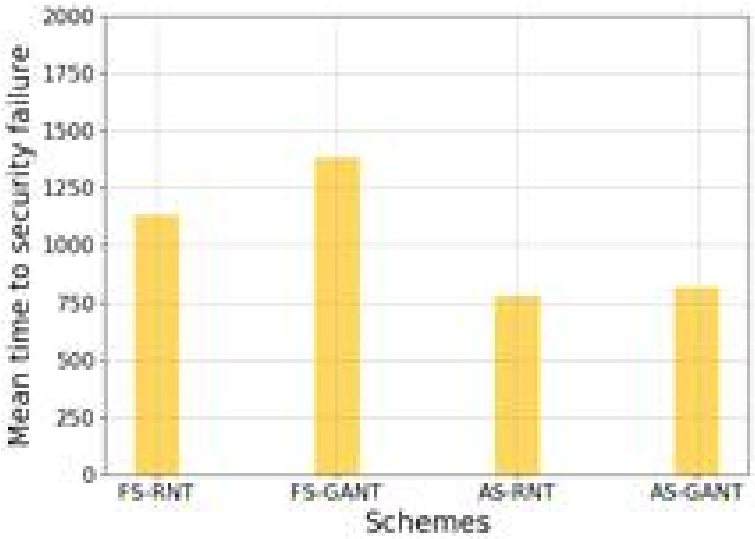


[그림 7] IoT 보안 평가를 위한 IoT network 예

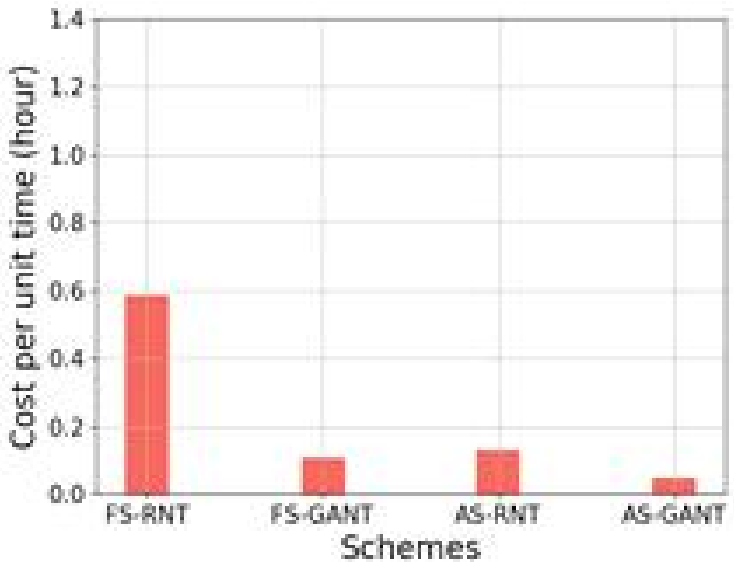
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 8] MTD 방법론에 따른 Decoy 노드를 향항 공격 경로



[그림 9] MTD 방법론에 따른 Mean Time to Security failure



[그림 10] MTD 방법론에 따른 평균 방어 비용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 차량 내부 네트워크인 CAN (Controller Area Network) 환경에서의 공격 데이터셋 구축

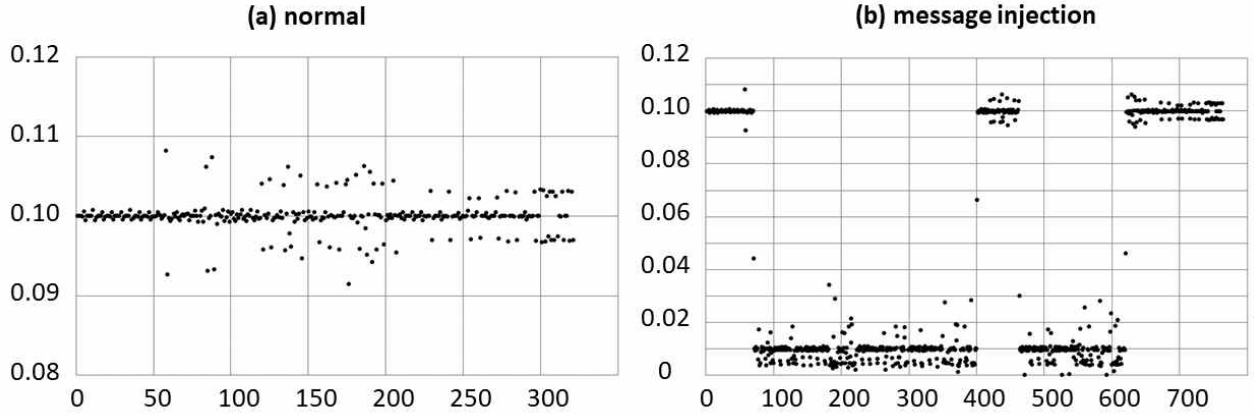
실제 테스트 차량을 제한된 환경에서 운행하며 OBD-II 단자를 통해 자체 개발한 Raspberry Pi 기반의 CAN Interface 장치를 이용하여 4가지 유형(DoS, Fuzzing, RPM Spoofing, Gear Spoofing)의 메시지 주입 공격을 수행하고, CAN Traffic을 수집하였다.

[표 2] Car Hacking 데이터셋 개요

Attack Type	# of messages	# of normal messages	# of injected messages
DoS	3,665,771	3,078,250	587,521
Fuzzing	3,838,860	3,347,013	491,847
Spoofing drive gear	4,443,142	3,845,890	597,252
Spoofing RPM gauze	4,621,702	3,966,805	654,897
Attack-free (normal)	988,987	988,872	-

(3) CAN 메시지의 주기적 특성을 이용한 Inter-Arrival Time 분석 기반의 침입탐지 시스템 개발

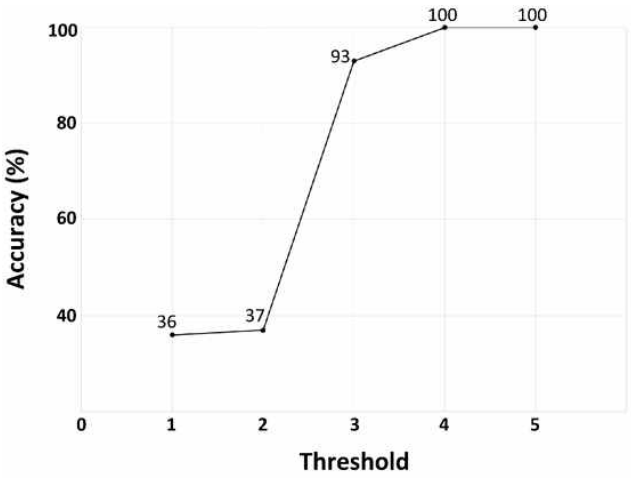
수집된 CAN Traffic 분석을 통해 CAN ID 별 메시지 전송 주기 및 특성을 파악하고, 이를 이용한 Rule 기반의 경량화된 침입탐지 시스템 개발하였다.



[그림 11] CAN 메시지의 Inter-Arrival Time 분포도

실험결과, 정상 상태 차량에서 CAN 메시지의 Inter-Arrival Time의 오차범위는 약 10% 이내이지만, 공격이 발생하는 경우 정상 범위를 크게 벗어나는 특징이 있었으며 메시지 주입 공격 시, 메시지 주입 속도를 정상 메시지의 Inter-Arrival Time의 2배, 5배, 10배로 변경하며 탐지 성능을 측정한 결과 공격 탐지 Threshold 값을 4 이상으로 주었을 때, 메시지 주입 공격 발생 여부를 100% 정확도로 탐지할 수 있었다.

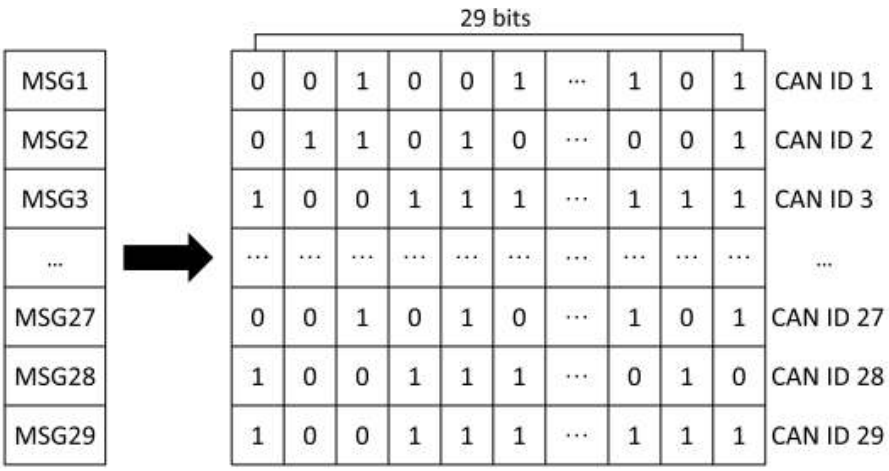
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 12] 임곗값에 따른 공격 탐지 정확도

(4) CAN Traffic의 ID 시퀀스 패턴을 이용한 딥러닝 기반의 침입탐지 시스템 개발

CAN 프로토콜의 주기적 특성으로 인하여 CAN Traffic에서 나타나는 CAN ID 시퀀스의 규칙성을 이용하여 정상 상태의 CAN ID 시퀀스와 공격이 발생한 경우의 CAN ID 시퀀스의 패턴의 차이를 딥러닝 모델에 학습시켜 높은 정확도의 침입탐지 시스템 개발하였다.



[그림 13] CAN ID 시퀀스 변환

이를 위해 CAN ID 시퀀스를 2-D Matrix 데이터로 표현하기 위하여 CAN ID를 bit 단위로 표현하여 Matrix 데이터로 변환하는 Frame Builder라는 전처리 모듈을 제안하였으며, 4가지 유형의 메시지 주입 공격에 대하여 모델 생성 및 성능 테스트 결과 0.1 % 이하의 FNR (False Negative Ratio)와 0.18 % 이하의 ER (Error Rate)를 보였다.

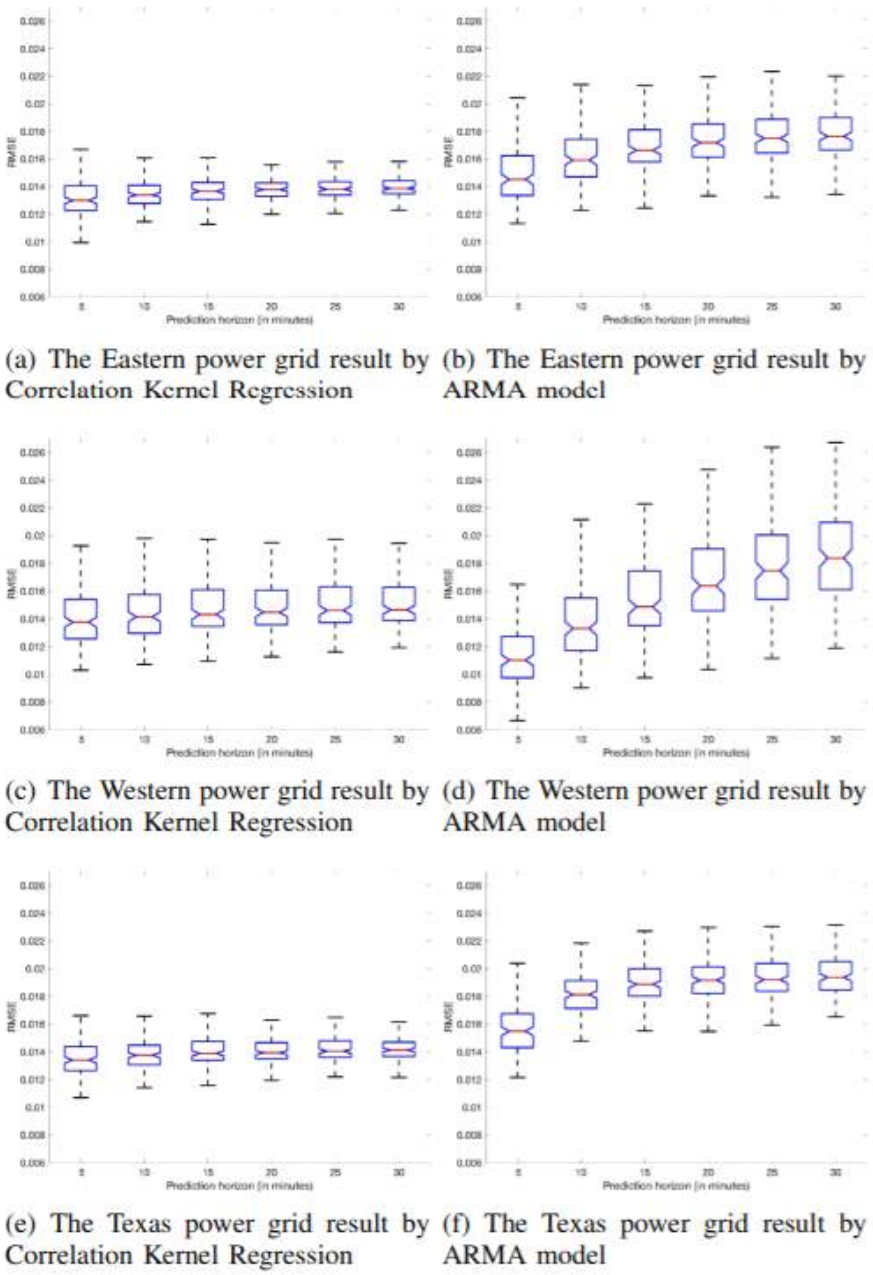
Dataset (%)	DoS		Gear		RPM		Fuzzy	
	FNR	ER	FNR	ER	FNR	ER	FNR	ER
mean	0.13	0.04	0.12	0.09	0.11	0.06	0.50	0.28
std	0.02	0.01	0.04	0.05	0.04	0.02	0.24	0.07
min	**0.10**	**0.03**	**0.06**	**0.05**	**0.07**	**0.04**	**0.24**	**0.18**
25%	0.11	0.04	0.10	0.06	0.09	0.04	0.28	0.24
50%	0.13	0.04	0.11	0.07	0.10	0.05	0.49	0.27
75%	0.14	0.05	0.14	0.08	0.12	0.07	0.60	0.33
max	0.17	0.05	0.20	0.22	0.20	0.09	0.97	0.43

[그림 14] 공격 탐지 실험 결과

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(5) 시계열별 ENF 신호를 추출 후 h-ahead prediction을 직접 미국의 power grid 상에 수행

해당 연구를 미국 power grid 상에 ENF 신호 안정성 예측연구를 진행하여 아래와 같은 결과를 얻어냈다.



(a) The Eastern power grid result by Correlation Kernel Regression

(b) The Eastern power grid result by ARMA model

(c) The Western power grid result by Correlation Kernel Regression

(d) The Western power grid result by ARMA model

(e) The Texas power grid result by Correlation Kernel Regression

(f) The Texas power grid result by ARMA model

[그림 15] ENF 신호 안정성 예측 실험결과

위 그림들은 각 예측모델에 따른 RMSE 값을 나타내고 있으며 현재 미국 Power grid 상에 이상치가 없어서 h 값에 따른 예측의 안정성까지만 볼 수 있었다.

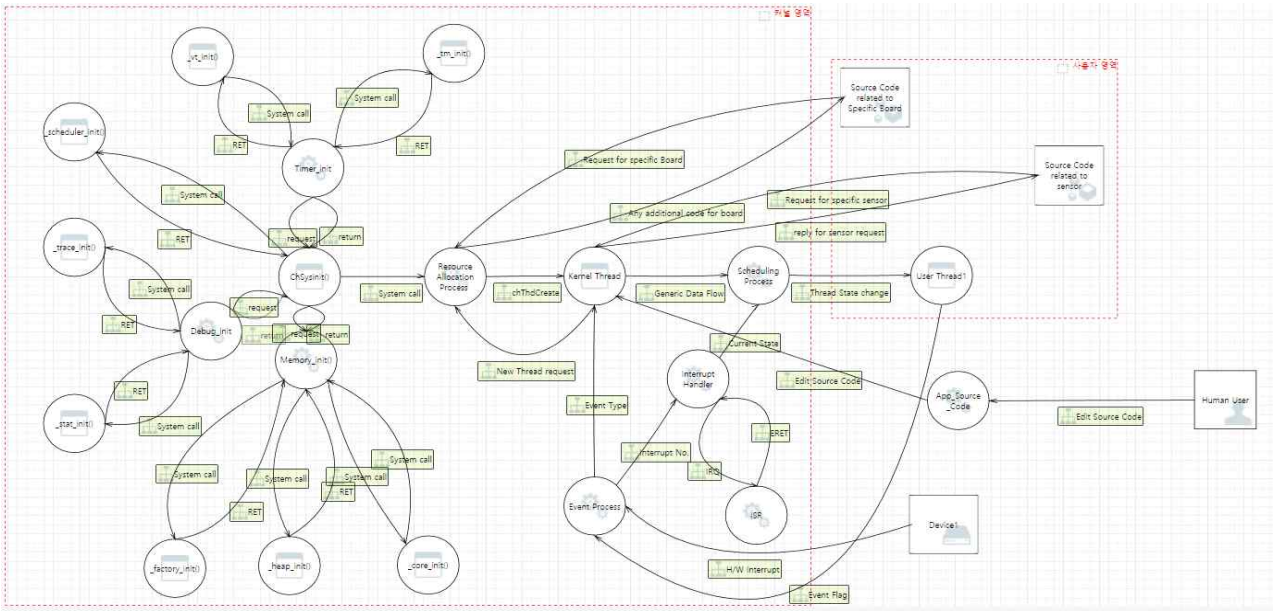
(6) 기존의 FFT 기술보다 향상된 기술인 QIFFT를 연구하여 더욱 양질의 신호추출 가능

기존에는 ENF 신호추출을 하기 위해서 Short Time Fourier Transform (STFT)를 사용하고 있으나, 해당 신호의 소스가 IoT 기기나 멀티미디어 데이터들의 부채널 신호이므로 원치 않은 잡음과 이상 현상 때문에 시간변이에 따라 ENF 신호들이 많은 튕김 현상과 잡음에 의한 왜곡 현상이 존재하였다. 이를 보완하기 위해서 시간별 Frequency 값에 Interpolation 기법을 적용하였고 이를 통해 왜곡된 spectrum이 원래의 스펙트럼에 더욱 가까워지는 복원 효과를 얻을 수 있었다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(7) IoT 기기의 사용자 데이터 흐름의 도식화 및 IoT 기기에 발생할 수 있는 위협 도출

마이크로소프트에서 제공하는 위협 모델링 도구를 이용하여 IoT 기기에서 운영체제로 주로 사용되는 Chibi OS에 대한 위협 모델링을 진행하였고 특히 User_app_source 함수에 대하여 OWASP 위협 평가하였다. OWASP 위협 평가는 likelihood factor들과 impact factor들에 항목들의 점수 평균으로 계산하며, 각 factor는 취약점의 강도와 취약점이 공개되었을 때, 시스템과 회사가 입을 수 있는 경제적 및 기술적 타격에 대해서 수치화하여 연산하였다.



[그림 16] IoT 기기의 사용자 영역 도식화

사용자 영역의 위협 정보 획득이 가능하며 이를 토대로 위협 모델링 진행하였고, 위협 모델링을 통해 도출된 위협은 아래 표와 같다.

[표 3] 위협 모델링 결과

위 협	세 부 내 용
사용자 데이터 유출 및 훼손	외부 주체가 생성 또는 변경되는 데이터를 유출, 변경 또는 삭제
최소 권한	내부 설계 및 구현의 오류로 인하여 사용자 권한을 가진 애플리케이션에서 발생한 문제
우회 접근	내부 설계 혹은 구현의 오류로 인하여 보안 기능을 우회하여 접근
안전하지 않은 상태	잘못된 초기화 및 재시작 등으로 인한 IoT 기기의 상태가 불안정해짐
서비스 거부	정당한 객체의 시스템 자원 접근 및 사용을 제한함

(8) 도출된 위협이 사용자의 IoT 기기에 미치는 영향 수치화

모든 위협 정보가 실제 위협으로 나타나지 않기 때문에 위협 가능성이 가장 큰 부분인 User_app_source 함수의 Spoofing 공격을 중점으로 6.375점으로 점수를 산출하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[표 4] 취약점 평가 결과

평가 항목		Score
Likelihood Factors	Skill Level	6
	Motive	4
	Opportunity	4
	Size	6
	Ease of Discovery	3
	Ease of Exploit	4
	Awareness	3
	Intrusion Detection	3
Impact Factors	Loss of Confidentiality	6
	Loss of Integrity	5
	Loss of Availability	5
	Loss of Accountability	3
	Financial Damage	3
	Reputation Damage	1
	None-compliance	1
	Privacy Violation	4
Score		6.375

위처럼 도출된 위협과 산출 점수를 바탕으로 딥러닝 및 머신러닝 기반 위협 탐지 시스템을 개발하였다.

(9) IoT 기기에 도출된 위협을 효과적으로 탐지하는 시스템 개발

비인가 사용자가 사용자의 IoT 기기를 탈취하여 사용자 민감 정보에 접근 및 유출 시도하여 사용자의 비밀번호, 잠금 해제 패턴 등을 모방할 수 있으며, 사용자가 사용하는 애플리케이션 외의 정보유출 또는 복제를 위한 제3의 애플리케이션을 설치하여 사용 가능하다. 따라서, 이러한 공격 시나리오를 탐지하고 사용자에게 효과적으로 전달하기 위해 탐지 시스템 및 경고 시스템을 개발하였다. 앱 사용 패턴 분석 기술을 연구하여 각 사용자마다 사용한 app list를 생성하고 이를 bag-of-word에 활용하였다. 시간 순서에 따른 Training, Validation, Testing set을 분류하였으며 이때 Training set의 크기는 수집 데이터의 60%로 설정하였다. “unknown” tag를 추가하여 모델을 생성(모든 조건부 확률에 smoothing 기법 사용)하고 한 시퀀스에 “unknown” 태그가 두 개 이상 나타나면 (예: P(Unknown | A, Unknown)) 해당 시퀀스는 확률을 0으로 계산하였다. Validation set과 Testing set의 크기는 각각 수집 데이터의 20%로 설정하였다. 각 사용자별 최적의 EER을 갖는 threshold를 계산하고 Validation set으로 계산한 threshold를 이용하여 전체 모델의 성능을 평가하였다.

실험결과, app 시퀀스 길이 제한에 따른 성능의 경우 App 시퀀스가 길어질수록 부정확한 usage 패턴 증가하였으며 특정 길이로 제한하여 조건부 확률 계산 시 성능이 향상됨을 확인하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[표 5] 제한된 app 시퀀스 길이의 실험결과

3-gram	6.96% (median)
4-gram	4.00% (median)
5-gram	1.48% (median)
Best case of sequence	n-gram + 1

smoothing 기법을 적용했을 때에는 성능의 소폭 상승을 확인할 수 있었다.

[표 6] smoothing 기법 적용 후 실험결과

3-gram	6.56% (median)
4-gram	4.03% (median)
5-gram	1.41% (median)

Classification 결과를 토대로 사용자/비인가 사용자 구별하기 위해 미리 정의한 threshold와 비인가 사용자 탐지 결과의 score를 비교하였으며, 임계치보다 score가 작다면 비인가 사용자로 판단하여 경고 메시지를 통해 사용자에게 위협을 알리도록 하였다.

(10) 탐지된 위협의 사용자 친화적인 경고 메시지 연구, 기존 연구에서 언급하는 경고 메시지 분석, 기존 경고 메시지들의 장점들을 활용한 새로운 경고 메시지 및 전달 방식 도출

낮은 보안성이 경고 시스템에 어떠한 영향을 미치는가와 사용자 Context에 따라 만족해야 하는 protection level의 차이를 알아보기 위해 기존 연구를 분석한 결과, 27%의 피험자가 detection delay에 대한 우려가 있었고, 22% 피험자가 False Accept Rate에 대한 우려가 있었으며, 11% 피험자가 mimicry attack에 대한 우려를 보였다. 사용자에게 효과적으로 경고를 전달하기 위해 다양한 Pop-up 메시지 방식을 연구하고 개발에 고려한 경고 시스템 디자인들은 [그림 17]과 같다.



[그림 17] 메시지 시스템 디자인 1(a)과 디자인 2(b)

디자인 1([그림 17]-(a))의 경우, 사용자 이외에 비인가된 사용자라고 판단될 때 화면 잠김 및 꺼짐(스마트 폰의 화면 잠김과 동일)을 보이도록 하였다. 디자인 2([그림 17]-(b))는 input context

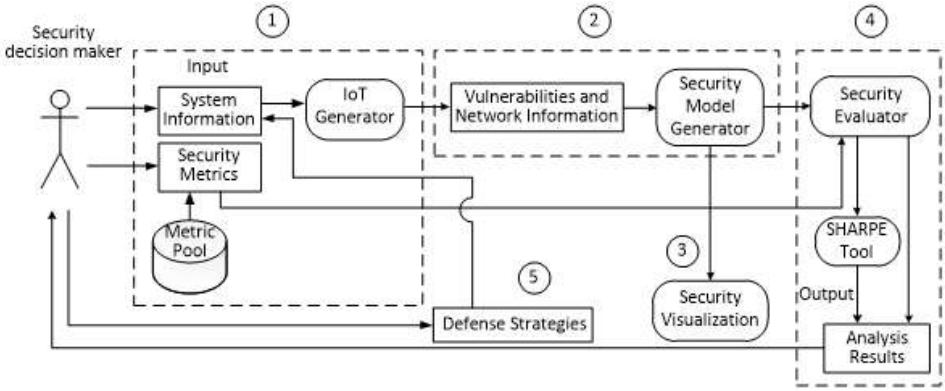
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

데이터에 관한 결과가 기존 사용자 데이터 기반 학습을 통해 계산된 임계치에 도달하지 못했을 때 화면 잠금을 하도록 하였다. 디자인 1과 차이는 Similarity 기반의 score를 통해 사용자가 아니라고 판단될 때 일차적으로 진동과 팝업 메시지로 경고하고 사용자의 행위가 지속할 경우 해당 score는 지속해서 줄어들어 특정 임계치에 도달하면 바로 화면이 잠기도록 하였다. 따라서 사용자의 기기가 바로 잠김으로 인해 도중에 작업이 중단되는 불편함이 해소하고자 하였다.

다) 3차년도 연구수행 결과

(1) 보안 평가 모델 개발

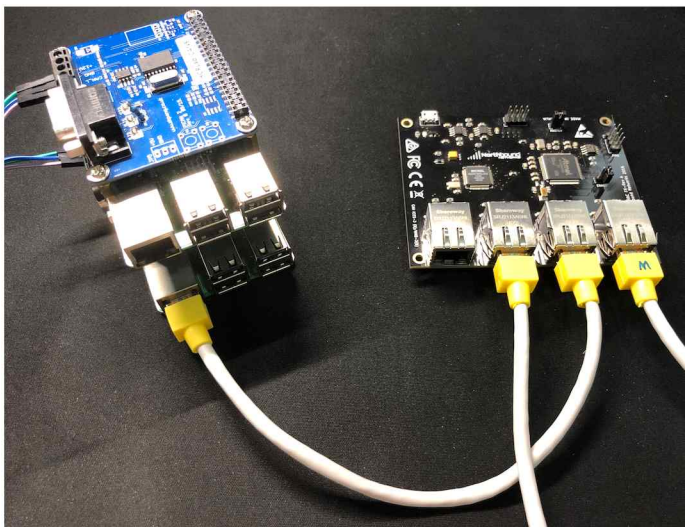
IoT 장치들의 이종성과 유동성을 고려한 보안 평가 모델 및 효율적인 평가 방안을 연구하였다.



[그림 18] 사이버보안 평가 프레임워크

(2) 보안기술 적용을 위한 테스트베드 구축

2대의 라즈베리파이와 1대의 SDN switch를 활용하여 테스트베드를 구현하였다. 라즈베리파이 1대에서는 실제 차량을 대신하는 역할로서 CAN 메시지를 발생하도록 하여, 미리 캡쳐한 데이터 셋을 재생하고 선을 통해 아래 라즈베리파이로 전달한다. 다른 라즈베리파이 1대에서는 CAN 메시지를 수신 받아 UDP packet을 Ethernet으로 전달하는 메시지 변환기의 역할을 수행한다. SDN switch는 OpenFlow를 지원하는 switch 역할을 한다.



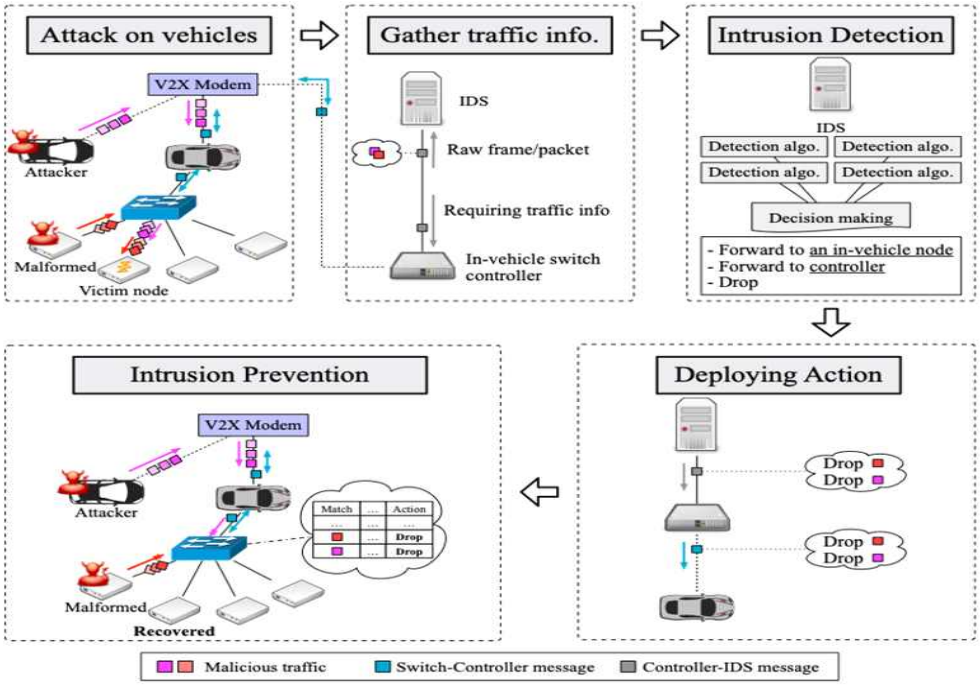
[그림 19] 사이버보안 평가 프레임워크

(3) 침입탐지 및 대응기술 모델 개발

구축된 테스트베드를 바탕으로 아래와 같은 침입탐지 및 대응기술 모델을 개발하였다. 정상/공격 CAN 메시지가 발생하면, CAN-to-ETH translator가 패킷을 SDN 스위치로 보내고 차량에서 발생되는 트래픽을 스위치에서 요약하여 해당 정보를 차량 밖의 침임 탐지 시스템에 보낸다. 침

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

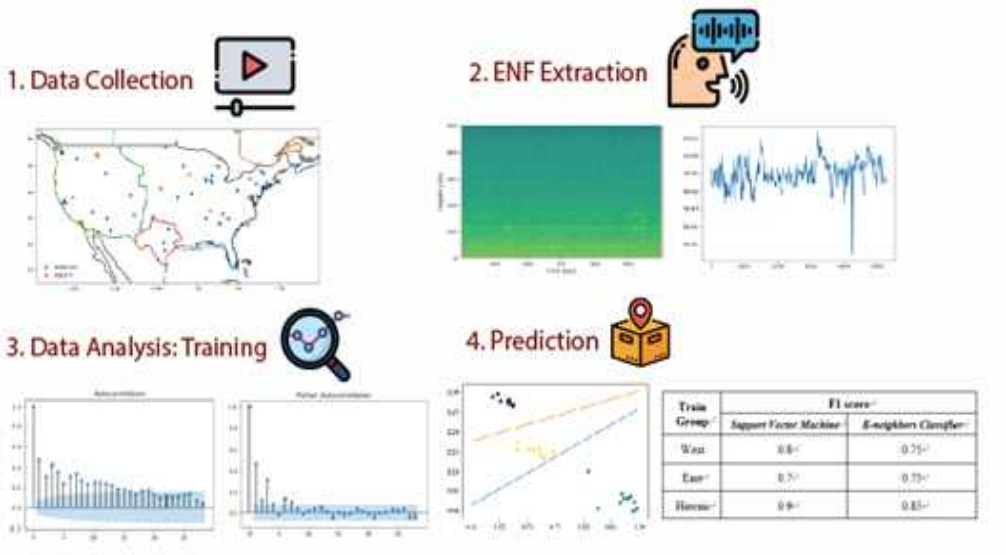
입이 식별된다면 그 결과를 차량에 보내고 해당하는 network flow를 차량에 탑재된 스위치 단에서 차단함으로써, 침입을 탐지할 뿐만 아니라 차량이 정상적으로 주행할 수 있도록 모델을 개발하였다.



[그림 20] 차량 IDS/IPS model의 전체 동작과정

(4) 보안사고 예측 기술

ENF 신호와 보안사고의 연관성을 분석하여 보안사고 예측 가능성을 분석하고, ENF 신호를 이용한 예측 시스템을 개발하였다.



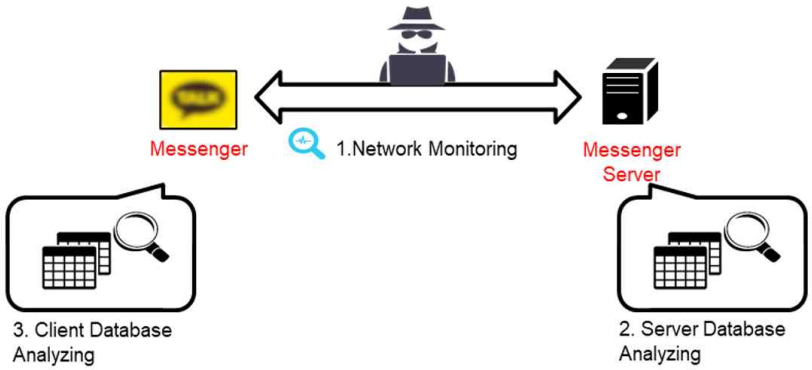
[그림 21] ENF 신호를 이용한 보안사고 예측 시스템 개발

해당 기술은 네트워크 주파수 신호가 나타나는 그리드를 찾으려고 할 때, 별도의 보간 과정 없이도 위치를 추적할 수 있는 방법이다. 온라인 멀티미디어 서비스의 스트리밍 비디오에서 네트워크 주파수 신호를 수집하고, 해당 신호에 2차 보간 FFT(QIFFT) 기법을 사용하여 ENF 신호를 추출한다. 그 후에, 추출된 신호를 일정한 크기로 그룹화하고 시계열 데이터 분석 기법인 ARIMA 모델을 통해 학습시킨다. 그리ᄂᆞ 학습된 결과에서 지역 ENF 데이터의 계수를 분석하여 각 지역별 특징을 나타내는 유의미한 값을 찾는다. 이 기술을 사용하면 높은 정확도로 주어진 온라인 파일이 재생되고 있는 위치를 예측 및 추적할 수 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(5) usable security 기술

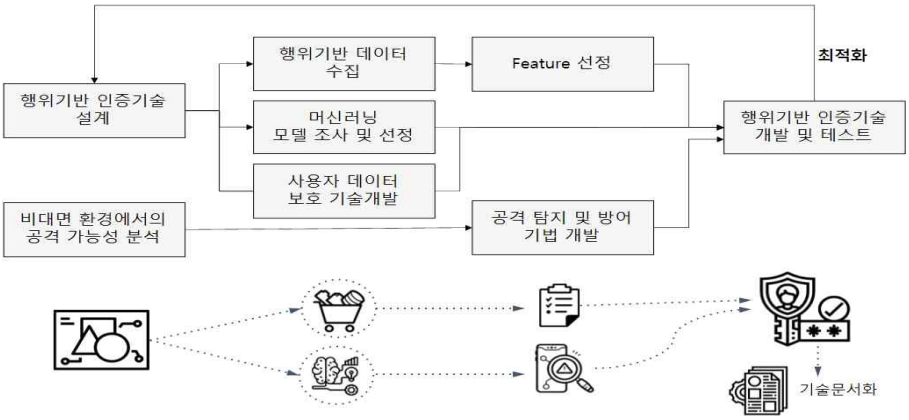
IoT 장치의 보안 정책을 손쉽게 관리하도록 하는 기술 및 보안 애플리케이션의 편의성 평가 지표를 개발하였다.



[그림 22] Instant messenger의 보안 취약점 분석 및 데이터 복구 방법

(6) 행위기반 사용자 인증기술 개발

행위기반 인증기술에 사용가능한 요소기술(예: touch dynamics, keystroke, app usage pattern 등)들을 조사하고 사용자 행위기반, Touch dynamics 기반, 어플리케이션 사용 패턴 기반 사용자 인증기술을 개발하였다. 해당 기술은 센서 데이터(가속도 센서, 터치 이벤트 등)와 사용자의 어플리케이션 사용 이력(history)을 feature로 추출 및 기록하고 머신러닝/딥러닝 기술을 이용하여 비인가된 사용자가 기기를 사용할 때 차단할 수 있는 기술이다.



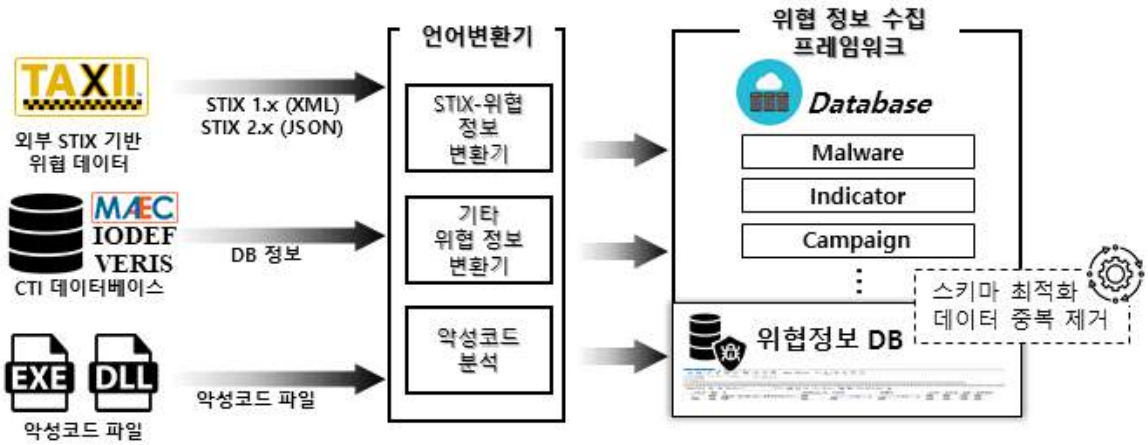
[그림 23] 사용자 친화형 인증 기술의 개발 내용 및 범위

또한, 사용자 생체 정보 보호를 위한 프라이버시 보존하기 위해 인증 시스템에서 사용되는 민감한 사용자 데이터(사용자 생체 정보)를 보호하기 위해 익명화하고 인증에 필요한 주요 특성만을 남기고, 원본 데이터는 삭제하는 비식별화 과정을 거쳐, 인증 정확도와 프라이버시를 동시에 보존하는 기술을 개발하였다.

(7) 사용자 데이터 기반 보안관리 프레임워크 개발

기존/신규 보안 위협 정보 수집 데이터베이스 구축을 위해 다양한 출처(Open TAXII server, AlienVault, VirusTotal, FireEye 등)에서 자동으로 보안 위협 정보를 수집하고 수집된 보안 위협 정보의 포맷을 하나로 통합 및 관리하는 보안 위협 정보 관리 프레임워크 개발하였다([그림 23] 참조). 해당 기술은 오픈소스 맬웨어 분석 시스템(예: Cuckoo sandbox)을 통한 정적/동적 결과로부터 의미 있는 보안 위협 정보를 추출하며, 데이터 중복 문제를 해결하기 위해 위협 정보의 중복 수집/저장 방지 알고리즘이 탑재되었다.

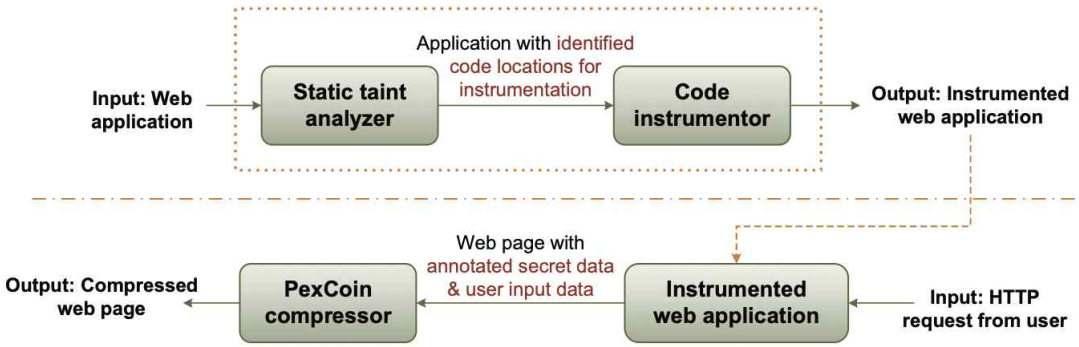
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 24] 위협정보 기반 보안관리 프레임워크

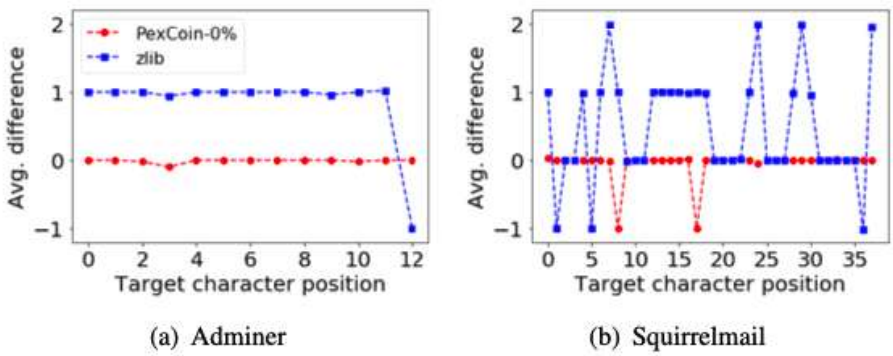
(8) HTTPS 부채널 공격인 BREACH에 대한 압축 효율성이 개선된 방어법 개발

HTTPS 부채널 공격인 BREACH에 대해 기존 연구 대비 압축률이 개선된 방어법을 개발하였다. BREACH 공격은 DEFLATE 압축 알고리즘으로 인해 발생하는 취약점이다. 입력값으로 웹 어플리케이션을 받아 사용자 입력값(user input data)과 기밀 데이터(secret data)에 주석(annotation) 표기를 하도록 웹 어플리케이션을 수정한다([그림 24] 참조).



[그림 25] PexCoin의 작업 흐름.

해당 기술(PexCoin)의 압축기는 웹 페이지에 표기된 주석 정보로부터 해당 데이터가 사용자 입력값이나 기밀 데이터인지를 확인할 수 있으며, 이를 기반으로 특정 규칙을 정의하여 DEFLATE 압축시 해당 데이터가 매칭되어 치환될 수 있는지 여부를 판단한다. 기밀 데이터 사이의 압축 허용 여부가 압축률 개선에 있어 중요하기 때문에 기밀 데이터 사이의 압축을 확률적으로 허용하는 압축 모델을 개발하였으며, 실제 부채널 공격을 수행해 봄으로써, 해당 기술의 부채널 공격으로부터 안전성을 제공함을 확인하였다([그림 25] 참조).

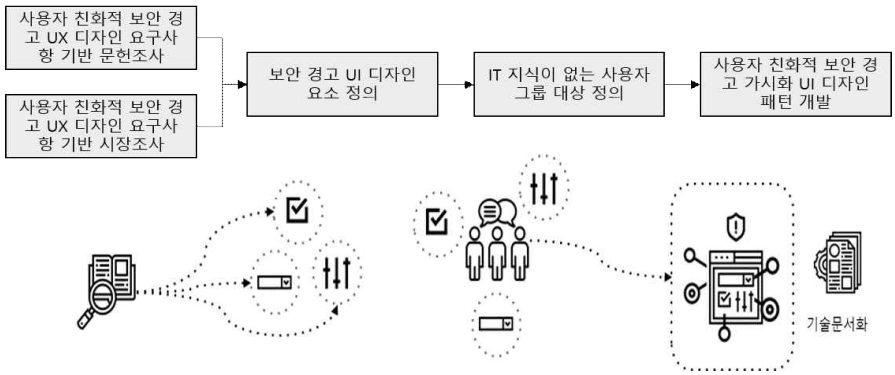


[그림 26] 부채널 정보 유출 평가.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(9) 사용자 보안 요구사항을 입력받는 UI를 개발

다양한 비대면 환경과 해당 환경에서 사용되는 기기별 잠재적 보안 및 프라이버시 이슈에 대한 선행 연구 수행을 위해 HCI 분야 및 보안, 프라이버시 분야 학술대회 및 학술지를 통하여 도메인별, 사용자 유형별 사용자 보안 및 프라이버시 위협 종류, 요구사항, 디자인 등의 사전연구를 진행하였다. 사전 연구를 토대로, IT 지식이 없는 사용자 요구사항을 기반으로 사용자 친화적 보안 경고 UI 디자인 요소를 정의하고, 사용자 보안 요구사항을 입력받는 UI를 개발하여 high level 사용자 보안 요구사항을 정립된 데이터 모델에 맞게 low level 보안 규칙으로 변환하는 방법을 개발하였다([그림 26] 참조).



[그림 27] 보안 경고 가시화 기술의 3차년도 개발 내용 및 범위

2) 정량적 연구수행 결과

(단위 : 건, 천원)

성과지표명 \ 연도			1차년도 (2018~2019)	2차년도 (2019~2020)	3차년도 (2020~2021)	계	가중치 (%)
전담기관 등록·기탁 지표	국외논문 (SCIE)	목표(단계별)	0	0	1	1	100
		실적(누적)	0	3	1	4	100
	국외논문 (비SCIE)	목표(단계별)	0	1	1	2	100
		실적(누적)	0	0	0	0	100
	국내논문	목표(단계별)	1	0	0	1	100
		실적(누적)	0	0	0	0	100
	학술대회	목표(단계별)	0	0	0	0	100
		실적(누적)	2	5	1	8	100
	특허출원 (국내)	목표(단계별)	0	1	1	2	100
		실적(누적)	0	0	0	0	100
	특허등록 (국내)	목표(단계별)	0	0	1	1	100
		실적(누적)	0	0	0	0	100
연구개발과제 특성 반영 지표	인력양성	목표(단계별)	2	2	2	6	100
		실적(누적)	0	1	1	2	100
	인력교류	목표(단계별)	0	0	0	0	100
		실적(누적)	1	2	0	3	100
계		목표(단계별)	3	4	6	13	100
		실적(누적)	3	11	3	17	100

3) 세부 정량적 연구개발성과

[과학적 성과]

□ 논문(국내외 전문 학술지) 게재

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

번호	논문명	학술지명	주저자명	호	국명	발행기관	SCIE 여부 (SCIE/비SCIE)	게재일	등록번호 (ISSN)	기여율
1	Digital forensic analysis of encrypted database files in instant messaging applications on Windows operating systems: Case study with KakaoTalk, NateOn and QQ messenger	Elsevier Digital Investigation	Jusop Choi	28	영국	Elsevier	SCIE	24-April-19	2666-2817	100%
2	Automated dataset generation system for collaborative research of cyber threat analysis	Hindawi Security and Communication Networks	Daegeon Kim	2019	영국	Hindawi	SCIE	30-Sep-19	1939-0114	100%
3	CBR-Based Decision Support Methodology for Cybercrime Investigation: Focused on the Data-Driven Website Defacement Analysis	Hindawi Security and Communication Networks	Mee Lan Han	2019	영국	Hindawi	SCIE	20-Dec-19	1939-0114	100%
4	Do Many Models Make Light Work? Evaluating Ensemble Solutions for Improved Rumor Detection	IEEE ACCESS	YOUNGH WAN KIM	8	미국	IEEE	SCIE	14-Aug-20	2169-3536	100%

□ 국내 및 국제 학술회의 발표

번호	회의 명칭	발표자	발표 일시	장 소	국 명
1	WISA 2018: The 19th world conference on information security applications	Sooyeon Lee	August 23-25, 2018	Jeju Island	대한민국
2	WISA 2018: The 19th world conference on information security applications	Geumhwan Cho	August 23-25, 2018	Jeju Island	대한민국
3	2019 Australasian Conference on Information Security and Privacy	Woojoong Ji	July 3-5, 2019	Christchurch	뉴질랜드
4	IEEE International Congress on Internet of Things (ICIOT) 2019	Eunil Seo	July 8-13, 2019	MILAN	이탈리아
5	WISA 2019: The 20th world conference on information security applications	KyungHo Park	Aug 21-24, 2019	Jeju Island	대한민국
6	2019 International Conference on Information and Communication Technology Convergence (ICTC)	Woorim Bang	Oct 16-18, 2019	Jeju Island	대한민국
7	Proceedings of the 35th Annual Computer Security Applications Conference	Joonun Jang	Dec 9-13, 2019	Puerto Rico	미국
8	2020 International Conference on Information and Communication Technology Convergence (ICTC)	Seohyun Kim	Oct 21-23, 2020	Jeju Island	대한민국

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[사회적 성과]

□ 전문 연구 인력 양성

번호	분류	기준 연도	현황										
			학위별				성별		지역별				
			박사	석사	학사	기타	남	여	수도권	충청권	영남권	호남권	기타
1	석사	2019		1			1		1				
2	박사	2021	1				1		1				

□ 국제화 협력성과

번호	구분 (유치/파견)	기간	국가	학위	전공	내용
1	학술회의 개최	2018-07-17	2018-07-20	-	-	THE 2018 INTERNATIONAL WORKSHOP ON THE INTERNET OF THINGS CYBERSECURITY AND SAFETY
2	파견	2019-08-01	2020-07-31	박사	컴퓨터공학	CSIRO의 Data61 방문 연구원으로 공동연구 수행
3	유치	2019-02-01	2019-06-30	박사	Information Technology	고려대학교에 visiting scholar position으로 공동연구 수행

□ 인력교류 성과

구분	상대국	상대기관명	기간 (YYYY.MM ~ YYYY.MM)	해당연구자				장/단기 구분
				국적	성명	학위2)	전공	
방문 교수	뉴질랜드	New Zealand, Canterbury University	2018. 09 ~ 2019. 3	대한민국	윤지원	박사	보안	장기

□ 포상 및 수상 실적

번호	종류	포상명	포상 내용	포상 대상	포상일	포상 기관
1	2018 사이버안보(보안) 논문 공모전	우수상	사이버안보(보안) 논문 공모전	이수연	2018.08	한국정보보호학회
2	2018 사이버안보(보안) 논문 공모전	대상	사이버안보(보안) 논문 공모전	문태근	2020.09	한국정보보호학회

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4) 목표 달성 수준

추 진 목 표	달 성 내 용	달성도(%)
그래픽 보안 모델 개발	IoT 장치, 시스템 및 서비스의 보안 평가를 자동화하고, IoT 환경 특성에 따라 확장 가능하고 적응력 있는 방식으로 IoT 장치들의 보안 수준을 비용 효과적으로 평가할 수 있는 그래픽 모델을 개발한다.	100%
효율적인 평가 방법 개발	IoT 장치들의 하드웨어/소프트웨어/통신 프로토콜의 이종성에 따라, 그룹화 및 군집화 기법을 이용하여 보안성을 평가한다. 또한, IoT 장치들의 유동성을 고려하여 모빌리티 모델을 통해 IoT 장치들의 이동 패턴을 파악함으로써 정확한 보안 평가를 수행할 수 있도록 한다.	100%
IoT 환경에 적합한 보안 지표 개발	기존의 보안 지표들이 IoT 환경에서 얼마나 효과적인지 분석하고, 사용하기 적합한 지표들을 제안한다. 또한, IoT 환경의 이종성과 유동성을 반영하여 효율적으로 보안성을 정량적으로 평가하기 위한 새로운 지표들을 개발한다.	100%
IoT 환경에 적합한 성능·경제 지표 개발	IoT 환경에 보안 기술 배포로 인한 IoT 장치들의 응답 시간, 지연 시간, 처리량 등의 성능이 얼마나 영향을 받는지 측정하기 위한 지표를 개발하고, 공격자에게 요구되는 비용과 노력 대비 보안 투자가 얼마나 비용 대비 효과적인지를 측정하기 위한 경제 지표를 개발한다.	100%
통합된 보안평가 도구 개발 및 테스트	본 연구에서 개발된 그래픽 보안 모델과 보안·성능·경제 지표, 효율적인 평가 방법이 모두 통합된 소프트웨어 도구를 개발하고, 자율주행 자동차와 스마트홈 환경에서 검증한다.	100%
자율주행 차량의 위협 모델링	자율주행 차량에 대한 위협 모델링을 수행하여 잠재적 위협을 도출하고, 현존하는 탐지, 완화 및 대응 기법들을 분석한다.	100%
탐지된 공격 패턴 공유를 위한 인프라스트럭처 설계	식별된 위협들과 공격 패턴을 효율적으로 공유하기 위한 인프라스트럭처를 설계하고 개발한다.	100%
시그니처 기반의 침입탐지 시스템 개발	위협 모델링을 통해 식별된 위협을 신속하게 탐지하기 위해서 패턴 매칭 알고리즘을 이용한 시그니처 기반의 침입탐지 시스템을 개발한다.	100%
이상징후 기반의 침입탐지 시스템 개발	알려지지 않은 공격 패턴을 탐지하기 위해 CAN 환경의 특성을 이용하여 메시지 ID 빈도, 패킷 시퀀스, 트래픽 엔트로피 모니터링 하는 경량 이상징후 탐지 알고리즘을 개발한다.	100%
기계학습 기반의 self-learning 침입탐지 기술 개발	새롭게 발생하는 공격 패턴들과 공격의 변종 패턴들을 자동으로 탐지하기 위해서 최신 기계학습 방법인 CNN (Convolutional Neural Network), DNN (Deep Neural Network), RNN (Recurrent Neural Network)를 이용하는 self-learning 엔진을 개발한다.	100%
효율적인 전기신호 수집 기술 연구	IoT 환경의 분산 네트워크에서 오디오/비디오/전력 신호에 들어있는 ENF 신호를 효율적으로 추출하기 위한 방법을 연구한다.	100%
노이즈 멀티미디어에서 전기 신호 탐지 및 추출 기술 개발	ENF 패턴은 주요 신호가 아니라 부 채널에 속하기 때문에 패턴이 불분명하고 노이즈가 심한 환경에서는 추출하기 어렵다. IoT 장치들로부터 ENF 패턴을 선명하게 복원해내기 위한 기술을 개발한다.	100%
다중 ENF 신호의 고주파 특성 추출 및 결합 기술 개발	다중 고주파 방법을 이용하여 IoT 데이터에 포함된 노이즈를 감소시키고 고품질의 ENF 신호를 추출하기 위한 기술을 개발한다.	100%
부분적으로 중첩된 신호의 정렬 기술 개발	IoT 네트워크의 센서 장치로부터 안정적이고 길이가 긴 ENF 신호를 수집하기 위해서 IoT 네트워크의 서로 다른 센서 데이터로부터 생성된 다중 ENF 신호를 신호 정렬 기법을 이용하여 정렬시킨다.	100%
ENF 신호를 이용한 보안사고 예측 가능성 평가	ENF 신호와 보안사고 사이의 연관성을 계산하고 비교한다. ENF 신호가 보안사고를 판단하는데 핵심 신호로 사용될 수 있다면, ENF 신호를 이용한 보안사고 예측 시스템을 개발할 수 있으며, 핵심 신호로 사용할 수 없는 경우에는 보안사고 예측에 추가적인 신호로써 사용할 수 있다.	100%

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

추 진 목 표	달 성 내 용	달성도(%)
ENF 신호를 이용한 보안사고 예측 기술 개발	ENF 신호와 보안사고가 높은 연관성을 가지고 있는 경우, IoT 네트워크의 센서 장치들로부터 수집된 ENF 신호를 이용한 보안사고 예측 시스템을 개발한다. 개발된 예측 시스템은 실시간으로 운영되어 온라인 서비스로 제공될 수 있다.	100%
일반 사용자를 위한 IoT 위협 모델 개발	IoT 시스템이 내재하고 있는 개인정보 및 보안 위협에 대해 인지하지 못하는 일반 사용자를 위한 다양한 IoT 위협 모델을 개발한다. 사이버 공격의 대상이 될 가능성이 높은 IoT 자산들을 식별하고, 일반적인 IoT 시스템들을 분석하여 IoT 장치로의 비인가된 접근으로 이어질 수 있는 진입 지점을 식별한다.	100%
사용가능하고 안전한 IoT 어플리케이션 개발	스마트홈 환경에서 직관적이고 사용자 친화적인 인터페이스 디자인을 통해 사용자에게 임박한 IoT 보안 위협을 효과적으로 알리고 위협을 완화시키기 위한 실행 가능한 조치를 제안하는 솔루션을 개발한다.	100%
IoT 어플리케이션을 위한 사이버보안 위협 탐지 시스템 개발	보안 결점을 탐지 및 진단하고 적절한 완화 조치를 자동으로 수행하는 사이버보안 경고 시스템을 개발한다. 사이버보안 경고 메시지와 연관된 위험을 시각적으로 제공하여 최종 사용자가 필요한 보안 조치를 신속하게 수행할 수 있도록 사용자 친화적인 보안 대시보드를 개발한다.	100%
IoT 어플리케이션을 위한 사이버보안 경고 시스템 개발	보안 결점을 탐지 및 진단하고 적절한 완화 조치를 자동으로 수행하는 사이버보안 경고 시스템을 개발한다. 사이버보안 경고 메시지와 연관된 위험을 시각적으로 제공하여 최종 사용자가 필요한 보안 조치를 신속하게 수행할 수 있도록 사용자 친화적인 보안 대시보드를 개발한다.	100%
사용자 보안 요구사항으로부터 보안 규칙 도출	최종 사용자가 IoT 장치 및 서비스의 보안 정책과 규칙을 용이하게 관리할 수 있도록 하는 기술을 개발한다.	100%
편의성 평가 지표 개발	사용자 행위와 사용자 만족도 두 가지 범주로 IoT 보안 어플리케이션에 적합한 편의성 평가 지표를 개발하고, 해당 지표들을 통해 보안 어플리케이션의 편의성을 평가하기 위한 IoT 테스트베드를 개발한다.	100%

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4. 연구개발성과의 관련 분야에 대한 기여 정도

1) 기술적 측면

본 연구 수행결과로서 기대되는 보안 위험/위협 평가 프레임워크를 통해 IoT 네트워크 및 이에 포함된 모든 기기들의 보안 취약점을 분석하고, 공격 가능한 루트를 파악할 수 있고, 여기에 대한 능동적인 대응책을 마련 가능하고 이상행위 탐지 및 반응을 효과적으로 수행할 수 있을 것으로 기대된다. 본 연구 수행결과로서 기대되는 IoT 네트워크 내의 ENF 신호를 수집하고 추출하는 방법과 신뢰할 수 있는 신호 처리 및 분석을 통해 자동화된 취약점 평가, 악의적인 보안 위협 행위 예측이 가능해 짐 , 이를 통해 이후 IoT 악성 행위 탐지 및 방어 시스템과 결합하여 적극적인 방어체계를 구축할 것으로 기대된다.

2) 경제적 산업적 측면

IoT는 스마트홈 등 생활가전을 비롯한 다양한 분야와 결합하면서 급속히 성장하고 있는 추세다. 시장조사기관 IDC에 따르면 2016 전 세계 IoT 시장은 7370억 달러로, 2015년보다 무려 17.9%나 성장 했으며, 오는 2020년 1조 7000억 달러에 달할 것으로 추정된다. 국내 IoT 관련 사업은 빠르게 성장하고 있지만, 국내 IoT 시장의 소비자의 93.0%는 IoT 기기로 인해 개인 사생활이 침해될 것으로 우려되고 있음. 이는 세계 평균이나 47.0%보다 불안도가 매우 높음. 이에 따라 국내 업계(SK인포섹, SGA솔루션즈 등)는 IoT 기기용 보안 OS를 개발 중에 있거나 상용화를 계획 중이다. 이는 점차 IoT 보안이 네트워크뿐만 아니라 기기에 탑재 되어있는 OS단에서 기기 보안성을 강화해 관련 시장을 점차 확대하려는 계획이다. IoT 서비스 업체들이 직면하고 있는 가장 큰 문제는 사이버보안 강화가 있으며, IoT 네트워크에 침투하여 스마트홈 서비스망 더 크게는 국가 통신망을 파괴할 수 있는 취약점을 사전에 식별 및 조치하는 적극적인 보안시스템 운용이 가능하여 국가 경제적 손실을 예방할 수 있다.

5. 연구개발성과의 관리 및 활용 계획

본 연구 수행결과로서 기대되는 자동화된 보안 위협 평가 프레임워크, 침해사고 탐지 및 반응 기술, 악의적 보안 이벤트 보안 예측 기법 및 편의성 테스트는 IoT 네트워크를 구성하고 있는 홈 캠, CCTV, 스마트홈, 스마트 자동차 등 다양한 시스템과 신규 서비스에서의 정보보호를 위한 기본적인 침해탑지 도구로 활용될 가능성이 있다. IoT는 기존의 임베디드 기기들뿐만 아니라 다양한 기기들에 인터넷이 결합됨에 따라 정보통신 네트워크 및 기기에서 발생 가능한 보안 문제가 작게는 개인 단위에서 크게는 국가적으로 확산 될 수 있다. 따라서 국민에게 제공되는 서비스 정보에 대한 무단 수집 및 도용, 관련 서비스 내용 조작, DDoS 공격으로 인한 네트워크로 연결된 기간 시스템의 마비 등 기존에는 나타나지 않았던 새로운 보안 위협 및 취약성이 점차 확산될 가능성이 크다. 따라서 기술적 측면에서의 보안 대책이 새롭게 수립되어야 하며, 본 연구과제 수행결과인 보안 위험/위협 평가 프레임워크는 IoT 서비스에서의 정보보호를 위한 기반기술로 활용될 수 있으며, 이와 같은 핵심 원천기술 확보를 통하여 특허 기술 선점을 통한 국가 경쟁력 확보가 가능하며, 개발된 기술의 국내업체 이전을 통한 국내업체 경쟁력 강화 및 지적재산권에 대한 간접 수익을 낼 수 있을 것으로 기대된다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 별첨 자료 >

중앙행정기관 요구사항	별첨 자료
1. 논문(SCIE)	1) Digital forensic analysis of encrypted database files in instant messaging applications on Windows operating systems: Case study with KakaoTalk, NateOn and QQ messenger
	2) Automated dataset generation system for collaborative research of cyber threat analysis
	3) CBR-Based Decision Support Methodology for Cybercrime Investigation: Focused on the Data-Driven Website Defacement Analysis
	4) Do Many Models Make Light Work? Evaluating Ensemble Solutions for Improved Rumor Detection
2. 학술대회	1) ADSaS Comprehensive real-time anomaly detection system
	2) Threat Modeling and Analysis of Voice Assistant Applications
	3) FuzzBuilder: Automated building greybox fuzzing environment for C/C++ library
	4) Show Me Your Account: Detecting MMORPG Game Bot Leveraging Financial Analysis with LSTM
	5) Forecasting the Electric Network Frequency Signals on Power Grid
	6) Automated Cash Mining Attacks on Mobile Advertising Networks
	7) Profiling-based classification algorithms for security applications in Internet of Things
	8) Location tracking technique for Regional ENF Classification Using ARIMA

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 1-1 >

Digital Investigation 28 (2019) S50–S59

Contents lists available at ScienceDirect

Digital Investigation

journal homepage: www.elsevier.com/locate/diin

Digital forensic analysis of encrypted database files in instant messaging applications on Windows operating systems: Case study with KakaoTalk, NateOn and QQ messenger

Jusop Choi [a], Jaegwan Yu [b], Sangwon Hyun [c], Hyoungshick Kim [a, *]

[a] Sungkyunkwan University, Republic of Korea
[b] LIGNEXT Co., Ltd, Republic of Korea
[c] Chosun University, Republic of Korea

ARTICLE INFO

Article history:

Keywords:
Instant messaging applications
Forensic analysis
Database encryption
Key recovery

ABSTRACT

Instant messaging applications store users' personal data (e.g., user profile, chat messages, photos and video clips). Because those data typically include privacy sensitive information, most instant messaging applications are trying to protect the stored data in an encrypted form so that the authorized messaging application itself can only access the data. In this paper, we analyzed the locations and file formats of personal data files in three instant messaging applications (KakaoTalk, NateOn, and QQ) which are the most popularly used in China and South Korea. We particularly examined the encryption and decryption procedures for internal databases in those messaging applications through reverse-engineering. Our analysis results demonstrate how the database files of those instant messaging applications are stored and encrypted. Moreover, in the cases of KakaoTalk and NateOn applications, we found that their encrypted database files can successfully be recovered without requiring user password. We also found that QQ messenger stores the encryption key for the database files into an external server. This implementation may raise another privacy concern because users' personal data can be freely accessed by the service provider without user consent.

© 2019 The Author(s). Published by Elsevier Ltd on behalf of DFRWS. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

Introduction

Instant Messaging (IM) applications such as AIM, MSN Messenger, Google Talk, and WhatsApp help people to communicate with each other. IM applications have become increasingly popular because they have several advantages over other communication methods (e.g., email and phone calls). IM applications provide reliable and timely message delivery between users. Moreover, users are capable of sending messages to other users even in offline, archiving previous messages, and checking whether a message recipient already read a delivered message or not.

However, IM applications often raise serious privacy concerns because users' private messages, photos, and video clips can be exposed to unauthorized parties (Alfred and Sameer Patil, 2012). In an IM application, a user's personal data is typically stored in database files on a device (e.g., PC or smartphone) where the IM application is running. Inherently, such database files would have become one of the most attractive targets for intelligence agencies, police investigators or cybercriminals. For example, the information about friends or contacts could be misused for a variety of cybercriminal activities such as spam, phishing and rogue accounts (Kim et al., 2015). As another example, intelligence agencies or police officers can access suspects' chat database files for investigation which may violate people's privacy without their consent (Fitzpatrick, 2016). Therefore, it is crucial to protect users' personal data stored in the database files against unauthorized accesses.

To protect the database files of a user's personal data, an IM application typically encrypt the database files with a key only accessible by the IM application. Unsurprisingly, the management of this encryption key is critically important because the exposure of the encryption key provides any individual with access to the protected database files of the IM application. Our research was motivated to investigate whether the security of the encryption key in commercial IM applications would actually be acceptable to the standard criteria in the information security community.

* Corresponding author.
E-mail addresses: cjs19920@skku.edu (J. Choi), jaegwan.yu@lignex1.com (J. Yu), shyun@chosun.ac.kr (S. Hyun), hyoung@skku.edu (H. Kim).

https://doi.org/10.1016/j.diin.2019.01.011
1742-2876/© 2019 The Author(s). Published by Elsevier Ltd on behalf of DFRWS. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

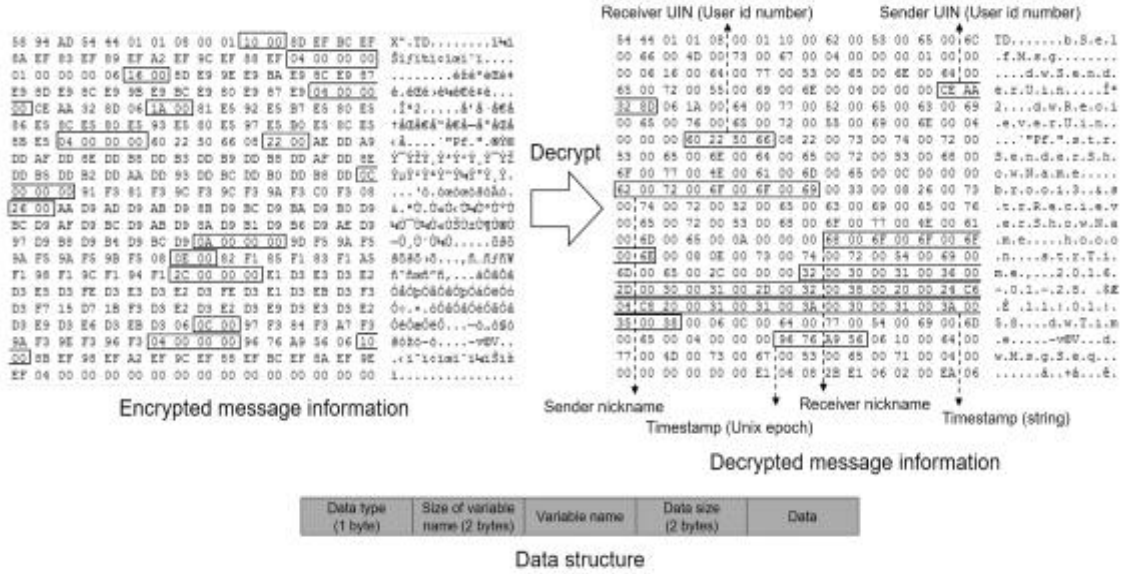


Fig. 9. Message information block in QQ.

are the most popular IMs in China and South Korea. This forensic analysis revealed how an encryption key is generated and how chat history database files are internally stored and encrypted in these IMs.

In the cases of KakaoTalk and NateOn, we found that a user's chat messages can be recovered from encrypted database files without any secret information (e.g., user password) from the user. In the case of QQ messenger, we found that an encryption key for each client application is generated by the service provider and delivered to the client application. This design of centralized key management may raise another privacy concern because the service provider can access every user's chat messages without any restrictions. Unlike QQ messenger, key generation in a KakaoTalk application contains the device-specific information (e.g., *UUID*, *MN*, and *SN*) which is not exposed to the service provider. Without knowledge of such device-specific information, the service provider cannot obtain the same key as the device owner and consequently cannot decrypt the device owner's chat messages from the encrypted database files.

Our study shows how difficult it is to securely protect the user's sensitive data files with only pure software technologies against sophisticated attackers. Although we cannot obtain the encryption key only using application analysis in QQ messenger, it has a risk that messenger server or government can obtain the user's private messages because the key is only managed by the server side. Although we currently limited our security analysis to KakaoTalk, NateOn and QQ messenger service only, we believe this type of attack can also be applicable to other IM applications.

In future work, we plan to analyze the chat history protection features of other messengers, and also develop countermeasures to protect encrypted databases against forensic analysis.

Acknowledgments

This work was supported in part by the ICT R&D program (No.2018-0-00532) and the NRF (No.2017K1A3A1A17092614, NRF-2016R1A6A3A11930593). The authors would like to thank all the anonymous reviewers for their valuable feedback.

References

Aditya Mahajan, M.S.D., Sanghvi, H.P., 2013. Forensic analysis of instant messenger applications on android devices. Int. J. Comput. Appl. 68 (8), 38–44.

Al Barghuthi, N.B., Said, H., 2013. Social networks IM forensics: encryption analysis. J. Commun. 8 (11), 708–715.

Alfred, Kobsa, Sameer Patil, B.M., 2012. Privacy in instant messaging: an impression management model. Behav. Inf. Technol. 31, 355–370.

Anglano, C., 2014. Forensic analysis of WhatsApp messenger on android smartphones. Digit. Invest. 11 (3), 201–213.

Choi, J., Park, J., Kim, H., 2017. Forensic analysis of the backup database file in KakaoTalk messenger. In: Big Data and Smart Computing (BigComp), 2017 IEEE International Conference on. IEEE, pp. 156–161.

Corp, K., 2016. 2Q FY2016 Earnings Conference Call. http://www.kakaocorp.com/upload_resources/ir/event/ir_event_20160825012832.pdf. (Accessed 7 September 2016).

Eastlake 3rd, D., Jones, P., September 2001. US Secure Hash Algorithm 1 (SHA1). RFC 3174, Cisco Systems. https://tools.ietf.org/rfc/rfc3174.txt. (Accessed 24 January 2017).

Fitzpatrick, A., 2016. Here's How Police Get a Suspect's Facebook Information. http://mashable.com/2012/12/18/police-facebook/#ERE6rnihaPqw. (Accessed 14 September 2016).

Gao, F., Zhang, Y., 2013. Analysis of WeChat on iPhone. In: 2nd International Symposium on Computer, Communication, Control and Automation. pp. 278–281.

Kim, E., Park, K., Kim, H., Song, J., 2015. Design and analysis of enumeration attacks on finding friends with phone numbers: a case study with KakaoTalk. Comput. Secur. 52, 267–275.

Kohl, J., Neuman, C., September 1993. The Kerberos Network Authentication Service (V5). RFC 1510, ISI. http://www.rfc-editor.org/rfc/pdfrfc/rfc1510.txt.pdf. (Accessed 22 January 2019).

Lee, J.-K., Han, J.-S., Lee, S.-J., 2011. Method to extract communication history in instant messenger. J. Korea Inst. Inf. Secur. Cryptol. 21 (2), 49–60.

Microsoft Corp, 1999. OLE Concepts and Requirements Overview. http://support.microsoft.com/kb/q86008. (Accessed 24 September 2016).

Neuman, B.C., Ts'o, T., 1994. Kerberos: an authentication service for computer networks. IEEE Commun. Mag. 32 (9), 33–38.

Park, K., Kim, H., 2015. Encryption is not enough: inferring user activities on KakaoTalk with traffic analysis. In: International Workshop on Information Security Applications. pp. 254–265.

Park, S., Oh, D., Lee, B.G., 2011. Analyzing user satisfaction factors for instant messenger-based mobile SNS. In: Future Information Technology. Springer, pp. 280–287.

Rivest, R., April 1992. The MD5 Message-Digest Algorithm. RFC 1321. MIT Laboratory for Computer Science and RSA Data Security, Inc.. https://tools.ietf.org/rfc/rfc1321.txt. (Accessed 2 November 2016)

Rogaway, P., 2004. Efficient instantiations of tweakable blockciphers and refinements to modes OCB and PMAC. In: International Conference on the Theory and Application of Cryptology and Information Security. Springer, pp. 16–31.

Shin, D., Choi, Y., Lee, Y., Park, S., Kim, S., Won, D., 2007. Security analysis on the authentication mechanisms of Korean popular messengers. In: International

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 1-2 >

Hindawi
Security and Communication Networks
Volume 2019, Article ID 6268476, 10 pages
https://doi.org/10.1155/2019/6268476

WILEY | Hindawi

Research Article

Automated Dataset Generation System for Collaborative Research of Cyber Threat Analysis

Daegeon Kim and **Huy Kang Kim**

Graduate School of Information Security, Korea University, Seoul, Republic of Korea

Correspondence should be addressed to Huy Kang Kim; cenda@korea.ac.kr

Received 5 April 2019; Revised 30 July 2019; Accepted 5 September 2019; Published 30 September 2019

Guest Editor: Surya Nepal

Copyright © 2019 Daegeon Kim and Huy Kang Kim. This is an open access article distributed under the Creative Commons Attribution License, which permits unrestricted use, distribution, and reproduction in any medium, provided the original work is properly cited.

The objectives of cyberattacks are becoming sophisticated, and attackers are concealing their identity by masquerading as other attackers. Cyber threat intelligence (CTI) is gaining attention as a way to collect meaningful knowledge to better understand the intention of an attacker and eventually predict future attacks. A systemic threat analysis based on data acquired from actual cyber incidents is a useful approach to generating intelligence for such an objective. Developing an analysis technique requires a high-volume and fine-quality data. However, researchers can become discouraged by inaccessibility to data because organizations rarely release their data to the research community. Owing to a data inaccessibility issue, academic research tends to be biased toward techniques that develop steps of the CTI process other than analysis and production. In this paper, we propose an automated dataset generation system called CTIMiner. The system collects threat data from publicly available security reports and malware repositories. The data are stored in a structured format. We released the source codes and dataset to the public, including approximately 640,000 records from 612 security reports published from January 2008 to June 2019. In addition, we present a statistical feature of the dataset and techniques that can be developed using it. Moreover, we demonstrate an application example of the dataset that analyzes the correlation and characteristics of an incident. We believe our dataset will promote collaborative research on threat analysis for the generation of CTI.

1. Introduction

Cyber threat intelligence (CTI) is evidence-based knowledge including context, mechanisms, indicators, implications, and actionable advice regarding existing or emerging threats to assets [1]. CTI can be utilized to achieve a broad situational awareness, collaborate in defeating cyber threats faced by others, and prevent cyber threats by applying CTI into defense systems.

With an increase in global cyber threats, CTI is gaining increased attention as a response to such threats. Many nations and organizations have also attempted to promote the use of CTI by enacting laws that legalize and encourage the collection of CTI [2], sharing CTI through multilateral cooperation [3–5], and establishing various standards [6, 7]. Furthermore, during the recent decade, the number of articles related to CTI have dramatically increased, as shown in Figure 1 (Google Scholar search result with exact keyword matching of "cyber threat intelligence" including patents and citations on March 30, 2019).

During the Olympic Winter Games in PyeongChang 2018, a cyberattack targeting the server operated by the organizing committee occurred. What makes this case noteworthy is that the security researchers attributed different countries as the perpetrators of the attack. The authors in [4, 8] insisted that Chinese and Russian actors were responsible for the attack, respectively. In [9, 10], it was pointed out that it is impossible to attribute the attack to a specific country based on the small amount of code discovered, which overlaps malware used by the Lazarus Group, a hacking group from North Korea. However, the authors of [4] insisted that there was evidence indicating that a Russian attacker tried to masquerade as a North Korean hacking group. In this example, we can see that a precise

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

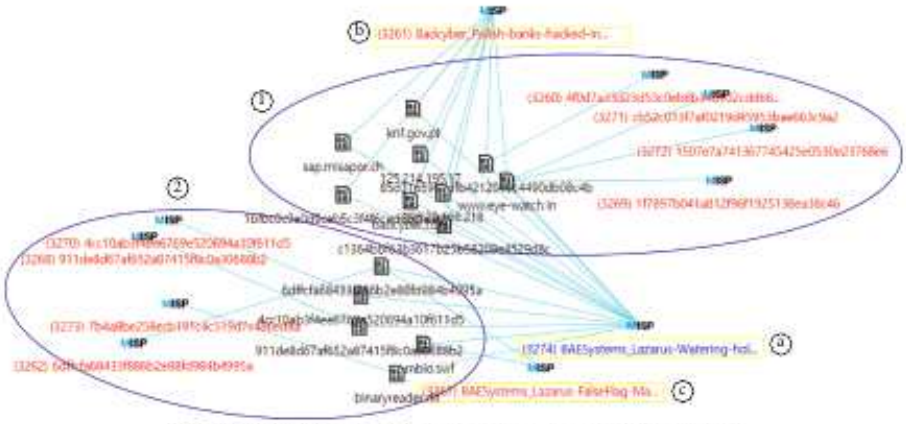


FIGURE 10: Sample application of the dataset to a correlation analysis.

6. Conclusion

Owing to the prevalence of cyber threats and a rapid increase in the amount of data collected, researchers are developing techniques for the different intelligence processes to be actively conducted. However, compared to other intelligence processing steps, studies have been undertaken limitedly for the analysis and production step that requires the real CTI dataset for the analysis. We pointed out that dataset unavailability is the main reason suppressing vitalization of the research despite many interests. To address the problem, we proposed CTIMiner system that generates the dataset consisted of the data contained in security reports and supplemented with malware analysis data related to the reports. After categorizing the types of data collected from the system, we provided the statistical feature of the dataset. To show the usability and applicability of the dataset, we proposed several research topics possible to be conducted using the dataset and demonstrated the correlation analysis result for an event in the dataset.

Our future research direction is to develop and enhance the proposed analysis technique using the dataset on top of the CTI correlation analysis framework [12]. By releasing this dataset to the public, we believe it can promote the threat analysis research to generate CTI.

Data Availability

The source codes of CTIMiner system and the generated dataset described in this paper are available to the public. These are accessible at our GitHub repository (https://github.com/dgkim0803/CTIMiner). Using the source codes, security reports, and MISP, one can generate a dataset composed of the data types that one has interested in.

Conflicts of Interest

The authors declare that they have no conflicts of interest.

Acknowledgments

This work was supported under the framework of international cooperation program managed by the National Research Foundation of Korea (No. 2017K1A3A1A17092614).

References

[1] R. McMillan, *Definition: Threat Intelligence*, Gartner, Stamford, CT, USA, 2013.

[2] *Senate Resolution 754, Cybersecurity Information Sharing Act of 2015 (CISA)*, Council on Foreign Relations, New York, NY, USA, 2015.

[3] *Cybersecurity Alliance for Mutual Progress (CAMP)*, 2016, https://www.cybersec-alliance.org.

[4] Olympic destroyer is here to trick the industry," *GReAT*, 2018, https://securelist.com/olympicdestroyer-is-here-to-trick-theindustry/84295/.

[5] *FACT SHEET: President Xi Jinping's State Visit to the United States*, The White House, Washington, DC, USA, 2015.

[6] C. Johnson and D. Waltermire, *Special Publication 800-150: Guide to Cyber Threat Information Sharing*, National Institute of Standards and Technology (NIST), Gaithersburg, MD, USA, 2014.

[7] "The MITRE cybersecurity standards," 2013, https://www.mitre.org/capabilities/cybersecurity/overview/cybersecurityresources/standards.

[8] J. Rosenberg, "2018 winter cyber olympics: code similarities with cyber attacks in Pyeongchang," 2018, http://www.intezer.com/2018-winter-cyber-olympics-code-similarities-cyber-attacks-pyeongchang.

[9] M. L. P. Rascagneres, "Who wasn't responsible for olympic destroyer?," 2018, https://blog.talosintelligence.com/2018/02/who-wasnt-responsible-for-olympic.html.

[10] J. A. Guerrero-Saade, P. Moriuchi, and G. Lesnewich, "Targeting of olympic games it infrastructure remains unattributed," 2018, https://www.recordedfuture.com/olympic-destroyer-malware.

[11] *Joint Publication 2-0: Joint Intelligence*, U.S. Joint Chiefs of Staff, USA, 2013.

[12] D. Kim, J. Woo, and H. K. Kim, ""I know what you did before": General Framework for Correlation Analysis of Cyber Threat Incidents," in *Proceedings of the IEEE 35th*

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 1-3 >

Hindawi
Security and Communication Networks
Volume 2019, Article ID 1901548, 21 pages
https://doi.org/10.1155/2019/1901548



Research Article

CBR-Based Decision Support Methodology for Cybercrime Investigation: Focused on the Data-Driven Website Defacement Analysis

Mee Lan Han, Byung Il Kwak, and Huy Kang Kim

Graduate School of Information Security, Korea University, Seoul, Republic of Korea

Correspondence should be addressed to Huy Kang Kim; cenda@korea.ac.kr

Received 25 March 2019; Revised 21 August 2019; Accepted 2 December 2019; Published 20 December 2019

Guest Editor: Jungwoo Ryoo

Copyright © 2019 Mee Lan Han et al. This is an open access article distributed under the Creative Commons Attribution License, which permits unrestricted use, distribution, and reproduction in any medium, provided the original work is properly cited.

Criminal profiling is a useful technique to identify the most plausible suspects based on the evidence discovered at the crime scene. Similar to offline criminal profiling, in-depth profiling for cybercrime investigation is useful in analysing cyberattacks and for speculating on the identities of the criminals. Every cybercrime committed by the same hacker or hacking group has unique traits such as attack purpose, attack methods, and target. These unique traits are revealed in the evidence of cybercrime; in some cases, these unique traits are well hidden in the evidence such that it cannot be easily perceived. Therefore, a complete analysis of several factors concerning cybercrime can provide an investigator with concrete evidence to attribute the attacks and narrow down the scope of the criminal data and grasp the criminals in the end. We herein propose a decision support methodology based on the case-based reasoning (CBR) for cybercrime investigation. This study focuses on the massive data-driven analysis of website defacement. Our primary aim in this study is to demonstrate the practicality of the proposed methodology as a proof of concept. The assessment of website defacement was performed through the similarity measure and the clustering processing in the reasoning engine based on the CBR. Our results show that the proposed methodology that focuses on the investigation enables a better understanding and interpretation of website defacement and assists in inferring the hacker's behavioural traits from the available evidence concerning website defacement. The results of the case studies demonstrate that our proposed methodology is beneficial for understanding the behaviour and motivation of the hacker and that our proposed data-driven analytic methodology can be utilized as a decision support system for cybercrime investigation.

1. Introduction

Advanced persistent threat (APT) attacks, stealthily and continuously controlled by hackers or hacking groups targeting a specific entity, remain as a challenging threat, particularly to the companies or organizations that handle sensitive funding and information. When successful, APT attacks can have a catastrophic impact on critical infrastructures, such as banking, broadcasting system, and mass media sites. This impact is not speculative or theoretical—in fact, it is supported by various real-world incidents and actual attacks. For instance, in February 2016, a group of hackers stole $81 million from the Central Bank of Bangladesh through its account at the Federal Reserve Bank of New York through an APT attack which targeted constantly the SWIFT payment system for a year [1]. Furthermore, in May 2017, the WannaCry ransomware, another type of APT attack, spread due to the vulnerability in the Microsoft Server Message Block (SMB; the message format used to share folders and files and so on in Microsoft Windows OS). This attack caused catastrophic consequences, such a standstill and disruption of online work in hospitals, companies, and several government agencies. According to Symantec's 2017 annual report [2], the SWIFT case and the WannaCry ransomware case were perhaps launched by the Lazarus group that could be affiliated to the DarkSeoul (DS) case in 2013 and the Sony Pictures Entertainment (SPE) case in 2014. Symantec found that the hacking skills in the SWIFT case were very similar to those used by the Lazarus group, presumably one of the North

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

and evidence-driven decision making should be the critical process. Also, reducing the amount of data and time to be analysed are important factors to deliver the high value of intelligence data.

Although the obtained results appear to be sound and meaningful, it is difficult to evaluate the accuracy of the results unless the attacker is captured. Naturally, the ground-truth data with specific information about the involved hacking groups for verification are rare (i.e., no adversary claimed that the two attacks were the result of their actions). However, it is noteworthy that our methodology provides a meaningful insight into the confidential and undercover network of cybercrime as well, especially when there is a lack of information. Also, the proposed methodology contributes to facilitate the analysis and reducing the time required for searching for possible suspects of cybercrime. We believe that the proposed system is meaningful for further exploration and correlation of various website defacement cases.

As mentioned in Discussion and Limitations, a cross-data analysis with other various data sources should be reviewed. Said differently, the use of additional online or offline information acquired by human intelligence (HUMINT) or different types of signal intelligence (SIGINT) and sources may also help to reason composition requirements of crime and reduce the category of investigation. Furthermore, the proposed methodology can be expanded into incident information for compatibility and information exchangeability with other cyberthreat intelligence system as the Structured Threat Information eXpression (STIX) and Trusted Automated eXchange of Indicator Information (TAXII), which are key strategic elements of the information-sharing system [54].

There are features such as the particular messages (i.e., thanks-to, notifier, nationality, religion, and anniversary) or image and mp3 file in the web resources which are gathered from the zone-h.org site. Although these features are limited to only a small number of hackers of the web resources, in future research, we will try to study a close-knit network among them, such as the hub hacking group, key player, and followers. Furthermore, we also plan to more definitely classify and systemize the hackers' intents using text mining and mood detection techniques. The findings of this prospective study will contribute meaningful insights to trace hackers' behavioural patterns and to estimate their primary purpose and intent.

Data Availability

The web-hacking dataset applied to our paper can be downloaded from the linked site below. http://ocslab.hksecurity.net/Datasets/web-hacking-profiling.

Conflicts of Interest

The authors declare that there are no conflicts of interest regarding the publication of this paper.

Acknowledgments

This work was supported under the framework of international cooperation program managed by the National Research Foundation of Korea (No. 2017K1A3A1A17092614).

References

[1] S. S. Response, "Swift attackers' malware linked to more financial attacks," 2016, https://www.symantec.com/connect/blogs/swift-attackers-malware-linked-more-financial-attacks.

[2] S. S. Response, "Wannacry: ransomware attacks show strong links to lazarus group," 2017, https://www.symantec.com/connect/blogs/wannacry-ransomware-attacks-show-strong-links-lazarus-group.

[3] K. lab, "Lazarus under the hood," 2018, https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2018/03/07180244/Lazarus_Under_The_Hood_PDF_final.pdf.

[4] Operation Blockbuster, "Destructive malware report," 2016, https://www.operationblockbuster.com/wp-content/uploads/2016/02/Operation-Blockbuster-Destructive-Malware-Report.pdf.

[5] D. Martin and SANS Institute InfoSec Reading Room, "Tracing the lineage of DarkSeoul," 2016, https://www.sans.org/reading-room/whitepapers/critical/tracing-lineage-darkseoul-36787.

[6] D. S. C. T. U. T. Intelligence, "Wiper malware threat analysis," 2013, https://www.secureworks.com/research/wiper-malware-analysis-attacking-korean-financial-sector.

[7] R. Sherstobitoff, M. L. Itai Liba, and O. O. T. C. James Walter, "Dissecting operation troy: cyberespionage in South Korea," 2013, https://www.mcafee.com/enterprise/en-us/assets/white-papers/wp-dissecting-operation-troy.pdf.

[8] N. Horton and A. DeSimone, "Sony's nightmare before christmas: the 2014 North Korean cyber attack on Sony and lessons for US government actions in cyberspace," 2018, https://www.jhuapl.edu/Content/documents/SonyNightmareBeforeChristmas.pdf.

[9] I. K. Lee and S. R. Ramsey, *The Korean Language*, State University of New York, Albany, NY, USA, 2000.

[10] V. Benjamin and H. Chen, "Securing cyberspace: identifying key actors in hacker communities," in *Proceedings of the 2012 IEEE International Conference on Intelligence and Security Informatics*, pp. 24–29, Arlington, VA, USA, June 2012.

[11] Y. Lu, X. Luo, M. Polgar et al., "Social network analysis of a criminal hacker community," *Journal of Computer Information Systems*, vol. 51, no. 2, pp. 31–41, 2010.

[12] J.-W. Jang, H. Kang, J. Woo, A. Mohaisen, and H. K. Kim, "Andro-autopsy: anti-malware system based on similarity matching of malware and malware creator-centric information," *Digital Investigation*, vol. 14, pp. 17–35, 2015.

[13] J. W. Jang and H. K. Kim, "Function-oriented mobile malware analysis as first aid," *Mobile Information Systems*, vol. 2016, Article ID 6707524, 11 pages, 2016.

[14] Y. Ki, E. Kim, and H. K. Kim, "A novel approach to detect malware based on api call sequence analysis," *International Journal of Distributed Sensor Networks*, vol. 11, no. 6, Article ID 659101, 2015.

[15] M. L. Han, H. C. Han, A. R. Kang et al., "Web-hacking dataset for the cyber criminal profiling," 2016, http://ocslab.hksecurity.net/Datasets/web-hacking-profiling.

[16] M. L. Han, H. C. Han, A. R. Kang, B. I. Kwak, A. Mohaisen, and H. K. Kim, "WAHP: web-hacking profiling using case-based reasoning," in *Proceedings of the 2016 IEEE Conference*

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 1-4 >

IEEE Access

Received July 28, 2020, accepted August 6, 2020, date of publication August 14, 2020, date of current version August 26, 2020.

Digital Object Identifier 10.1109/ACCESS.2020.3016664

Do Many Models Make Light Work? Evaluating Ensemble Solutions for Improved Rumor Detection

YOUNGHWAN KIM[1], HUY KANG KIM[1], (Member, IEEE), HYOUNGSHICK KIM[2,3], (Associate Member, IEEE), AND JIN B. HONG[4], (Member, IEEE)

[1]School of Cybersecurity, Korea University, Seoul 02841, South Korea
[2]Department of Computer Science and Engineering, College of Software, Sungkyunkwan University, Seoul 16419, South Korea
[3]CSIRO Data61, Eveleigh, NSW 2015, Australia
[4]Department of Computer Science and Software Engineering, The University of Western Australia, Crawley, WA 6009, Australia

Corresponding author: Jin B. Hong (jin.hong@uwa.edu.au)

This work was supported in part by the Australia-Korea Foundation (AKF) of the Department of Foreign Affairs and Trade (DFAT) project Intelligent Cybersecurity: Jumpstarting Collaboration on Smarter Security for Dynamic Networks, and in part by the framework of international cooperation program managed by the National Research Foundation of Korea under Grant NRF-2017K1A3A1A17092614.

ABSTRACT There have been many efforts to detect rumors using various machine learning (ML) models, but there is still a lack of understanding of their performance against different rumor topics and available features, resulting in a significant performance degrade against completely new and unseen (unknown) rumors. To address this issue, we investigate the relationship between ML models, features, and rumor topics to select the best rumor detection model under specific conditions using 13 different ML models. Our experiment results demonstrate that there is no clear winner among the ML models in all different rumor topics with respect to the detection performance. To overcome this problem, a possible way is to use an ensemble of ML models. Although previous work presents an improved detection of rumors using ensemble solutions (ES), their evaluation did not consider detecting unknown rumors. Further, they did not present nor evaluate the configuration of the ES to ensure that it indeed performs better than using a single ML model. Based on these observations, we propose to evaluate the use of an ES by examining their unknown rumor detection performance compared with single ML models but as well as different configurations of the ESes. Our experimental results using real-world datasets found that an ES of Random Forest, XGBoost and Multilayer perceptron overall produced the best F1 score of 0.79 for detecting unknown rumors, a significant improvement compared with a single best ML model which only achieved a 0.58 F1 score. We also showed that not all ESes are the same, with significantly degraded detection and large variations in performance when different ML models are used to construct the ES. Hence, it is infeasible to rely on any single ML model-based rumor detector. Finally, our solution also performed better than other recent detectors, such as eventAI and NileTMRG that performed similar to using a single ML model – making it a much more attractive solution to detect unknown rumors in practice.

INDEX TERMS Feature analysis, machine learning, rumor detection, social media, ensemble solution, Twitter.

I. INTRODUCTION

The spread of rumors is still prevalent today. To address this issue, various machine learning (ML) models have been proposed to detect rumors [1], [2]. The majority has focused on improving the performance of ML models for specific rumor events (e.g., crime-related tweets from [3]), but mostly they were applied in the post-analysis phase (i.e., after the rumor has spread/collected). Consequently, many ML models were able to achieve a competitive performance (in terms of accuracy, F1 scores, etc.), but using them to detect new and unseen (unknown) rumor events significantly degraded their detection performance (which we demonstrate later in Section IV). For example, there was a large number of rumors

The associate editor coordinating the review of this manuscript and approving it for publication was Camelia Delcea.

This work is licensed under a Creative Commons Attribution 4.0 License. For more information, see https://creativecommons.org/licenses/by/4.0/

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-1 >

ADSaS: Comprehensive Real-time Anomaly Detection System

Sooyeon Lee, and Huy Kang Kim

***Abstract*—Since with massive data growth, the need for autonomous and generic anomaly detection system is increased. However, developing one stand-alone generic anomaly detection system that is accurate and fast is still a challenge. In this paper, we propose conventional time-series analysis approaches, the Seasonal Autoregressive Integrated Moving Average (SARIMA) model and Seasonal Trend decomposition using Loess (STL), to detect complex and various anomalies. Usually, SARIMA and STL are used only for stationary and periodic time-series, but by combining, we show they can detect anomalies with high accuracy for data that is even noisy and non-periodic. We compared the algorithm to Long Short Term Memory (LSTM), a deep-learning-based algorithm used for anomaly detection system. We used a total of seven real-world datasets and four artificial datasets with different time-series properties to verify the performance of the proposed algorithm.**

***Index Terms*—anomaly detection, SARIMA, STL, real-time, data stream**

I. Introduction

EXTREMELY vast data leads to severe challenges to a security administrator who should catch all the anomalies in real-time. Anomaly detection cannot be regarded as a human-work anymore. To automate the anomaly detection process, machine-learning-based and statistics-based anomaly detection have been researched within diverse research areas including network intrusion detection, fraud detection, medical diagnoses, sensor events and others. Despite the variety of such studies in recent years, most anomaly detection systems find anomalies in limited conditions. This is because not only a variety of attacks but also multiple sensors in a single device generate a different type of time-series. In the case of IoT devices, which are embedded with multiple sensors, it is inefficient to use independent anomaly detection algorithms to each different sensor. Anomaly detection systems that are resistant to various datasets should detect anomalies autonomously irrespectively of the time-series properties.

Also, the anomaly detection system should occupy as little memory as possible. Most of deep learning based anomaly detection systems are generally unsuitable for an environment such as IoT devices because of the limited memory and light capacity. As most anomalies cause a critical problem to the medical system such as ventricular assist system, anomaly detection system must get less latency. Although there are many types of researches based on deep learning recently, deep learning approaches are not suitable to process data in real-time that changes frequently or has large data since it takes a lot of time to build a model compared to other algorithms.

S. Lee and H. K. Kim are with Korea University.

The critical conditions of anomaly detection system for IoT devices or cloud network intrusion detection are as follows. First is accuracy, second is speed, third is the small size of the model and the last is domain universality [1], [2]. We propose ADSaS, anomaly detection system using SARIMA and STL, to meet the four conditions. SARIMA is conventional time-series forecast method, and STL is a versatile and robust method for time-series decomposition. Aforementioned methods are commonly used for stationary and periodic time-series data [3]. In our experiments, however, integrating two methods shows better performance not only for periodic data but also for non-periodic data. Moreover, the size of the model and speed are optimized by undersampling and interpolation. For accuracy, we defined an anomaly window for evaluation and then judged how well ADSaS finds anomalies in various datasets.

The contributions of our system are as follows:

- Regardless of time-series properties, ADSaS detects anomalies with high precision and recall. We verify this by using the time-series from a variety of sources. With the development of Cyber-Physical Systems (CPS) or IoT devices, anomaly detection systems must detect anomaly autonomously and generically for applications.
- ADSaS detects various types of anomaly. (i.e., peak, dip, concept drift, contextual anomalies, and collective anomalies)
- ADSaS detects anomalies with short latency. We use two conventional time-series analysis methods and advance performance by undersampling. By undersampling time-series, time-series model is built much faster. Though undersampling causes loss of data, STL recovers that loss by decomposing prediction errors.
- ADSaS proceeds anomaly detection in real-time for every data stream.

II. Related works

In particular, there have been studies such as automotive IDS [4], SCADA, control network [6] to detect anomalies for mission-critical and safety-critical systems. It is important to develop anomaly detection algorithm robustly for the efficiency of intrusion detection in a modern network environment such as cloud computing [5]. Anomaly detection in time-series is roughly divided to clustering-based approach [7], [8] and forecast-based approach. Most of the forecast-based approaches perform anomaly detection based on the error with the predicted value.

Several machine learning techniques were introduced so far for anomaly detection system. LSTM network has been

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

ACKNOWLEDGEMENTS

This work was supported under the framework of international cooperation program managed by National Research Foundation of Korea (No.2017K1A3A1A17 092614).

REFERENCES

[1] Zhi-Kai, Z. et al.: IoT Security: Ongoing Challenges and Research Opportunities, In: 7th International Conference on Service-Oriented Computing and Applications (SOCA) on IEEE, pp. 230-234. (2014)
[2] Subutai, A. et al.: Unsupervised real-time anomaly detection for streaming data, Neurocomputing, vol. 262, pp. 134-147. (2017)
[3] James, H.: Time Series Analysis, Princeton University Press (1994)
[4] Han, M. et al.: A statistical-based anomaly detection method for connected cars in internet of things environment, In: International Conference on Internet of Vehicles, pp.88-97. (2015)
[5] Kwon, H. et al.: Self-similarity based lightweight intrusion detection method for cloud computing, In: Asian Conference on Intelligent Information and Database Systems, pp.353-362. (2011)
[6] Yu, S.J. et al.:Hurst parameter based anomaly detection for intrusion detection system, In: Computer and Information Technology, pp. 234-240. (2016)
[7] Kingsly, L., Christopher, L.: Unsupervised Anomaly Detection in Network Intrusion Detection Using Clusters, Proceedings of the Twenty-eighth Australasian conference on Computer Science, vol. 38, pp. 333-342. (2005)
[8] Rikard, L., Goran, F., Egils, S.: Anomaly detection in sea traffic - a comparison of the Gaussian Mixture Model and the Kernel Density Estimator, 12th International Conference on Information Fusion, pp. 756-763. (2009)
[9] Pankaj, M. et al.: Long Short Term Memory Networks for Anomaly Detection in Time Series. In: 23rd European Symposium on Artificial Neural Networks, Computational Intelligence and Machine Learning (ESANN), pp. 89-94. (2015)
[10] Jonathan, G. et al.: Anomaly Detection in Cyber Physical Systems Using Recurrent Neural Networks. In: 8th International Symposium on High Assurances Systems Engineering (HASE) on IEEE, pp. 140-145. (2017)
[11] Sucheta, C., Lovekesh, V.: Anomaly detection in ECG time signals via deep long short-term memory networks, In: Data Science and Advanced Analytics (DSAA), pp. 1-7. IEEE, France (2015).
[12] Nikolay, L., Saeed, A., Ian, F.: Generic and Scalable Framework for Automated Time-series Anomaly Detection, Proceedings of the 21th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, pp. 1939-1947.(2015)
[13] Asrul Y., et al.: ARIMA Based Network Anomaly Detection, Communication Software and Network ICCSN '10, pp. 205-209. (2010)
[14] Rob, H., Yeasmin, K.: Automatic time series forecasting: the forecast package for R. Monash University, Department of Econometrics and Business Statistics, 2007.
[15] Ching, C., Yu, C., Yu, C.: Seasonal ARIMA forecasting of inbound air travel arrivals to Taiwan, Journal of Transportmetrica, vol. 5, pp. 125-140. (2009)
[16] Yantai, S. et al.: Wireless traffic modeling and prediction using seasonal ARIMA models, Communications ICC'03, vol. 3, pp. 1675-1679. IEEE (2003)
[17] Yuanyuan, W. et al.: Application of residual modification approach in seasonal ARIMA for electricity demand forecasting: A case study of China, Energy Policy, vol. 48, pp. 284-294. (2012)
[18] Cygnus Research International, https://www.cygres.com/OcnPageE/Glosry/SpecE.html
[19] David, D., Wayne, F.: Fuller Distribution of the Estimators for Autoregressive Time Series with a Unit Root, vol. 74, no. 366a, pp. 427-431. Journal of the American Statistical Association (2012)
[20] Robert, C. et al.: STL: A Seasonal-Trend Decomposition Procedure Based on Loess. Journal of Official Statistics, vol. 6, pp. 3-73. (1990)
[21] Mills, T.: Time Series Techniques for Economists, Cambridge University Press (1990)
[22] The Numenta Anomaly Benchmark, https://github.com/numenta/NAB

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-2 >



Threat Modeling and Analysis of Voice Assistant Applications

Geumhwan Cho[1], Jusop Choi[1], Hyoungshick Kim[1(✉)], Sangwon Hyun[2], and Jungwoo Ryoo[3]

[1] Sungkyunkwan University, Seoul, South Korea
{geumhwan,cjs1992,hyoung}@skku.edu
[2] Chosun University, Gwangju, South Korea
shyun@chosun.ac.kr
[3] Pennsylvania State University, Altoona, USA
jryoo@psu.edu

Abstract. Voice assistant is an application that helps users to interact with their devices using voice commands in a more intuitive and natural manner. Recently, many voice assistant applications have been popularly deployed on smartphones and voice-controlled smart speakers. However, the threat and security of those applications have been examined only in very few studies. In this paper, we identify potential threats to voice assistant applications and assess the risk of those threats using the STRIDE and DREAD models. Our threat modeling demonstrates that generic voice assistants can potentially have 16 security threats. To mitigate the identified threats, we also discuss several defense strategies.

Keywords: Voice assistant · Threat modeling · STRIDE · DREAD

1 Introduction

Voice assistant is a software program that helps users to interact with services (e.g., search engine) and applications (phone application) using voice commands with a more intuitive and convenient user interface mechanism. In general, voice assistant application runs as a background process and can be activated by using a reserved voice command (e.g., "Hey, Siri" and "Alexa"). Popular voice assistants including Siri (Apple), Alexa (Amazon) and Now (Google) help people shop online, send instant messages, and make phone calls, all through voice commands. However, to our knowledge there is no study analyzing security threats to voice assistants through a threat modeling process. Only a few studies experimentally demonstrated that commercial voice assistant applications are vulnerable to various forms of voice presentation attacks (e.g., [4,11]).

The goal of this paper is to identify potentially serious security threats to voice assistants and suggest several mitigation techniques to mitigate them. We first identify what threats exist and how risky the threats are by using the Security Development Lifecycle (SDL) threat modeling tool [10] that systemically

© Springer Nature Switzerland AG 2019
B. B. Kang and J. Jang (Eds.): WISA 2018, LNCS 11402, pp. 197–209, 2019.
https://doi.org/10.1007/978-3-030-17982-3_16

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

and the characteristics are unique. In the cloud computing, the accuracy of the voiceprint authentication achieved 3.2% in FRR (False Reject Rate) [13].

The voiceprint method is vulnerable to recorded voice. Therefore, voice assistants have to use the liveness detection method. The liveness detection calculates phoneme localization with two microphones. Through the liveness detection method, the voice assistant can distinguish whether the input voice is from the user in real time or replayed. Zhang et al. [12] achieved over 99% accuracy and under 1% EER (Equal Error Rate).

To mitigate the denial of service attack of Sect. 4.2, limiting availability in data flows is required. That is, the voice assistant has to input the audible hertz sounds (e.g., 20–20,000 Hz) using signal processing for low pass filter. If the voice assistant only accepts the human audible sound ranging from 20 to 20,000 Hz, it is easier to detect anomalies. DoS attacks can be mitigated by limiting the number of the input data flows and filtering malformed data.

The simplest way to prevent the information disclosure in Sect. 4.3 is the encryption of data flows, such as SSL/TLS network protocols. However, imperfect encryption can still lead to information leakages. Many Android apps use SSL/TLS to protect their sensitive information. However, the sensitive data protected by SSL/TLS was vulnerable to Man-in-the-Middle attacks because some developers often used incorrect options or implementations [9]. In addition, the HTTPS protocol which is popularly used in protecting home banking, e-commerce, and e-procurement was vulnerable to Man-in-the-Middle attacks when the attacker had access to the victim's network [3] (Table 2).

The other threats can also be handled by a variety of mitigation methods. According to a given situation and capabilities, the mitigation methods should be properly chosen and implemented. Unsurprisingly, mitigation methods are not secure forever. Therefore, threat modeling analysts should periodically analyze possible threats and prepare proper strategies to mitigate those threats.

6 Conclusion

This paper analyzed potential security threats for voice assistant systems and suggested several mitigation strategies to reduces the risk of the identified threats through threat modeling analysis that has been widely used in the field of information security. Based on the threat analysis results, we also presented several attack scenarios. Finally, we proposed several practical defense strategies to mitigate the identified threats. In future work, we will implement the discovered attacks against real-world voice assistant systems to show their feasibility.

Acknowledgments. This work was supported in part by the ITRC (IITP-2018-2015-0-00403) and the NRF (No. 2017K1A3A1A17092614). The authors would like to thank all the anonymous reviewers for their valuable feedback.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-3 >



FuzzBuilder: Automated building greybox fuzzing environment for C/C++ library

Joonun Jang
Samsung Research
Seoul, Republic of Korea
joonun.jang@samsung.com

Huy Kang Kim
Korea University
Seoul, Republic of Korea
cenda@korea.ac.kr

ABSTRACT

Fuzzing is an effective method to find bugs in software. Many security communities are interested in fuzzing as an automated approach to verify software security because most of the bugs discovered by fuzzing are related to security vulnerabilities. However, not all software can be tested by fuzzing because fuzzing requires a running environment, especially an executable. Notably, in the case of libraries, most of the libraries do not have a relevant executable in practice. Thus, state-of-the-art fuzzers have a limitation to test an arbitrary library. To overcome this problem, we propose *FuzzBuilder* to provide an automated fuzzing environment for libraries. *FuzzBuilder* generates an executable that calls library API functions to enable library fuzzing. Moreover, any executable generated by *FuzzBuilder* is compatible with existing fuzzers such as AFL. We evaluate the overall performance of *FuzzBuilder* by testing open source libraries. Consequently, we discovered unknown bugs in libraries while achieving high code coverage. We believe that *FuzzBuilder* helps security researchers to save both setup cost and learning cost for library fuzzing.

CCS CONCEPTS

• **Security and privacy → Software security engineering**;

KEYWORDS

greybox fuzzing, library fuzzing, software development, unit test

ACM Reference Format:
Joonun Jang and Huy Kang Kim. 2019. FuzzBuilder: Automated building greybox fuzzing environment for C/C++ library. In *2019 Annual Computer Security Applications Conference (ACSAC '19), December 9–13, 2019, San Juan, PR, USA.* ACM, New York, NY, USA, 11 pages. https://doi.org/10.1145/3359789.3359846

1 INTRODUCTION

Greybox fuzzing is a test method used to find bugs residing in software. Security researchers often use greybox fuzzing as an automated method to find security flaws in programs because most of the bugs found by greybox fuzzing can be related to security vulnerabilities. Until today, greybox fuzzing has been researched extensively, and many fuzzers have been implemented, such as AFL [35], AFLFast [13], AFLGo [12], VUzzer [24], T-Fuzz [23], Angora [14], and CollAFL [17]. The fuzzers showed their performance by discovering bugs in programs. Table 1 shows the number of unknown bugs found by each greybox fuzzer.

Table 1: The number of unknown bugs found by greybox fuzzers

greybox fuzzer	# of bugs
AFL	more than 370
AFLFast	12
AFLGo	39
VUzzer	8
T-Fuzz	3
Angora	175
CollAFL	157

Greybox fuzzing is well known for its advantage of being able to test with only binaries. However, most of the bugs in Table 1 are in open source software. This implies that greybox fuzzing is also useful when source code is available. Therefore, it is necessary to apply greybox fuzzing to a development process to prevent security vulnerabilities at an early stage. In practice, large IT companies such as Google and Microsoft enforce fuzzing in their development process. Notably, Google developed *OSS-Fuzz* [27], which is a greybox fuzzing service platform for open source software.

Greybox fuzzing requires an execution of a program. This implies that it is not easy to apply greybox fuzzing to libraries. Nonetheless, libraries need to be tested with greybox fuzzing, as vulnerabilities in libraries potentially affect many programs by being reused.

A simple approach for fuzzing a library is to generate an executable that calls library API functions and then fuzzing the generated executable. The executable enables library fuzzing by calling library API functions with arbitrary input values generated by a fuzzer. To this end, source code for an executable should be written manually. Generally, writing code can be done by developers or testers.

Developers can write code with in-depth knowledge of a library. Thus, a library API can be used correctly, which helps to reduce false positive bugs. Additionally, various combinations of library API functions can be used, which helps to achieve high code coverage.

However, writing code is an additional task for developers. Furthermore, it is difficult for developers to write code for fuzzing

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
ACSAC '19, December 9–13, 2019, San Juan, PR, USA
© 2019 Association for Computing Machinery.
ACM ISBN 978-1-4503-7628-0/19/12…$15.00
https://doi.org/10.1145/3359789.3359846

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Some researches suggested new input generation mechanisms to solve this problem: Angora[14], VUzzer[24], lafintel [9], steelix [22], eclipser [15], TIFF [19], memfuzz [16]. Additionally, there are hybrid approaches that use both fuzzing and symbolic execution [30, 34]. However, it is still useful to provide seeds because they help to achieve sufficient code coverage without any runtime resources, in contrast to the above mechanisms.

Fuzzers should find bugs as many and as fast as possible to increase the efficiency of greybox fuzzing. One of the ways to achieve this is increasing the number executed instructions during fuzzing. If more instructions are executed, then a larger part of code is visited, thereby increasing opportunities to discover bugs. Thus, the number of visited code lines is measured to evaluate the performance of greybox fuzzing along with the number of discovered bugs.

Most of the greybox fuzzers require an executable and the executable should be guaranteed to terminate within a short time. Greybox fuzzers should execute a program with as many input values as possible to explore various program paths. Thus, execution time is significant as it determines how many input values can be tested within a specific time. These make it challenging to apply greybox fuzzing to some programs, such as a library or a server program which is waiting a request. Hence, an additional executable should be prepared to apply greybox fuzzing and additional executables should include calling functions that are defined in a target program and terminate within a short time.

5.2 OSS-Fuzz

OSS-Fuzz is a fuzzing service framework that was managed by Google. This framework was released to share open source projects with a successful fuzzing experience of chrome component. Until today, *OSS-Fuzz* has tested more than 100 open source projects and has found more than 10000 bugs.

To register an open source project to *OSS-Fuzz*, developers in charge of a project should write code for fuzzing. The written source code is stored in *OSS-Fuzz*, and then it is distributed to Clusterfuzz [11] environment. Clusterfuzz is a distributed environment where fuzzing is performed. *OSS-Fuzz* uses *Libfuzzer* as a fuzzer.

Libfuzzer is a greybox fuzzer for a library, that allows developers to write code for fuzzing by using a simple interface. The written source code is built to an executable with *Libfuzzer* code. Fuzzing starts by executing this executable.

Although *Libfuzzer* provides a way for library fuzzing, source code for fuzzing should be written manually by one who has in-depth knowledge of a target project. These make it challenging to use *Libfuzzer* in practice because it requires an understanding of a library to write code correctly, understanding of fuzzing to write code that is fuzzing-friendly, and maintenance of source code.

6 DISCUSSION

The followings are discussion topics for generating an executable more precisely.

Automated specification of FA. FA is chosen manually in this study. User intervention is required to provide information about FA to *FuzzBuilder*. Fortunately, it is not difficult to select them because various information is available in the form of manual or example code. However, as future work, we will automate this functionality for a fully automated process.

Optimization of generated executable. *FuzzBuilder* eliminates unnecessary test functions when generating executables from unit tests. However, there are many instructions that are not related to fuzzing in generated executables. It is because most of the instructions were copied from unit tests directly. Further, even necessary test functions may include calls to library API functions that are not directly related to FA. These unnecessary parts slow down execution speed, which affects fuzzing performance. As future work, we will consider a transformation of unit tests to generate a more efficient executable for library fuzzing.

Errors in unit test. Unit test functions that implement test cases may use an instruction to terminate program forcefully, such as *assert* and *abort* for handling unexpected results. Some test functions do not consider an unexpected value; hence, many bugs may arise if an unexpected value is given. Unfortunately, most of the values from fuzzers are an unexpected value. Thus, these cases frequently occur during fuzzing and can cause two problems. First, because of forced termination, most of the instructions in unit tests may not be executed sufficiently. Second, fuzzers will recognize such termination as a bug. As bugs in test code may not be a bug of a target library, this can be considered as a false alarm. One of the advantages of greybox fuzzing is low false alarms. Therefore, this topic should be considered to get benefits of greybox fuzzing.

Expansion of input value types. *FuzzBuilder* considers an input parameter type as char pointer. This data type is sufficient to show the performance of the proposed method. This is because many functions for parsing, a primary test target of greybox fuzzing, receive input values in the form of char pointer data type. Further, most of the fuzzing in *OSS-Fuzz* use this data type for passing random input to a library. However, input value can be a string data type in C++, or any user-defined type. Fuzzers have a higher chance to explore various paths of libraries if more data types are supported.

7 CONCLUSION

In this study, we proposed a method for applying greybox fuzzing to a library. We implemented this method as a tool, *FuzzBuilder*, which is based on LLVM framework. Executables generated by *FuzzBuilder* can be used in any other fuzzers such as AFL. This method helps developers by eliminating writing and maintenance of source code for fuzzing. Additionally, this method helps testers to perform greybox fuzzing without in-depth knowledge of a target program. Further, seeds can be generated by this method for efficient greybox fuzzing. Thus, *FuzzBuilder* helps to enhance software security by applying greybox fuzzing to various types of a program easily.

ACKNOWLEDGMENTS

This work was supported under the framework of international cooperation program managed by National Research Foundation of Korea(No.2017K1A3A1A17092614).

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-4 >

Show Me Your Account: Detecting MMORPG Game Bot Leveraging Financial Analysis with LSTM

Kyung Ho Park
Graduate School of Information Security
Korea University
Seoul, Republic of Korea
kyungho96@korea.ac.kr

Eunjo Lee
Data Center
NCSOFT
Seongnam, Republic of Korea
gimmesilver@ncsoft.com

Huy Kang Kim
Graduate School of Information Security
Korea University
Seoul, Republic of Korea
cenda@korea.ac.kr

arXiv:1908.03748v1 [cs.CR] 10 Aug 2019

***Abstract*—With the rapid growth of MMORPG market, game bot detection has become an essential task for maintaining stable in-game ecosystem. To classify bots from normal users, detection methods are proposed in both game client and server-side. Among various classification methods, data mining method in server-side captured unique characteristics of bots efficiently. For features used in data mining, behavioral and social actions of character are analyzed with numerous algorithms. However, bot developers can evade the previous detection methods by changing bot's activities continuously. Eventually, overall maintenance cost increases because the selected features need to be updated along with the change of bot's behavior.**

To overcome this limitation, we propose improved bot detection method with financial analysis. As bot's activity absolutely necessitates the change of financial status, analyzing financial fluctuation effectively captures bots as a key feature. We trained and tested model with actual data of Aion, a leading MMORPG in Asia. Leveraging that LSTM efficiently recognizes time-series movement of data, we achieved meaningful detection performance. Further on this model, we expect sustainable bot detection system in the near future.

***Index Terms*—MMORPG, Game bot detetion, LSTM neural networks**

I. Introduction

Online game plays a huge role in modern leisure. With 44.6 billion US dollars of market share estimated by 2022, Massively Multiplayer Online Role-Playing Game (MMORPG) takes significant position in global market [1]. MMORPG is a game genre that users have own characters to play various activities in a virtual world. They combat with monsters, accumulate game assets, even chat or date with others. As various activities exist, in-game ecosystem shows similar pattern as a real world. [2] Interestingly, people in a real world and MMORPG users pursue a common goal: a wealth. In a real world, diligent workers accumulate wealth from salaries. Similarly, heavy users in a virtual world gather game assets and become wealthy. Wealth in a game makes character stronger, and stronger character gives more fun to player. Reflecting that players want better game assets, some corporate-like entities even created Real Money Trading (RMT), a transaction of game assets with real money [3]. However, money-related issues created illegal activities. Some malicious users developed automated program, called a game bot.

Game bot is an automated program playing game autonomously instead of human users. Without any touch of human, bots automatically move around virtual world. They behave in programmed way, repetitively do patterned actions to collect game asset. Bots normally gather wealth faster than normal players because program does not get tired [4]. Leveraging this efficiency, corporate-like entities called Gold Farmer Group (GFG) started to operate thousands of bots at the same time. GFGs collect enormous amount of in-game cash or rare items, and sell it to buyers with real money [5].

Game companies should detect these bots and provide adequate actions because bots create deprivation of normal users. If some users purchase items with real money and become powerful easily, normal users would depreciate their effort of growing characters. Moreover, in-game economy goes unstable with affluent assets created by bots. GFG especially collects a huge amount of game assets, and creates an inflation and overflow of asset. Inflated assets easily break balance among users and skew the game design. As a result, bots make gaming experience of normal users feel depreciated, leave the game, and eventually create loss to game company.

To counteract malicious activities of bots, academia and industry have developed bot detection methods in two main streams: client-side detection and server-side detection. Client-side method detects bots by implementing challenge-response program or security solution. For challenge-response method, game client asks question that humans can easily solve. As bots are not programmed to answer unexpected questions, characters with wrong response are classified as bots. Security solutions such as GameGuard or Warden are specially developed client-side program for bot detection. However, both methods are inadequate to apply at industry level. Challenge-response methods like CAPTCHA excessively drop user's game experience, as they feel disturbed during the play. Security solutions frequently collide with vaccine programs, create crash of the system [6].

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

record its performance with four metrics: accuracy, precision, recall, and F1-score.

IV. Experiment Result

To gain enough records of training, we separated monthly dataset into weekly basis. We randomly mixed data, and performed 10-fold cross validation for assured result. Table V shows the result of experiment with evaluation metrics.

TABLE V: Bot detection experiment result

Experiment	Accuracy	Precision	Recall	F1 Score
Week 1	0.9494	0.9385	0.9759	0.9490
Week 2	0.9401	0.9168	0.9831	0.9488
Week 3	0.9487	0.9237	0.9886	0.9551
Week 4	0.9509	0.9103	0.9861	0.9476
Average	0.9473	0.9223	0.9834	0.9501

We interpret trained model detects bots with reasonable performance. Experiment result shows relatively lower precision than recall, implicating existence of false positive error. Considering characteristics of bot detection, we evaluate this error is allowable. One of primary goals of bot detection is making a list of doubtful accounts rather than blocking accounts. If game company blocks normal user showing similar pattern as bots, it directly generates dissatisfaction or even annoy of user. Thus, bot detection prioritizes figuring out doubtful characters rather than direct blocking. In this viewpoint, we evaluate our model efficiently detects bots only with a few financial features. We expect nsembling our model with other methods would achieve more precise detection, which is further illustrated in following Discussion section.

V. Discussion

1) Ensembling for precise detection: Ensembling our model with other methods would build powerful bot detection system. To hedge risk of false positive error, bots are not decided by a single detection method. To reduce false positive errors, even human-based detection method in the past required many skilled observers. In similar way, we believe more detection methods are required to collaborate for industry-level application. For features of ensembling, we would leverage other necessary conditions of game bots. Transaction with other characters or Non-Player Characters (NPC) can be utilized as features. Considering more information of bots, detection model would be improved resulting powerful performance.

2) Applicability into other MMORPGs: On following research, we would apply this model in other MMORPGs. With the growth of game industry, game companies operate multiple games at the same time. To put in game company's shoes, running different detection methods for different games is cost-ineffective. If detection method is applicable in multiple games, it creates economies of scale. We interpret features used in our model are commonly found. Previous research on bot network also suggested financial features are common traces of modern MMORPGs [14]. Therefore, we expect our model is applicable in other games to be used in industry-level practices.

VI. Conclusion

In this work, we proposed employment of financial analysis to game bot detection in real MMORPG ecosystem. Previous studies showed efficient bot detection methods, but underlying problem was variance of bot's activity. If bot developers change activity or make them act like normal users, it becomes resource-consumable to update detection methods. To overcome this limitation, we utilized financial information of characters which are necessary conditions of bot's activity. Considering purpose of bots related to RMT, patterned change of financial status is inevitable for bot characters. Through experiments, our results reveal that financial information are highly related to bot's activity, suggesting effectiveness at bot detection. Leveraging time-series dynamics of financial data, our LSTM neural networks efficiently captured pattern of bots. We validated this efficiency with actual game data of Aion, a famous MMORPG developed by NCSOFT.

Our detection model establishes essential contributions. First and foremost, our model establishes sustainable detection method as bots are hard to evade patterned financial changes. Moreover, our model is applicable into other games as utilized features are common in modern MMORPG. Unlike macroscopic analysis of bot network, LSTM neural network is eligible to detect individual characters to generate list of doubtful characters. Finally, our model enhances security of detection as LSTM neural network is a black-box model making bot developers hard to predict detection thresholds. There still exists a room for improvement. With ensembling our model with other necessary conditions of game bot, we would like to achieve qualified bot detection system with powerful performance. To assure generality of our model, we plan to check model's performance on other actual MMORPG data. In pursuit of sustainable, and general bot detection, we will further research on financial analysis in MMORPG ecosystem.

Acknowledgements

This work was supported under the framework of international cooperation program managed by National Research Foundation of Korea(No.2017K1A3A1A17092614).

References

[1] Technavio Research, "Global MMO Games Market 2018-2022," "https://www.apnews.com/9e7c206726784 1efb0fb22b2bd9398e3", 2018, [Online; Last Access 27 May 2019].

[2] E. Castronova, "Virtual worlds: A first-hand account of market and society on the cyberian frontier," *CESinfo Working Paper Series*, 2001.

[3] J.-S. Huhh, "Simple economics of real-money trading in online games," 2008.

[4] E. Lee, J. Woo, H. Kim, A. Mohaisen, and H. K. Kim, "You are a game bot!: Uncovering game bots in mmorpgs via self-similarity in the wild." in *NDSS*, 2016.

[5] M. A. Ahmad, B. Keegan, J. Srivastava, D. Williams, and N. Contractor, "Mining for gold farmers: Automatic detection of deviant players in mmogs," in *2009 International Conference on Computational Science and Engineering*, vol. 4. IEEE, 2009, pp. 340–345.

[6] J. Woo and H. K. Kim, "Survey and research direction on online game security," in *Proceedings of the Workshop at SIGGRAPH Asia*. ACM, 2012, pp. 19–25.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-5 >

Forecasting the Electric Network Frequency Signals on Power Grid

Woorim Bang* and Ji Won Yoon†
Graduate School of Information Security, Korea University, Seoul, Republic of Korea
{*wrbang, †jiwon_yoon}@korea.ac.kr

***Abstract*—The power grid, which is one of the important infrastructures, has a very challenging issue to stably manage electric power. The Electrical Network Frequency (ENF) which is the supply frequency on the power grid, however, has small variations near a constant frequency over time. In this paper, we studied the feasibility of predicting ENF values to operate the power grid reliably. To forecast ENF values, we analyzed the ENF signals by using auto-correlation and correlation coefficient. Based on the analysis results, we employed two approaches to forecast ENF values using a kernel regression model with correlation coefficient and autoregressive moving average model. To evaluate the accuracy of the proposed prediction algorithm, we experimented ENF data for 29 days in three power grids of the United States; the Eastern, the Western, and the Texas power grid. The results of our suggested methods presented the remarkable performance in forecasting ENF signals.**

***Index Terms*—Prediction, Electric Network Frequency, Data Mining**

I. Introduction

Modern society is hard to imagine without electricity. The electricity has become an essential part of our society; health and welfare, communications; finance; transportation; food and water supply; heating, cooling and lighting; computers and electronics; commercial enterprise [1]. Stable operation of the electrical power grid is challenging and demanding because of the electrical characteristic and the technical difficulties [1]. Besides the electrical attributes, the power grid is exposed to various threats such as cyber attack, natural disaster and equipment malfunction which monitor and control electricity.

An imbalance between power generation and demand, or various threats on the power grid can cause the blackout. On August 14, 2003, North American has experienced a major blackout. The power was not restored for 4 days in some parts of the United States. As a result of the grand-scale blackout, damages in the United States estimates range between $4 billion and $10 billion (U.S. dollars). In Canada, the gross domestic product was 0.7% down in August and manufacturing shipments in Ontario suffered $2.3 billion (Canadian dollars) losses [1]. Likewise, widespread electrical outages result in not only economic decline but also threatening the lives of people. The outage was due to an imbalance in the electric power grid and lack of effective real-time diagnosis, among others [2].

The Electrical Network Frequency (ENF) is the utility frequency of the power grids. The ENF should be monitored persistently to keep a stable state on the power grid. Monitoring the frequency of the power systems helps to predict system failures and prevent wide-area blackouts [3]. The power grid consists of numerous equipment and control sensors. Continuously managing devices to operate properly are many difficulties in reality due to aging and malfunction. Hence, the additional application is demanded which helps to detect the system abnormal or device failure.

Dong et al. [3] stated that the prediction of frequency is required for two reasons. First of all, we are able to restrain node failure by predicting the frequency values. We can recognize whether the power system is abnormal or not by prediction values. Secondly, when the ENF signal collection system installed in some areas malfunctions, we can recognize the reason whether a measurement problem or the presence of a spoofing signal during data transmission by compared to the predicted values and the collected data [3]. In this paper, we suggested to apply correlation kernel regression and autoregressive moving average model to forecast ENF signals.

To predict the ENF signal, the characteristics of the ENF signal should be analyzed. Because of the features that the ENF value varies with time and location, the studies to estimate the location and time using ENF have been actively conducted during several years [4, 5]. There have been a few attempts to analyze the ENF pattern [6] and to set the frequency range for operating the grid reliably [1]. Compared to related works, our work yields ENF pattern analysis results and suggest the ENF prediction algorithm which can flexibly apply to operate reliable power grid systems. The work by Grigoras [6] tries to analyze the pattern of ENF signals with 3D-spectrogram and 2D-spectrogram. It found only the presence of the pattern during working days, not the predictable pattern such as shapes or values. In our research, we not only find out a period of ENF signals but also propose a prediction algorithm with meaningful results. Furthermore, the report by the North America Electric Reliability Corporation [1] presented the normal and abnormal frequency ranges to operate the systems in reliable conditions. However, it has difficulty in proactively response until the frequency reaches the threshold. If the ENF signals can be predicted, we can observe abnormal indications and take appropriate actions before reaching the threshold.

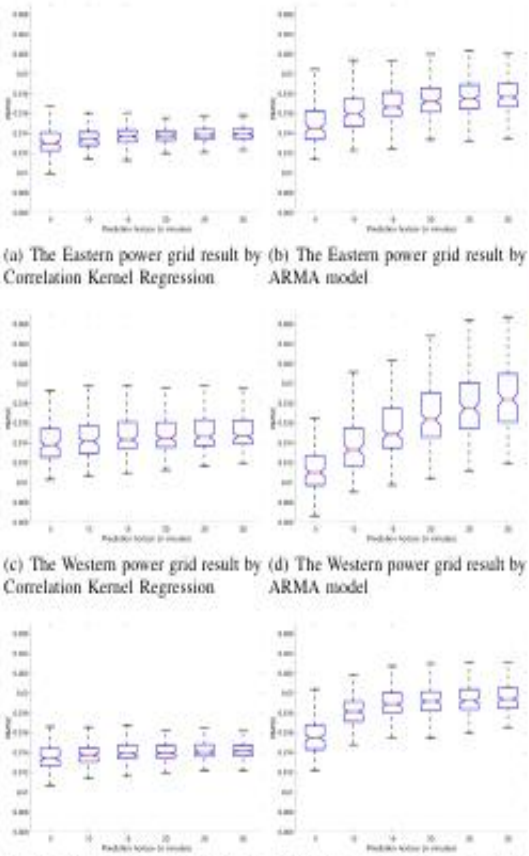
Our main contributions are summarized as follows:

- We researched on analyzing the pattern of the ENF signals and forecasting ENF signals. Therefore, we can stably forecast long term, 30 minutes ahead, ENF signals.

†Corresponding author.

Authorized licensed use limited to: Korea University. Downloaded on March 14,2021 at 10:34:43 UTC from IEEE Xplore. Restrictions apply.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



(a) The Eastern power grid result by Correlation Kernel Regression

(b) The Eastern power grid result by ARMA model

(c) The Western power grad result by Correlation Kernel Regression

(d) The Western power grad result by ARMA model

(e) The Texas power grid result by Correlation Kernel Regression

(f) The Texas power grid result by ARMA model

Fig. 4: The figure shows the RMSE result of forecasting the ENF values by applying the correlation kernel regression method and the AMRA model to each power grid; the Eastern, the Western and the Texas power grid. The result of the correlation kernel regression method is (a), (c) and (e). The result of the ARMA model is (b), (d) and (f).

using online multimedia to collect power system anomaly data. In our future work, when data is collected when a power system failure occurs, we will investigate the possibility that our proposed method can help to detect the power system anomalies.

VIII. Conclusions

In this paper, we analyzed the ENF signals and experimented forecasting the ENF values from three power grids (the Eastern, the Western and the Texas Interconnection) in the United States. By analyzing the ENF signals, we found out that the ENF signals have a high correlation by a day. We proposed two main algorithms which are the correlation kernel regression and autoregressive moving average model to forecast long-term ENF signals. The experiment of correlation kernel regression results the notable performance of forecasting ahead 30 minutes of the ENF values based on past one day ENF values compared to autoregressive moving average model. Although we only shows the possibility of predicting ENF values, our proposed approaches could also be applied to early warning of an impending attack which could thwart or blunt the impact of the physical damage on power systems. In our future work, we plan to analyze more power grids to confirm and generalize our approaches with common characteristics of the power grid.

Acknowledgment

This work was supported under the framework of international cooperation program managed by National Research Foundation of Korea(No.2017K1A3A1A17092614).

References

[1] US-Canada Power System Outage Task Force, S. Abraham, H. Dhaliwal, R. J. Efford, L. J. Keen, A. McLellan, J. Manley, K. Vollman, N. J. Diaz, T. Ridge, et al. *Final report on the august 14, 2003 blackout in the united states and canada: Causes and recommendations*. US-Canada Power System Outage Task Force, 2004.

[2] X. Li, X. Liang, R. Lu, X. Shen, X. Lin, and H. Zhu. Securing smart grid: cyber attacks, countermeasures, and challenges. *IEEE Communications Magazine*, 50(8), 2012.

[3] J. Dong, X. Ma, S. M. Djouadi, H. Li, and Y. Liu. Frequency prediction of power systems in fnet based on state-space approach and uncertain basis functions. *IEEE Transactions on Power Systems*, 29(6):2602–2612, 2014.

[4] Y. Jeon, M. Kim, H. Kim, H. Kim, J. H. Huh, and J. W. Yoon. I'm listening to your location! inferring user location with acoustic side channels. In *Proceedings of the 2018 World Wide Web Conference on World Wide Web*, pages 339–348. International World Wide Web Conferences Steering Committee, 2018.

[5] G. Hua, G. Bi, and V. LL Thing. On practical issues of electric network frequency based audio forensics. *IEEE Access*, 5:20640–20651, 2017.

[6] C. Grigoras. Applications of enf criterion in forensic audio, video, computer and telecommunication analysis. *Forensic science international*, 167(2-3):136–145, 2007.

[7] J. E. Tate and T. J. Overbye. Line outage detection using phasor angle measurements. *IEEE Transactions on Power Systems*, 23(4):1644–1652, 2008.

[8] J. E. Tate and T. J. Overbye. Double line outage detection using phasor angle measurements. In *2009 IEEE Power & Energy Society General Meeting*, pages 1–5. IEEE, 2009.

[9] J. Zhu and A. Abur. Improvements in network parameter error identification via synchronized phasors. *IEEE Transactions on Power Systems*, 25(1):44–50, 2009.

[10] Z. Zhong, C. Xu, B. J. Billian, L. Zhang, S.-JS Tsai, R. W. Conners, V. A. Centeno, A. G. Phadke, and Y. Liu. Power system frequency monitoring network (fnet) implementation. *IEEE Transactions on Power Systems*, 20(4):1914–1921, 2005.

[11] B. Qiu, L. Chen, V. Centeno, X. Dong, and Y. Liu. Internet based frequency monitoring network (fnet). In *Power Engineering Society Winter Meeting, 2001. IEEE*, volume 3, pages 1166–1171. IEEE, 2001.

[12] Y. Zhang, L. Chen, Y. Ye, P. Markham, J. Bank, J. Dong, Z. Yuan, Z. Lin, and Y. Liu. Visualization of wide area measurement information from the fnet system. In *Power and Energy Society General Meeting, 2011 IEEE*, pages 1–8. IEEE, 2011.

[13] Power Information Technology Laboratory at the University of Tennessee. Fnet/grideye web display. http://fnetpublic.utk.edu/index.html, 2018. Online; accessed 30 April 2018.

[14] Mathieu Sinn, Ji Won Yoon, Francesco Calabrese, and Eric Bouillet. Predicting arrival times of buses using real-time gps measurements. In *2012 15th International IEEE Conference on Intelligent Transportation Systems*, pages 1227–1232. IEEE, 2012.

[15] Peter Whittle. *Hypothesis testing in time series analysis*, volume 4. Almqvist & Wiksells, 1951.

[16] G. E. Box, G. M. Jenkins, G. C. Reinsel, and G. M. Ljung. *Time series analysis: forecasting and control*. John Wiley & Sons, 2015.

[17] Michael A. VanPutte John O. Everett. Rapid attack detection, isolation and characterization systems(radics), 2017. https://arpa-e.energy.gov/sites/default/files/F_GD_Speaker3_VanPutte_RADICS.pdf.

Authorized licensed use limited to: Korea University. Downloaded on March 14,2021 at 10:34:43 UTC from IEEE Xplore. Restrictions apply.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-6 >

Automated Cash Mining Attacks on Mobile Advertising Networks

Woojoong Ji[1(✉)], Taeyun Kim[1], Kuyju Kim[2], and Hyoungshick Kim[1]

[1] Sungkyunkwan University, Suwon, Republic of Korea
{woojoong,taeyun1010,hyoung}@skku.edu
[2] AhnLab, Seongnam, Republic of Korea
kuyju.kim@ahnlab.com

Abstract. Rewarded advertisements are popularly used in the mobile advertising industry. In this paper, we analyze several rewarded advertisement applications to discover security weaknesses, which allow malicious users to automatically generate in-app activities for earning cash rewards on advertisement networks; we call this attack *automated cash mining*. To show the risk of this attack, we implemented automated cashing attacks on four popularly used Android applications (`Cash Slide`, `Fronto`, `Honey Screen` and `Screen Stash`) with rewarded advertisements through reverse engineering and demonstrated that all the tested reward apps are vulnerable to our attack implementation.

1 Introduction

In rewarded advertisement services, the most important security issue is the detection of (artificially created) fraudulent user engagement activities that have no intention of generating value for the advertiser [6]. Recently, there have been few studies [2,3] that analyze the potential security risks in this domain. Cho et al. [2] demonstrated that six Android advertising networks were vulnerable to automated click fraud attacks through the Android Debug Bridge (ADB).

In this paper, we extend Cho et al's attack model of relying on automated input sequences at the user interface level into a more sophisticated attack called *automated cash mining*, which allows an attacker to automatically generate in-app activities at the network packet level. This is a significant advancement from previous studies [2,3] that merely showed potential weaknesses in rewarded advertisement applications.

To show the feasibility of our attack, we analyzed four popularly used reward apps (`Cash Slide`, `Fronto`, `Honey Screen` and `Screen Stash`) by reverse engineering and packet analysis, and we found that all tested reward apps are vulnerable to automated cash mining attacks.

2 Mobile Advertising Network

To provide a better understanding of automated cash mining attacks, we first present the typical model of a mobile advertising network for reward applications.

© Springer Nature Switzerland AG 2019
J. Jang-Jaccard and F. Guo (Eds.): ACISP 2019, LNCS 11547, pp. 679–686, 2019.
https://doi.org/10.1007/978-3-030-21548-4_40

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

case of a normal user, the amount of rewards received for three days increased by 3,196 times, 9.3 times, 15 times, 26 times when the automated cash mining attack was launched. Further, compared to the case of a normal user, the number of advertisements with rewards increased by 1,057 times, 3.3 times, 0.9 times, 1.2 times during the same time period. As a result, we confirmed that we could obtain rewards with 0.9 times to 1,057 times more efficiency using automated cash mining attack.

6 Conclusion

In this paper, we analyzed the security flaws present in mobile advertising networks. We introduced automated cash mining attacks to automatically generate in-app activities at the network packet level. While previous studies [2,3] have only demonstrated the feasibility of automated attacks by emulating human click behaviors at the UI level, we implemented the first *fully automated* and working tool that is capable of generating reward request messages in a massive manner.

In our attack experiments, we found that all tested adverting networks failed to detect our automated cash mining attacks. This could be explained from the economic incentives of a security failure in current mobile adverting network models. We expect that in automated cash mining attacks, the advertisers incur the financial losses rather than the advertising networks. To make matters worse, the success of automated cash mining attacks is not a loss in an advertising network but rather a profit. Because of this disincentive, we surmise that adverting networks might not be sufficiently motivated to detect automated cash mining attacks. To fix this problem, we suggest that the interaction between adverting networks and reward applications should be audited and monitored regularly by an external third party in order to properly regulate adverting networks.

Acknowledgments. This work was supported in part by NRF of Korea (NRF-2017K1A3A1A17092614) and the ICT Consilience Creative support program (IITP-2019-2015-0-00742).

References

1. Fiddler Extension (Requset to Code). http://www.chadsowald.com/software/fiddler-extension-request-to-code. Accessed 28 Feb 2019
2. Cho, G., Cho, J., Song, Y., Choi, D., Kim, H.: Combating online fraud attacks in mobile-based advertising. EURASIP J. Inf. Secur. **2016**(1), 2 (2016)
3. Crussell, J., Stevens, R., Chen, H.: Madfraud: investigating ad fraud in android applications. In: Proceedings of the 12th Annual International Conference on Mobile Systems, Applications, and Services (2014)
4. Enck, W., Octeau, D., McDaniel, P., Chaudhuri, S.: A study of android application security. In: Proceedings of the 20th USENIX Security Symposium (2011)
5. Evans, C., Palmer, C.: Certificate pinning extension for HSTS (2011). https://tools.ietf.org/html/draft-evans-palmer-hsts-pinning-00
6. Immorlica, N., Jain, K., Mahdian, M., Talwar, K.: Click fraud resistant methods for learning click-through rates. In: Deng, X., Ye, Y. (eds.) WINE 2005. LNCS, vol. 3828, pp. 34–45. Springer, Heidelberg (2005). https://doi.org/10.1007/11600930_5

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-7 >

2019 IEEE International Congress on Internet of Things (ICIOT)

Profiling-based classification algorithms for security applications in Internet of Things

*Eunil Seo, †Hyoungshick Kim, and ‡Tai-Myoung Chung
*Department of electrical and computer Eng., Sungkyunkwan University, Suwon, Korea
†‡College of software, Sungkyunkwan University, Suwon, Korea
{*seoei2, †hyoung, ‡tmchung}@skku.edu

***Abstract*—Due to the various types of network resources involved in the Internet of Things (IoT), it becomes challenging to detect security incidents and unexpected faults in IoT environments. The nature of network objects (e.g., system, user, service, and devices) is too various and changeable to predict objects' behaviors and to identify the best parameters for the machine learning model in order to detect anomalies against IoT protection. We propose a new profiling method called "Management Information Base for IoT (MIB-IoT)" by extending conventional MIB to a more generalized structure in order to represent not only the structured properties of network objects but also the best machine learning model for each network object in a systematic fashion. MIB-IoT profiles can be defined for various applications such as abnormal behavior detection, malicious behavior detection, and even data source identification. To demonstrate the feasibility of the proposed MIB-IoT, we apply various classification algorithms on datasets consisting of normal operation data, hardware fault data, and malicious data. The experiment results show that the classification algorithm using MIB-IoT is capable of achieving an accuracy of 99.81% for malicious behavior detection and an accuracy of 78.51% for data source identification respectively.**

***Keywords*-Machine learning, classification, abnormal behavior detection, Internet of Things (IoT), Management Information Base (MIB).**

I. Introduction

The systems involved in the Internet of things (IoT) network typically consist of numerous devices equipped with a variety of computing, power, sensor, and communication capabilities. Therefore, it is very difficult to conceptualize a universally working machine learning (ML) model across various IoT devices [1]. The features used in models and their behaviors can dynamically be changed with devices and applications.

To address this issue, we must consider the use of profiles to represent various IoT devices and applications as opposed to building a single universal ML model [2]. Specifically, we propose a new profiling method called "Management Information Base for IoT (MIB-IoT)" by extending conventional MIB [3] to a more generalized structure in order to systematically represent not only the structured properties of network objects but also the best ML model for each network object. Profiling is a useful technique for analyzing just a few samples when the samples can be grouped based on their different characteristics and behaviors [4].

As security attacks have evolved in complexity over time, naive rule-based detection techniques are becoming increasing limited in detecting new types of attacks. Our proposed profiling method is designed to incorporate various ML algorithms to better detect such new security attacks as well as data faults along with data sources in the IoT environment. Our contributions are summarized as follows:

1) To the best of our knowledge, this study is the first to consider the flexible structure of MIB-IoT involving ML algorithms in order to detect malicious behavior and identify data source in the IoT environment.
2) We presented how to build an MIB-IoT from selected ML algorithms against a service compromising regarding to HVAC (Heating,Ventilation, and Air Conditioning).
3) To show the feasibility of the proposed idea, we evaluated the performances of profiling-based classification algorithms with datasets consisting of a normal operation dataset, a hardware fault dataset, and a malicious dataset collected from 54 real-world sensors [5]; we also examined research on multiple ML algorithms for malicious behavior detection [6] and data source identification [7]. The experimental results indicate that our classification algorithm using MIB-IoT is capable of achieving an accuracy of 99.81% for malicious behavior detection (three classes) and an accuracy of 78.51% for data source identification (54 classes), respectively.

The remainder of this paper is organized as follows. In Section II, we discuss background information and related work. In Section III, we present the structure of MIB-IoT for profiling IoT devices and applications. In Section IV, we show the effectiveness of MIB-IoT based classification algorithms for malicious behavior detection and data source identification. In Section V, we introduce the MIB-IoT profiles to represent ML models for malicious behavior detection and data source identification. Finally, conclusions and further work are provided in Section VI.

II. Background

In this section, we explain the basic knowledge and terms that are required to understand the proposed system.

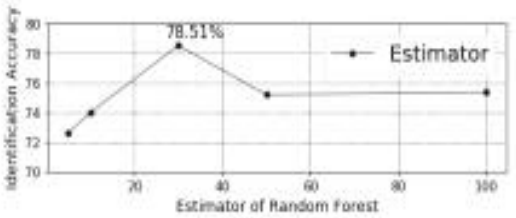
A. Profiling

Automated profiling involves different technologies (i.e., hardware), such as RFID-tags [8], biometrics, sensors, and computers, along with different techniques (i.e., software), such as data cleansing, data aggregation, and data mining. These technologies and techniques are integrated into profiling practices that allow for both the construction and application of the profiles; these profiles are then used to make

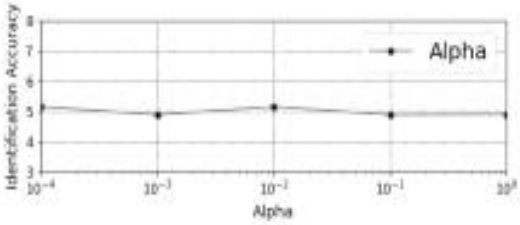
978-1-7281-2714-9/19/$31.00 ©2019 IEEE
DOI 10.1109/ICIOT.2019.00033

Authorized licensed use limited to: Korea University. Downloaded on March 14,2021 at 10:57:02 UTC from IEEE Xplore. Restrictions apply.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



(a) Random Forest model with different estimator.



(b) MLP model with different Alphas.

Fig. 7. Comparison between Random Forest model with different Estimators and MLP model with different alphas trained by a dataset consisting of normal operation data, hardware fault data, and malicious data

TABLE XII
RANDOM FOREST-BASED MIB-IOT FOR DATA SOURCE IDENTIFICATION.

HVAC(1).MIB-IoT(1): 1.3.6.1.4.1.100000.1.1.1		
HVAC(1).MIB-IoT(1).Property(4): 1.3.6.1.4.1.100000.1.1.1.4		
OID	Name	Value
1	Target	Data source identification
2	Machine Learning	Random Forest
3	Data List	Temp, Humidity, Light, Voltage, and Sensor ID
4	Best Parameter	Estimators: 30
5	Target Accuracy	78.51%

conventional MIB to a more generalized structure so as to represent not only structured properties of network objects but also the best ML model for each network object. We carefully developed MIB-IoT so as to make it compliant with the existing MIB standards. Hence, MIB-IoT profiles can be used for various applications such as abnormal behavior detection, malicious behavior detection, and data source identification. Our experiment results demonstrate that the classification algorithm using MIB-IoT is capable of achieving an accuracy of 99.81% for malicious behavior detection and 78.51% for data source identification respectively. We specifically note that the achieved accuracy (78.51%) using the pre-trained Random Forest model in the MIB-IoT profile is significantly better than the accuracy (72.63%) of the Random Forest model with default settings. In future work, we plan to improve MIB-IoT for autonomous updating, which minimizes the human burden for profiling, and we will also study the possibility of unsupervised ML algorithms.

ACKNOWLEDGMENTS

This research was partly supported by the NRF of Korea (NRF-2017K1A3A1A17092614), the ICT Consilience Creative support program (IITP-2019-2015-0-00742), and the ITRC support program (IITP-2019-2015-0-00403) supervised by the IITP.

REFERENCES

[1] A. L. Samuel, "Some studies in machine learning using the game of checkers," *IBM Journal of Research and Development*, vol. 3, no. 3, pp. 210–229, Jul 1959.

[2] H. M. B. D. Cardinaux F., Brownsell S., "Modelling of behavioural patterns for abnormality detection in the context of lifestyle reassurance." *In: Ruiz-Shulcloper J., Kropatsch W.G. (eds) Progress in Pattern Recognition, Image Analysis and Applications. CIARP 2008. Lecture Notes in Computer Science*, vol. 5197, 2008.

[3] M. Rose and K. McCloghrie, "Structure and identification of management information for tcp/ip-based internets," *IETF, STD 16, RFC 1155*, May 1990. [Online]. Available: https://www.rfc-editor.org/info/rfc1155

[4] M. Hildebrandt, S. Gutwirth, M. Hildebrandt, and S. Gutwirth, *Profiling the European citizen: cross-disciplinary perspectives*, 1st ed. Springer Publishing Company, Incorporated, 2008.

[5] S. Madden. (2003) Intel berkeley research lab data. [Online]. Available: http://db.csail.mit.edu/labdata/labdata.html

[6] R. Yan, T. Xu, and M. Potkonjak, "Data integrity attacks and defenses for intel lab sensor network," in *Proceedings of the 2015 IEEE 2Nd World Forum on Internet of Things (WF-IoT)*, ser. WF-IOT '15. Washington, DC, USA: IEEE Computer Society, 2015, pp. 721–726. [Online]. Available: http://dx.doi.org/10.1109/WF-IoT.2015.7389143

[7] Y. Meidan, M. Bohadana, A. Shabtai, J. D. Guarnizo, M. Ochoa, N. O. Tippenhauer, and Y. Elovici, "Profiliot: a machine learning approach for iot device identification based on network traffic analysis," in *Proceedings of the Symposium on Applied Computing*, ser. SAC '17. New York, NY, USA: ACM, 2017, pp. 506–509.

[8] A. Serbanati, C. M. Medaglia, and U. B. Ceipidor, "Building blocks of the internet of things: State of the art and beyond," *Deploying RFID-Challenges, Solutions, and Open Issues, InTech*, 2011.

[9] R. Clarke, "Profiling: a hidden challenge to the regulation of data surveillance," *Journal of Law and Information Science*, vol. 4, p. 403, 1993.

[10] R. Ferrando and P. Stacey, "Classification of device behaviour in internet of things infrastructures: towards distinguishing the abnormal from security threats," in *Proceedings of the 1st International Conference on Internet of Things and Machine Learning*, ser. IML '17. New York, NY, USA: ACM, 2017, pp. 57:1–57:7.

[11] S. Myagmar, A. J. Lee, and W. Yurcik, "Threat modeling as a basis for security requirements." *Symposium on Requirements Engineering for Information Security (SREIS)*, Aug 2005. [Online]. Available: http://d-scholarship.pitt.edu/16516/

[12] P. Ji and M. Szczodrak, "A multivariate model for data cleansing in sensor networks," Mar 2019.

[13] R. Yan, T. Xu, and M. Potkonjak, "Data integrity attacks and defenses for intel lab sensor network," *2015 IEEE 2nd World Forum on Internet of Things (WF-IoT)*, pp. 721–726, Dec 2015.

[14] S. Lee, S. Wi, E. Seo, J. Jung, and T. Chung, "Profiot: Abnormal behavior profiling (abp) of iot devices based on a machine learning approach," in *2017 27th International Telecommunication Networks and Applications Conference (ITNAC)*, Nov 2017, pp. 1–6.

[15] Y. x. Xie, X. g. Chen, and J. Zhan, "Data fault detection for wireless sensor networks using multi-scale PCA method," *2nd International Conference on Artificial Intelligence, Management Science and Electronic Commerce (AIMSEC)*, pp. 7035–7038, Aug 2011.

[16] M. E. Ahmed, S. Ullah, and H. Kim, "Statistical application fingerprinting for ddos attack mitigation," *IEEE Transactions on Information Forensics and Security*, vol. 14, no. 6, pp. 1471–1484, Jun 2019.

[17] K. McCloghrie and M. Rose, "Management information base for network management of tcp/ip-based internets: Mib-ii," *STD 17, RFC 1213*, Mar 1991. [Online]. Available: https://www.rfc-editor.org/info/rfc1213

[18] L. Pan and J. Li, "K-nearest neighbor based missing data estimation algorithm in wireless sensor networks," *Wireless Sensor Network*, vol. 2, pp. 115–122, Jan 2010.

[19] G. Kortuem, F. Kawsar, D. Fitton, and V. Sundramoorthy, "Smart objects as building blocks for the internet of things," *IEEE Internet Computing*, vol. 14, no. 1, pp. 44–51, Jan 2010.

Authorized licensed use limited to: Korea University. Downloaded on March 14,2021 at 10:57:02 UTC from IEEE Xplore. Restrictions apply.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 대표적 연구실적 사본 2-7 >

Location tracking technique for Regional ENF Classification Using ARIMA*

Seohyun Kim* and Ji Won Yoon†
*Dept. Cyber Defense, Graduate School of Korea University, Seoul, Republic of Korea**
School of Cyber Security, Korea University, Seoul, Republic of Korea†
{*kseohyuna, †jiwon_yoon} @korea.ac.kr

***Abstract*—Recently, a digital forensics technology has emerged that uses electrical network frequency (ENF) signals depending on the geographical environment for power supply. Through ENF data training, the technology finds the area where the signal occurred when any data was given. At this time, forecasts are usually made through interpolation based on trained data. In this paper, we proposed a location tracking method that does not require separate interpolation in the case of when trying to find the grid where the signal appears. The network frequency signal is collected from the streaming videos of the online multimedia services and the ENF signal is extracted using the secondary interpolation FFT (QIFFT) in the collected file. Subsequently, the extracted ENF signals are grouped into a constant size and trained through the Automatic Integrated Moving Average (ARIMA). Then, analyze the coefficients of regional ENF data to find meaningful sorting values in each region. This suggested how to track where online files are played and verified the accuracy of the predicted locations.**

Keywords—ARIMA, Data analysis, Data classification, ENF, Time series, SVM, Forecasting

I. Introduction

In a society where the use of computers and the Internet is indispensable, violations are occurring steadily. Under these circumstances, recent digital audio/video evidence has played a major role in solving problems. However, the problem is that audio/video evidence collected online can be arbitrarily edited or modulated by someone. To address these issues more clearly, the standard for electrical network frequency (ENF) is emerging as a means of evaluating the integrity of digital audio/video evidence and forensics. The application of the ENF criteria provides information such as editing, location, and date[1]. In particular, according to this trend, data interpolation is carried out using ENF and location tracking research through interpolation is becoming more active.

In this paper, We collected the ENF data through the website crawling and the ENF data collected from websites crawling the streaming data collected from online multimedia services are analyzed and ENF data is collected more stably[2].

Furthermore, in addition to learning the collected data using the Automatic Integrated Moving Average (ARIMA) model, extracted coefficients appear to be specific significant values for each region. This shows that location-tracking forensics is possible to predict the region where ENF data from arbitrary images are generated more simply and efficiently without the interpolation process typically used for forecasting[3].

The composition of this paper is as follows. Following the introduction in Chapter 1, Chapter 2 describes how to extract ENF signals from websites. Also Chapter 3 analyzes the characteristics of the extracted data and briefly describes the techniques to be used in training. Chapter 4 describes the new data feature analysis techniques proposed in this paper, and Chapter 5 and 6 explain the conclusions and significance of the research after each explaining the experimental results.

II. Backgrounds

A. Collecting Data

In this paper, data was collected within online multimedia services that have networks within the US power grid, which stream images and provide accurate location information to collect ENF signals with data to be used in experiments, Fig 1. The data that is actually collected are divided into East/West United States and Hawaii. After saving the latitude and longitude and m3u8 file in the streaming video, the audio was downloaded through it and resampled using the ffmpeg tool. In using the ffmpeg module, the original audio file typically has a high sampling rate, so storing the file requires a large amount of memory. Therefore, we first down-sampled the file at 1,000 Hz that did not damage the existing ENF signal and then saved it in the data/folder.



Fig. 1. Collected data from online multimedia services

B. Enf Extraction

After the collection, the ENF signal extraction phase uses the secondary interpolation FFT (QIFFT)[4] from the file to extract the ENF signal. The STFT (short-time Fourier transform) is used to efficiently analyze information on frequency changes over time for signals, and the frequency (ENF signal) resolution is calculated as 'FFT number/sample frequency'. For example, if the sampling rate is 1000 Hz and the number of FFTs is 1024, the resolution of the FFT is approximately 1 Hz (=1000/1024).

However, because ENF signals have low standard deviations, additional steps are needed to increase the

Authorized licensed use limited to: Korea University. Downloaded on March 14,2021 at 11:09:53 UTC from IEEE Xplore. Restrictions apply.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

As a result, the F1 score for each prediction data predicted through the SVM and K-neighbors classifier techniques are shown in Table 1.

TABLE I. ACCURACY SCORE OF TRAINING AND PREDICTING DATA

Train Group	F1 score	
	Support Vector Machine	*K-neighbors Classifier*
West	0.8	0.75
East	0.7	0.75
Hawaii	0.9	0.85

As shown in Table 1, comparing the results of regional labeling predictions for SVM techniques and K-neighbors classifier techniques, both showed similar accuracy for the region. In addition, local forecasting techniques using ARIMA coefficients clearly confirmed that the region where the data occurred can be found accurately without interpolation.

VI. CONCLUSION

As information technology advances, the growing number of digital data is being used in so many ways. At the same time, malicious use of voice and video data that is readily available online is also increasing. This paper proposed a new digital forensics technique that can find the characteristics of ENF data collected from online multimedia using ARIMA and use it for prediction to track the location more efficiently and simply than the interpolation method. Digital forensics using grid frequency signal data vary, but in this paper, the characteristic of grid frequency signal unique to each region is identified by coefficients. To obtain these coefficients, it is essential to estimate the correct order for the data. To extract the coefficients that mean regional characteristics and use them for learning to predict them, instead of simply learning time series data as a model in ARIMA at once, the experiment was carried out to train data repeatedly by grouping them into a certain size.

The proposed positioning technique predicts data except time data, so limitations may arise when drawing on a map, but it is significant that accurate location detection can be achieved efficiently without extra interpolation if it is simply aimed at finding the grid where signals originated through voice/video data. In the future, we expect accurate location detection research not only in the U.S. but also around the world by using ENF data extracted from online multimedia videos.

VII. ACKNOWLEGEMENT

This work was supported under the framework of international cooperation program managed by National Research Foundation of Korea (No.2017K1A3A1A1709261413).

REFERENCES

[1] Catalin Grigoras, "Applications of ENF criterion in forensic audio,video,computer and telecommunication analysis", Forensic Science International 167(2-3):136-45, May 2007

[2] GARG, Ravi; HAJJ-AHMAD, Adi; WU, Min, "Geolocation estimation from Electrical Network Frequency signals", ICASSP, pp. 2862-2866, 2013.

[3] Hyunsoo Kim, Youngbae Jeon, and Ji Won Yoon, "Construction of a National Scale ENF Map using Online Multimedia Data", ACM on Conference on Information and Knowledge Management. Pages 19–28, 2017.

[4] ABE, Mototsugu, SMITH III, Julius O. "Design criteria for the quadratically interpolated FFT method (I): Bias due to interpolation" no. STAN-M-114, 2004.

[5] G.E.P. Box, G. Jenkins, "Time Series Analysis, Forecasting and Control", Holden-Day, San Francisco,CA, 1970.

[6] Robert Kohn, Craig F. Ansley "Estimation, Prediction, and Interpolation for ARIMA Models with Missing Data", Journal of the American Statistical Association Vol. 81, No. 395, pp. 751-761 (11 pages),1986.

[7] YW Cheung, KS Lai, "Lag Order and Critical Values of the Augmented Dickey–Fuller Test" Journal of Business & Economic Statistics Volume 12, 1994.

[8] Giles M.Foody, Ajay Mathur, "Toward intelligent training of supervised image classifications: directing training data acquisition for SVM classification",Remote Sensing of Environment Volume 93, Issues 1–2, 30 October 2004.

Authorized licensed use limited to: Korea University. Downloaded on March 14,2021 at 11:09:53 UTC from IEEE Xplore. Restrictions apply.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

주 의

1. 이 보고서는 과학기술정보통신부에서 시행한 국가연구개발사업 연구개발과제 최종보고서이다.

2. 이 연구개발내용을 대외적으로 발표할 때에는 반드시 과학기술정보통신부(한국연구재단)에서 시행한 국가연구개발사업의 결과임을 밝혀야 한다.

3. 국가과학기술 기밀 유지에 필요한 내용은 대외적으로 발표 또는 공개하여서는 안 된다.